KNS 2026 AUTUMN MEETING · WORKSHOP

2026 한국원자력학회 추계학술발표회 원자력 사이버보안 워크숍

원자력시설 사이버보안 규제 변화, 이행 현황과 과제

— 디지털 I&C 시대, 대형원전에서 SMR·AR까지

일시 2026. 10. 28.(수) 14:00–18:00

장소 경주화백컨벤션센터(HICO) 2층 204호

주최 한국원자력학회

주관 원자력계측제어, 인간공학 및 자동원격 연구회

PROCEEDINGS

KNS(P)-004-2026 추계학술발표회 워크숍 발표자료집

목 차 CONTENTS

2026 한국원자력학회 추계학술발표회 · 원자력 사이버보안 워크숍
원자력시설 사이버보안 규제 변화, 이행 현황과 과제 — 디지털 I&C 시대, 대형원전에서 SMR·AR까지

No.	발표 제목 · 발표자	페이지
1	원자력시설 사이버보안 동향과 이슈 송재구 · 한국원자력연구원 (KAERI)	5
2	방사능방재법 개정에 따른 인·허가단계별 보안규제안 및 i-SMR 사이버보안 심사방향 권국희 · 한국원자력통제기술원 (KINAC)	19
3	국가 원자력시설 대상 생애주기별 보안내재화 지침 및 해설서 소개 정만현 · 국가보안기술연구소 (NSR)	31
4	원전 사이버보안 심층방호: 기술기준 분석 및 적용 방안 이정권 · 한국전력기술 (KEPCO E&C)	47
5	MSR 추진선박 개발 현황과 사이버보안 연계 이슈 김종원 · 삼성중공업	57
6	국가 핵심 인프라 보안 모니터링 시스템 강화 및 이행 현황 김진철 · 한전KDN	71
7	원전 사이버보안 관제를 위한 제어기 수준의 보안 모니터링 기술 연구 현황 손광섭 · 한국원자력연구원 (KAERI)	87

01

PRESENTATION

14:05–14:30

2026. 10. 28.(수)

2026 한국원자력학회 추계학술발표회 · 원자력 사이버보안 워크숍

원자력시설 사이버보안 규제 변화, 이행 현황과 과제 — 디지털 I&C 시대, 대형원전에서 SMR·AR까지

원자력시설 사이버보안 동향과 이슈

송재구

한국원자력연구원 (KAERI)

KOREA ATOMIC ENERGY RESEARCH INSTITUTE

원자력시설 사이버보안 동향과 이슈

Nuclear Cybersecurity: Trends and Issues

송재구 책임연구원

KAERI 한국원자력연구원 Korea Atomic Energy Research Institute

CONTENTS

원자력시설 사이버보안 규제 변화, 이행 현황과 과제 – 디지털 I&C 시대, 대형원전에서 SMR·AR까지

2026 한국원자력학회 워크숍 2026.10.28

01 디지털 I&C 전환과 보호 대상의 확장
02 활용 및 운영 환경의 변화
03 사이버보안 규제의 변화

한국원자력연구원
Korea Atomic Energy Research Institute

01

KOREA ATOMIC ENERGY RESEARCH INSTITUTE

디지털 I&C 전환과 보호 대상의 확장

01 디지털 I&C 전환과 보호 대상의 확장

Korea Atomic Energy Research Institute

원전 I&C의 디지털화 (AS-IS → TO-BE)

Analog system → Digital Convergence (원자력시설 컴퓨터 및 통신망 적용 확대) → **SMR/AR**

AS-IS

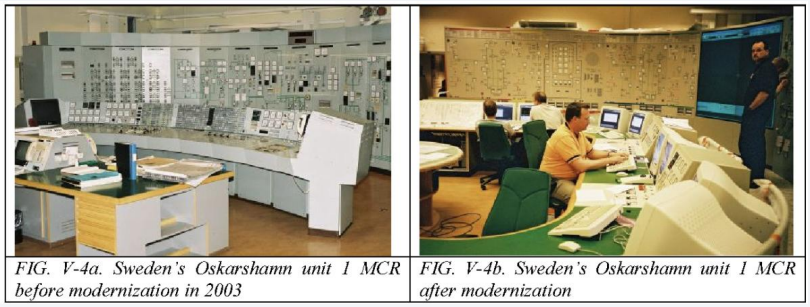


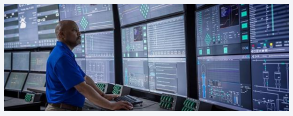
FIG. V-4a. Sweden's Oskarshamn unit 1 MCR before modernization in 2003

FIG. V-4b. Sweden's Oskarshamn unit 1 MCR after modernization

자료 출처 : Instrumentation and Control (I&C) Systems in Nuclear Power Plants: A Time of Transition - NTR2008 Supplement 오스카스함 원자력 발전소 (1972)

자료 출처 : SMART원전 MMIS 국산화, 우리가 책임진다, & I&C 기술 도약 "한국형 원전의 자부심이 되다", 원자력 신문

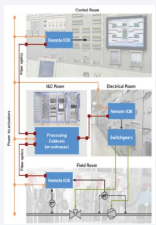
TO-BE



원격자율운전 디지털트윈기술

FPGA 등 최신 플랫폼 기술활용

최신 소프트웨어 적용



Multiplexed Communication

스마트센서, 무선기술 적용

01 디지털 I&C 전환과 보호 대상의 확장

원자력시설 사이버보안 규제 대상 (SSEP)

01 디지털 I&C 전환과 보호 대상의 확장

원자력시설 사이버보안 규제 대상 식별 : SSEP → CS → CDA

보호의 목적 = 사이버공격으로부터 필수디지털자산을 보호→ SSEP 기능의 유지

SSEP 기능

Safety · Security · EP

- 안전기능
- 보안기능
- 비상대응기능

필수시스템

Critical System (CS)

- SSEP 기능 수행
- SSEP 기능/CS 영향
- CS에 접근경로 제공
- CS를 지원 (전원·HVAC 등)
- CS를 보호하는 디지털자산

필수디지털자산

Critical Digital Asset (CDA)

- SSEP 기능수행 디지털자산
- SSEP/CS/CDA 악영향 가능 디지털자산
- CS/CDA 접근경로 제공 디지털 자산
- CS/CDA을 지원하는 디지털자산
- CS/CDA를 보호하는 디지털자산

보호 대상

= 식별된 CDA

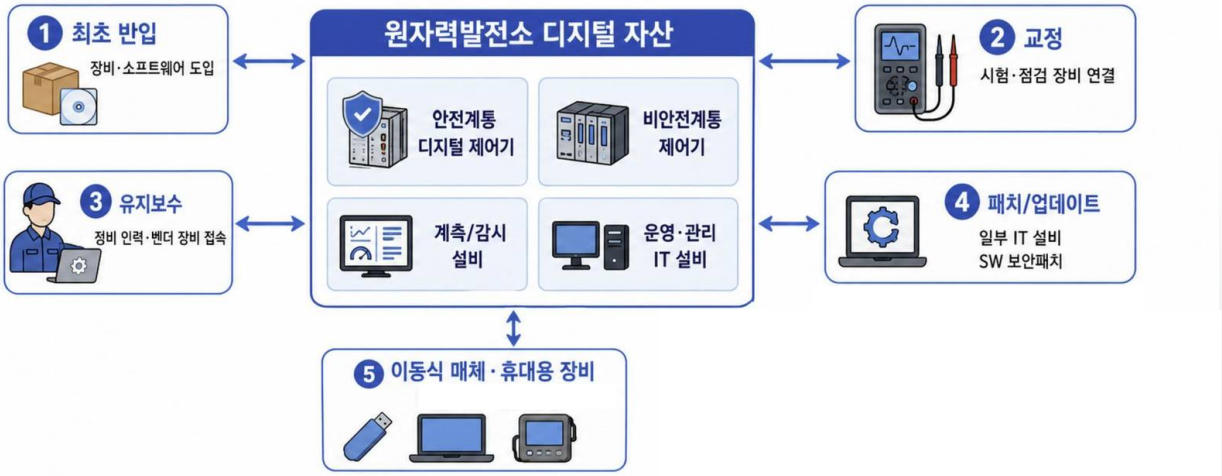
- 기술·운영·관리적 보안조치
- 보안등급·심층방어 방호구조
- 감시·취약점 평가·변경통제
- 식별 과정·결과 문서화

01 디지털 I&C 전환과 보호 대상의 확장

원자력시설 사이버보안 규제 대상 (CDA에 연결되는 모든 디지털 자산 검토 必)

3rd-party 제작사 · 상용제품

최초 반입, 교정, 유지보수, 패치 등으로 제한적 외부 인터페이스가 존재

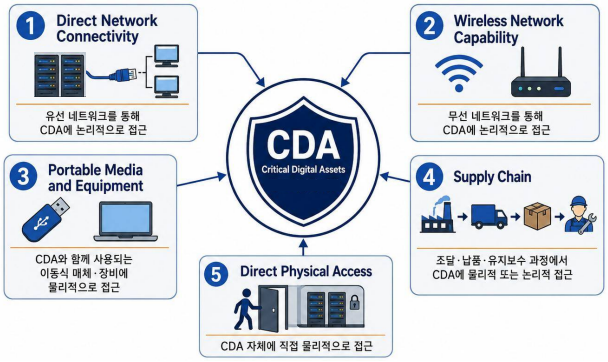


01 디지털 I&C 전환과 보호 대상의 확장

원자력시설 사이버보안 규제 대상 (CDA에 연결되는 모든 디지털 자산 검토 必)

Attack Vectors by NEI 10-09 (Revision 0) September 2011

1) Direct Network Connectivity
2) Wireless Network Capability
3) Portable Media and Equipment
4) Supply Chain



NEI 10-09 (Revision 0)
September 2011

APPENDIX A

ATTACK VECTORS

This appendix documents the capabilities required for an adversary to compromise a CDA. While these elements only describe the capability the attacker requires, these provide a foundation upon which attacks are dependent. If an adversary has none of the capabilities identified in Table A-1 at his disposal, he will not be able to complete an attack. Accordingly, these five elements are a reasonable set of attack vectors. The list in Table A-1 could be collapsed into two items, physical access and logical access. However, a set of five sub elements of physical and logical access were chosen to provide a clear and consistent way to identify and characterize the sources of threat actions against a CDA. These elements constitute the attack vectors that, if mitigated, provide high assurance that CDAs are adequately protected from cyber attacks up to and
basis threat as described in 10 CFR 73.1:

ork Connectivity – An adversary has logical access to a CDA via a
twork.
work Capability – An adversary has logical access to a CDA via a
vork.
dia and Equipment – An adversary has physical access to the portable
uipment that will be used with a CDA.
n – An adversary has physical or logical access to a CDA prior to or
ensee's procurement.
cal Access – An adversary has physical access to a CDA.

01

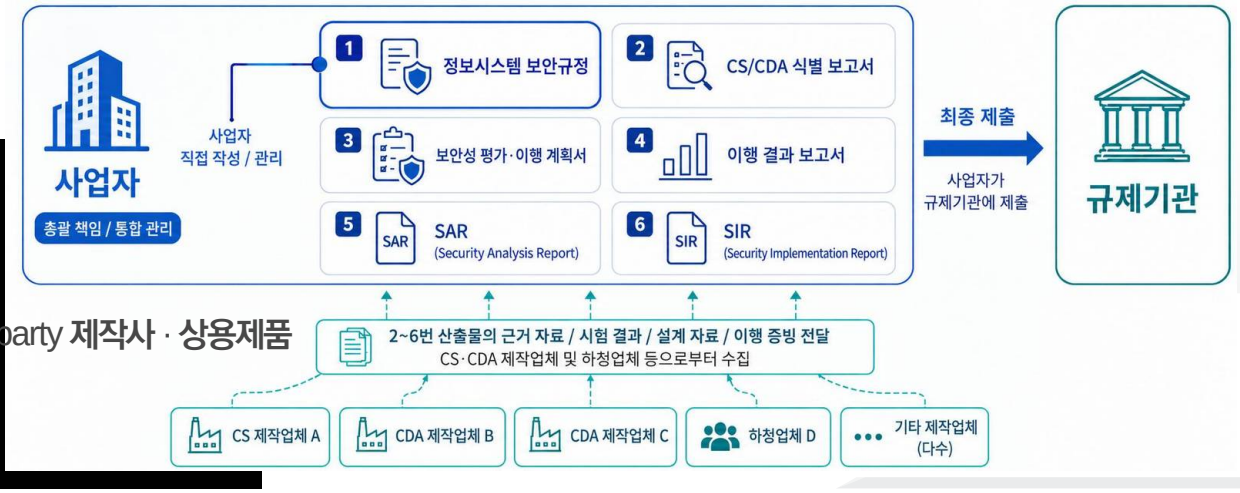
디지털 I&C 전환과 보호 대상의 확장

원자력시설 사이버보안 규제 대상 (CDA에 연결되는 모든 디지털 자산 검토 必)

지 원 번 호	KINAC/RS-015
개 정 번 호	02
발 행 일 자	2023. 12

2.2.2 사이버보안 조직의 구성 및 역할

2.2.2.1 원자력사업자는 평시 사이버보안 업무를 수행하는 운영과 분리된 독립적인 사이버 보안 조직을 책임자, 관리자, 담당자로 구성하고, 그 역할, 책임 및 권한을 다음과 같이 정의하고 문서화하여야 한다. 또한, 사이버보안 조직의 역할 등이 원자력사업자 (계약업체 포함)의 전 현장조직 및 구성원들에게 인식되도록 하여야 한다.



한국원자력연구원
Korea Atomic Energy Research Institute

02

KOREA ATOMIC ENERGY RESEARCH INSTITUTE

활용 및 운영 환경의 변화

02 활용 및 운영 환경의 변화

새로운 활용 환경

자료 출처 : KAERI, 차세대 비경수형 SMR 개발 현황, 이영준

02 활용 및 운영 환경의 변화

활용 목적과 배치 환경에 따른 사이버보안 고려사항

활용처	주요 특성	고려사항	점검 사항의 예
해상 플랫폼 (선박·부유식)	선박·해양구조물과 통합 운영, 위성통신 의존, 항해·기항에 따른 운영 환경 변화	- 원자력 규제 대상 자산과 해사 규제 대상 자산 구분 및 중복 자산의 적용 기준 설정 - 원자력 사업자와 선주·운항사 간 보안 책임 구분 - 육상 개발 단계(설계·제작)는 기존 원전과 같은 체계 적용, 해상 운영 단계는 IMO·IAEA 국제기준 논의와 연계	- 규제 적용 자산 범위와 선박 계통(항해·추진·전력) 간 경계·연결 목록 - 위성통신·항만 연계 구간 보안 통제 - 해상 운영 중 패치·정비·사고 대응 체계(육상 지원 제한 고려)
원격 지역 배치	상주 인력 최소화, 제한적 접근 환경, 원격 감시·지원(원격 운전은 검토 중인 운영개념), 현장 대응 인력 도착 지연	- 현장 대응 지연을 고려한 침입 탐지·대응·복구 기준 수립 - 원격 접속 허용 범위(감시 / 제어) 구분 기준 마련 - 통신 두절 시 안전 상태 유지 요건	- 원격 접속 인증(다중 인증)·권한·접속 기록 감사 - 비정상 행위 탐지 및 경보 전달 체계 - 통신 두절 시 현장 안전 기능의 독립 동작
산업 공정열 공급	산업설비(열 수요처)와의 시스템 연동, 제3자 운영 참여 가능성, 열 수요에 따른 출력 조정	- 원자력 시설과 산업설비 간 경계 설정 - 외부 연계 구간에 대한 사이버보안 책임 구분 및 관리 기준 수립 - 산업설비 측 이상(사이버 사건 포함)이 원자력 시설 안전에 미치는 영향 가능성 분석	- 연계 신호 방향·종류(감시 정보 / 제어 명령)와 네트워크 경계 보안 수단 - 연계 구간의 DCSA(보안 레벨·존) 설계 반영 여부 - 제3자 운영자 접근 권한·계약상 보안 의무
전력망 (스마트 그리드) 연계	전력 수요 변동에 따른 출력 조정(부하 추종), 운영 데이터 연계 가능성	- 데이터 송수신 구간 무결성·가용성 확보 기준 - 외부와 연결된 디지털 자산의 보안 범위 설정 - 출력 조정 제어 적용 방식 확인(자동 반영 사항 / 운전원 확인 후 반영 사항)	- 전력 망 연계 경로와 원자력 시설 간 분리 - 전력 망 운영자 연계 구간의 DCSA 반영 및 책임 구분 - 외부 통신 구간 메시지 인증·무결성 검증

한국원자력연구원
Korea Atomic Energy Research Institute

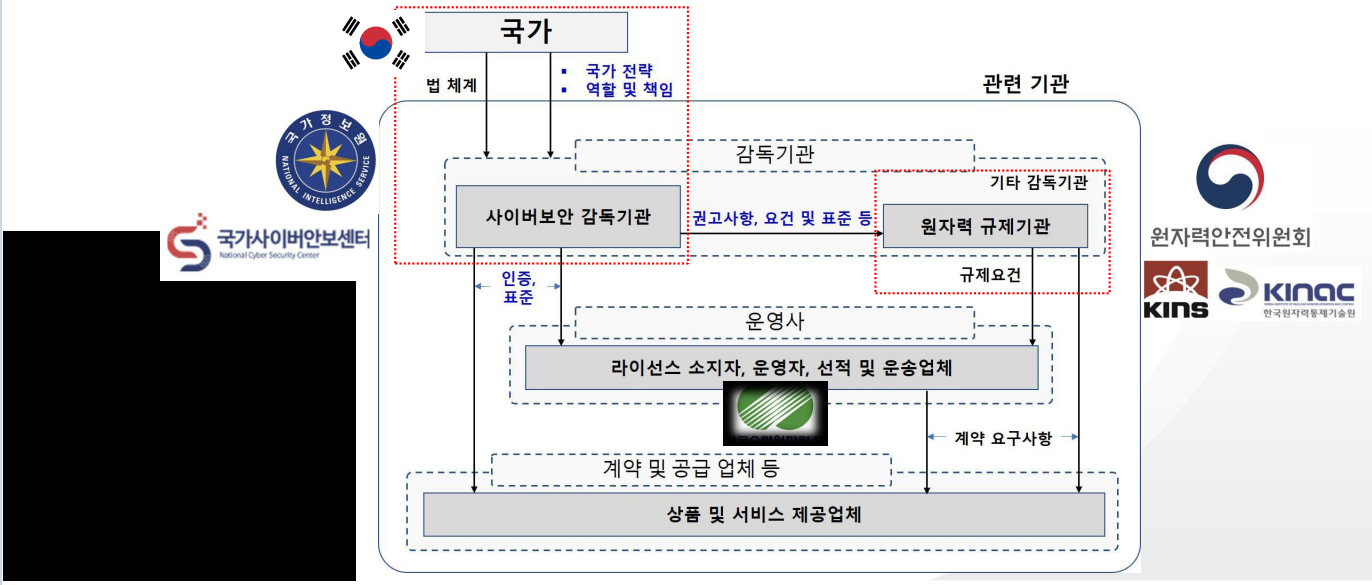
KOREA ATOMIC ENERGY RESEARCH INSTITUTE

03

사이버보안 규제의 변화

03 사이버보안 규제의 변화 (국내 현황)

국내 원자력 사이버보안 규제체계



03 사이버보안 규제의 변화 (국내 현황)

국내 원자력 사이버보안 규제체계

국가 수준

국정원

국가사이버안보센터

사이버안보 기획·조정
원자력시설 생애주기 지침
위협정보·협의체·공공기관 보안

협의·연계

원자력 규제

원자력안전위원회

안전규제

KINS

안전 심사·검사 지원
원자력안전법·RG-N08.13 SDOE

핵안보 규제

KINAC

핵안보 심사·검사 지원
방사능방재법·RS-015

15

03 사이버보안 규제의 변화 (국내 현황)

KINS/RG-N08.13, Rev. 3 "8.13 안전계통의 디지털 컴퓨터 사용"

2 디지털 안전계통 보호를 위한 보안성 개발 및 운영환경

이 규제입장은 폭포수 생명주기 모델을 참조하여 디지털 안전계통의 보호와 SDOE 수립에 대한 지침을 기술한다. 디지털 안전계통의 개발 절차는 디지털 안전계통 생명주기의 각 단계별로 SDOE를 저해하거나 계통의 신뢰성을 저하시키는 잠재적 약점 또는 취약성을 식별하고 완화해야 한다. 폭포수 생명주기는 다음과 같은 단계로 구성된다.

(1) 개념단계
(2) 요건단계
(3) 설계단계
(4) 구현단계
(5) 시험단계
(6) 설치, 점검, 인수시험단계
(7) 운영단계
(8) 유지보수단계
(9) 폐기단계

규제자는 (1) 안전계통의 개발에 적용된 개념단계부터 시험단계까지의 SDE를 위한 통제사항과 (2) 신뢰성 있는 계통 운영을 보장하기 위해 적용된 SOE를 위한 설계특성을 이 지침에 따라 평가한다. 사업자는 건설원전 인허가신청, 가동원전 변경허가신청, 표준설계인가 신청시 이와 같은 SDE 통제사항과 SOE 설계특성과 관련된 서류를 제출하여야 한다.

디지털 안전계통이 공급자에 의해 개발될 경우, 사업자는 다음을 보장할 수 있도록 하기 위한 조항을 구매시방서에 포함시켜야 한다.

(1) 공급자는 SDE를 구축하기 위한 적절한 수단을 취한다.
(2) 공급자는 디지털 안전계통의 SOE를 지원하기 위한 계통 설계상의 모든 특성을 포함한다.

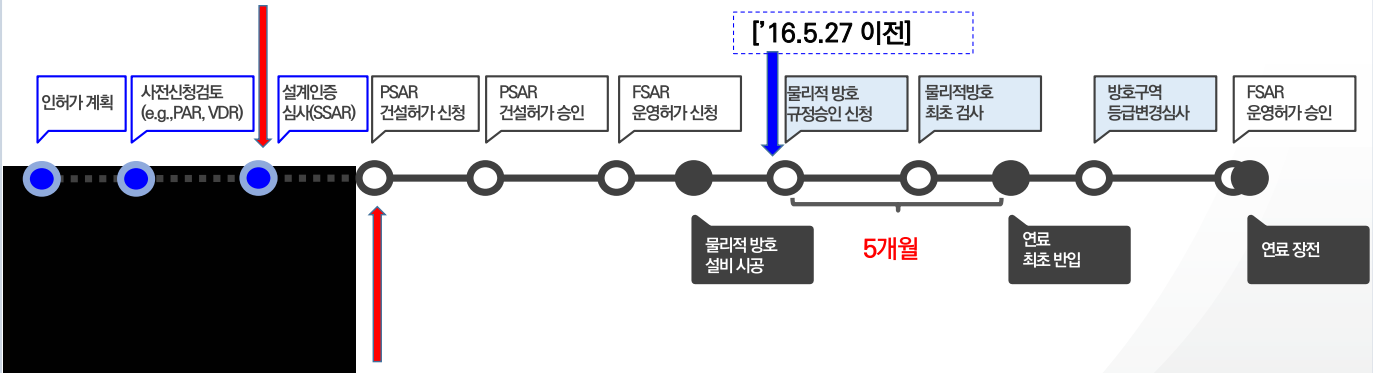
16

03 사이버보안 규제의 변화 (국내 현황)

국내 원자력시설 사이버보안 인허가 문서 제출 시점의 변화

[현]방사능방재법 개정에 따른 물리적방호규정 + 정보시스템 보안규정 제출 의무 (2027. 4. 1. 시행)

['16.5.27 이전]



[redacted]) 건설단계 사이버보안 적용 행정명령
자력시설 설계.건설단계에서의 물리적방호(사이버보안) 규제추진)

17

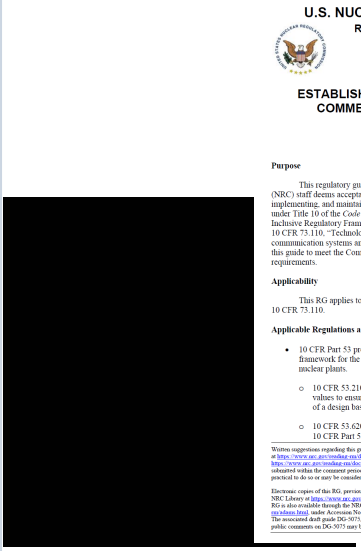
03 사이버보안 규제의 변화 (해외:규제 패러다임의 이동)

[redacted]

18

03 사이버보안 규제의 변화 (해외:규제 패러다임의 이동)

**NRC/RG 5.96은 모든 설비에 동일한 통제를 일률적으로 요구하기보다,
사이버공격이 초래할 수 있는 결과와 설비의 위험 수준을 고려하여 보안 프로그램의 수준을 조정하도록 제시.
"무엇이 더 중요한 위험인가?" 를 분석하고 그에 맞춰 보호.탐지.대응.역량을 설계하도록 가이드**



U.S. NUCLEAR REGULATORY COMMISSION
REGULATORY GUIDE 5.96, Revision 0

Issue Date: March 2026
Technical Leads: Ismael Garcia and Tammie Rivera

ESTABLISHING CYBERSECURITY PROGRAMS FOR COMMERCIAL NUCLEAR PLANTS LICENSED UNDER 10 CFR PART 53

A. INTRODUCTION

Purpose

This regulatory guide (RG) describes a method that the U.S. Nuclear Regulatory Commission (NRC) staff deems acceptable for complying with the Commission's regulations for establishing, implementing, and maintaining a cybersecurity program at commercial nuclear plants that are licensed under Title 10 of the *Code of Federal Regulations* (10 CFR) Part 53, "Risk-Informed, Technology-Inclusive Regulatory Framework for Commercial Nuclear Plants" (Ref. 1), subject to the requirements in 10 CFR 73.110, "Technology inclusive requirements for protection of digital computer and communication systems and networks" (Ref. 2). Licensees may use methods other than those described in this guide to meet the Commission's regulations if such methods satisfy the stated regulatory requirements.

Applicability

This RG applies to applicants and holders of a license under the provisions of 10 CFR Part 53 and 10 CFR 73.110.

Applicable Regulations and Orders

- 10 CFR Part 53 provides an alternative risk-informed and technology-inclusive regulatory framework for the licensing, construction, operation, and decommissioning of commercial nuclear plants.
  - 10 CFR 53.210, "Safety criteria for design-basis accidents," requires licensees to meet dose values to ensure that plants are designed to limit the public's radiation exposure in the event of a design basis accident.
  - 10 CFR 53.620, "Manufacturing" requires the holders of a manufacturing license under 10 CFR Part 53 to develop plans, programs, and organizational units to manage and control

Written suggestions regarding this guide or development of new guides may be submitted through the NRC's public Web site in the NRC Library at https://www.nrc.gov/reading-rm/doc-collections/reg-guides/index.html, under Document Collections, in Regulatory Guides, at https://www.nrc.gov/reading-rm/doc-collections/reg-guides/contactus.html. During the development process of new guides suggestions should be submitted within the comment period for immediate consideration. Suggestions received outside of the comment period will be considered if practical to do so or may be considered for future updates.

Electronic copies of this RG, previous versions of RGs, and other recently issued guides are available through the NRC's public Web site in the NRC Library at https://www.nrc.gov/reading-rm/doc-collections/reg-guides/index.html, under Document Collections, in Regulatory Guides. This RG is also available through the NRC's Agencywide Documents Access and Management System (ADAMS) at http://www.nrc.gov/reading-rm/adams.html, under Accession No. ML25332A008. The regulatory analysis may be found in ADAMS under Accession No. ML26042A230. The associated draft guide DG-5079, Revision 0, may be found in ADAMS under Accession No. ML22199A257. The staff responses to the public comments on DG-5079 may be found under ADAMS Accession No. ML26042A228.

03 사이버보안 규제의 변화 (해외:규제 패러다임의 이동)

**보안 통제 목록의 이행 확인 중심에서,
설계 단계는 결과 기반 차등 보호로, 운영 단계는 이행 효과의 입증 방식으로 전환**

기술 포괄
노형·운영개념과 무관하게 적용되는 요구 구조 (Part 53)

결과 기반 차등
잠재적 공격 결과에 비례한 보호 (§73.110 ·TRA)

보안 통제 효과의 입증
통제를 갖췄다는 문서가 아니라, 작동·유지되고 있다는 기록으로 입증

자료 출처: 10 CFR 73.54 / NRC Part 53 최종규칙(2026.3) / CSA N290.7:21 / ONR SyAPs 2022

03 사이버보안 규제의 변화 (해외:규제 패러다임의 이동)

CIE(Cyber-Informed Engineering)

- 미 DOE·INL이 추진하는 공학 접근법(12개 원칙)
- 사이버 공격의 결과를 공학적 수단(수동 조작, 아날로그 이중화, 기능 분리 등)으로 제거·축소
- 설계 초기부터 운영까지 생애주기 전반에 적용, 에너지 분야 중심으로 OT 전반에 확산 (미 DOE 국가 CIE 전략, 2022)

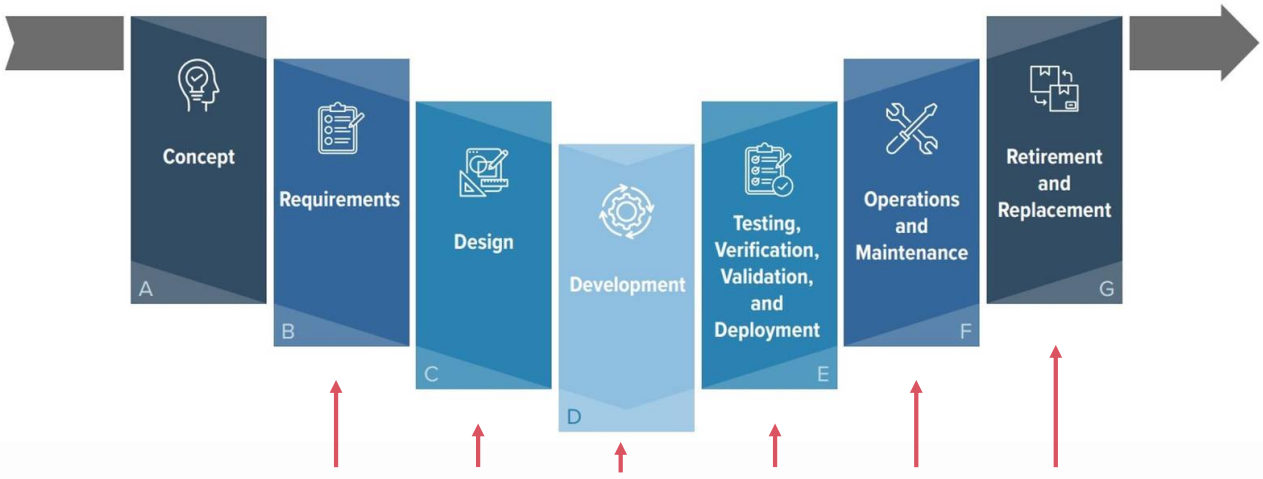
보안을 사후 통제가 아닌 설계의 요건부터 → Security by Design, Shift left

01 결과 중심 설계 Consequence-Focused Design	02 공학적 통제 Engineered Controls	03 안전한 정보 구조 Secure Information Architecture	04 설계 단순화 Design Simplification
05 복원력 있는 다층 방어 Resilient Layered Defenses	06 능동 방어 Active Defense	07 상호의존성 평가 Interdependency Evaluation	08 디지털 자산 인식 Digital Asset Awareness
09 공급망 보안 통제 Cyber-Secure Supply Chain Controls	10 계획된 복원력 Planned Resilience	11 엔지니어링 정보 통제 Engineering Information Control	12 사이버보안 문화 Cybersecurity Culture

자료 출처: DOE National Cyber-Informed Engineering Strategy(2022.6) / INL CIE·CCE 프로그램

03 사이버보안 규제의 변화 (해외:규제 패러다임의 이동)

보안을 사후 통제가 아닌 설계 초기부터 보안 내재화 → Security by Design, Shift left



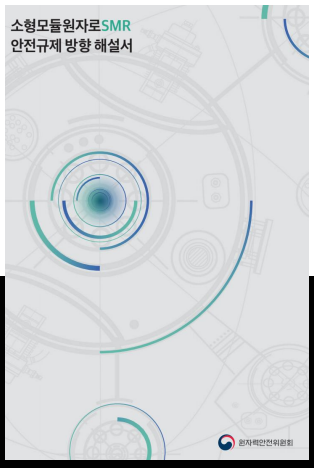
Cybersecurity is an essential consideration throughout the lifecycle.

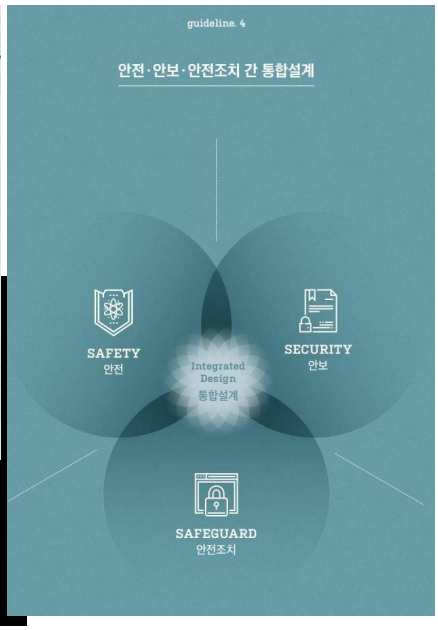
Image credit cyber-informed engineering implementation guide, fig 2. CIE system Engineering Lifecycle Model

03 사이버보안 규제의 변화 (규제 패러다임의 이동)

Korea Atomic Energy Research Institute

소형모듈원자로 SMR 안전규제 방향 해설서





안전, 안보 및 안전조치 간 통합된 방식의 설계를 통해 핵안보, 핵확산 저항성이 확보되고 안전성이 증진되도록 필요한 요소들이 고려되어야 한다.

원자로 설계는 3S(Safety·Security·Safeguard, 안전·안보·안전조치) 개념을 바탕으로 원전의 안전 대책, 핵안보, 핵물질 계량관리시스템 간 간섭 없이 각각의 본래 목적을 달성할 수 있도록 통합된 방식으로 설계하고 이행될 수 있습니다.

SMR은 대규모 전력망 연계 없는 오지 설치, 열·수소 생산 부대설비 운영 등 기존 대형 원전과는 다른 부지 및 구조물 형상을 가질 것으로 예상됨에 따라 핵물질의 불법이전, 사보타주 등 핵안보·핵확산 저항성 측면이 설계에 고려될 필요가 있습니다.

또한 SMR이 지향하는 혁신기술을 구현하기 위해 디지털 장비 및 최신 정보기술을 확대, 적용할 것으로 예상되는 바, 이에 따른 사이버보안 측면의 취약성을 사전에 식별하고 이에 대비할 필요가 있습니다.

관련 국내·외 기준
- IAEA SSR(특정안전요건)-2/1(설계) : 안전·보안·안전조치의 연계를 통해 통합된 방식으로 설계
- 미국 원자력규제위원회(NRC) 정책성명 : 격납건물 건전성 상실을 보호하는 특성과 항공기 충돌에도 노심 냉각을 유지하는 능력 등을 가진 설계

03 사이버보안 규제의 변화 (규제 패러다임의 이동)

Korea Atomic Energy Research Institute

디지털 전환과 신규 발전소 건설계획에 따른 사이버보안 대응 준비 필요

도입 규모와 준공 목표

대형 원전 2기
총 2.8GW

소형모듈원전(SMR)
0.7GW

예상 준공 시점

2035년(예상)	2037년(예상)	2038년(예상)
SMR 준공	대형 원전 1호기 준공	대형 원전 2호기 준공

단계별 주요 절차

1 부지 선정 및 예정구역 고시 — 2027년 초까지 (예상)
- 지자체 유치 공모·접수 및 선정 평가
- 부지 선정·발표와 전략환경영향평가
- 관계기관·지자체 의견 조회 후 예정구역 고시

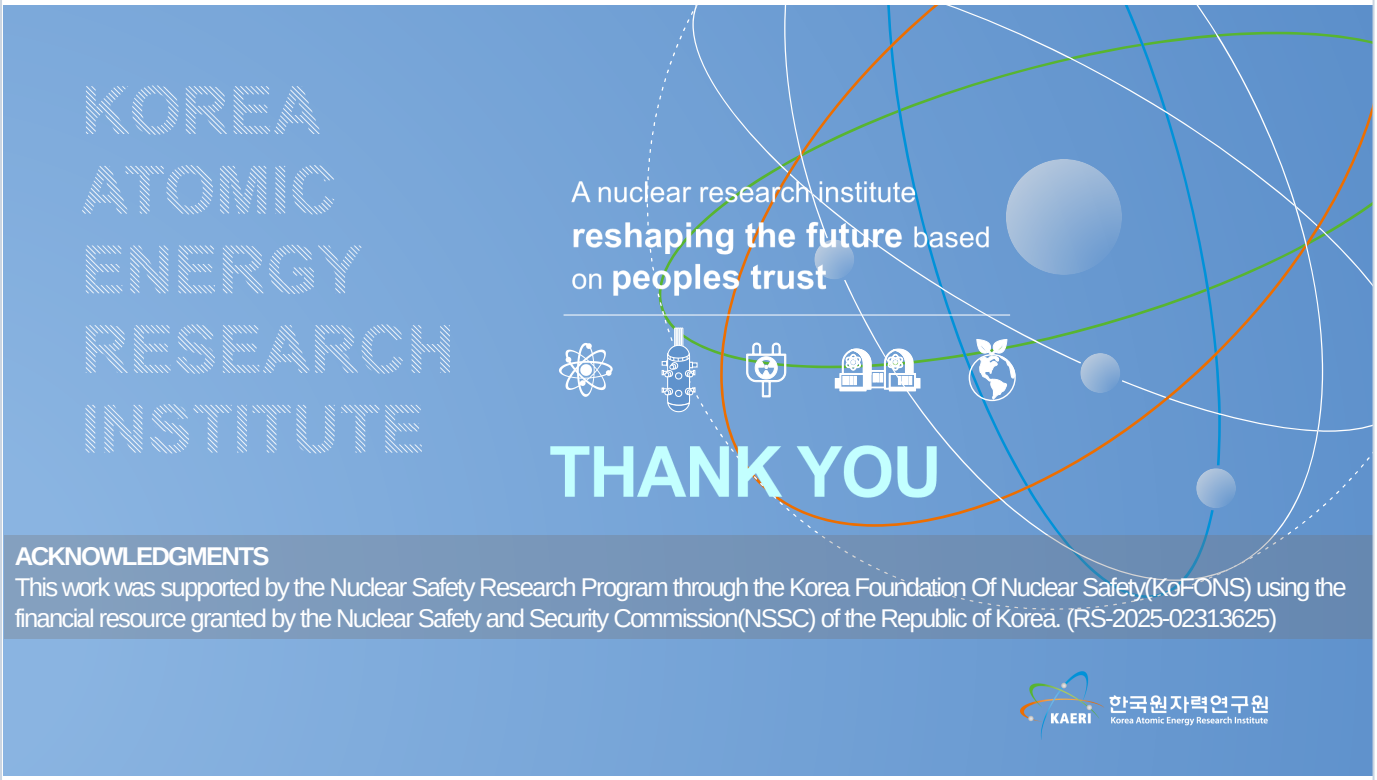
2 인허가 준비 — 2029년까지 (예상)
- 환경영향평가 및 방사선환경영향평가
- 전원개발사업 실시계획 승인
- 건설허가 신청

3 건설 — 2031년부터 (예상)
- 건설허가 및 공사계획 인가
- 본관 기초굴착과 최초 콘크리트 타설
- 사용전검사 및 운영허가

4 연료장전·시운전 및 준공 — 2037~2038년 (예상)
- 연료장전과 시운전
- 단계별 검증 후 준공

24

제 11차 전력수급기본계획



ACKNOWLEDGMENTS

This work was supported by the Nuclear Safety Research Program through the Korea Foundation Of Nuclear Safety(KoFONS) using the financial resource granted by the Nuclear Safety and Security Commission(NSSC) of the Republic of Korea. (RS-2025-02313625)

KAERI 한국원자력연구원 Korea Atomic Energy Research Institute

02

PRESENTATION

14:30–14:55

2026. 10. 28.(수)

2026 한국원자력학회 추계학술발표회 · 원자력 사이버보안 워크숍
원자력시설 사이버보안 규제 변화, 이행 현황과 과제 — 디지털 I&C 시대, 대형원전에서 SMR·AR까지

방사능방재법 개정에 따른 인·허가단계별 보안규제안 및 i-SMR 사이버보안 심사방향

권국희

한국원자력통제기술원 (KINAC)

방사능방재법 개정에 따른 보안규제안 및 i-SMR 사이버보안 심사방향

2026.10.28.

한국원자력통제기술원
혁신규제실 권국희

KINAC
KOREA INSTITUTE OF NUCLEAR NONPROLIFERATION AND CONTROL

목 차

01 개정 방사능방재법('26.3.)
02 하위 법령 및 고시 개정(안)
03 인·허가 단계별 심사 범위
04 i-SMR 사이버보안 심사방향

KINAC 한국원자력통제기술원

ㅇ 개정 방사능방재법(원자력시설 등의 방호 및 방사능 방재 대책법)

◆ 배경 및 주요 내용('26.3.31.(공포), '27.4.1.(시행))

- 설계, 건설단계부터 안전(safety)과 연계한 보안(security) 설계 및 체계를 위한 법적 근거 마련
- 원자력시설의 물리적방호(사이버보안 포함) 책임을 기존 원자력사업자에서 표준설계인가, 건설허가 및 건설·운영허가 신청자까지 확대
- 표준설계인가 단계에서 승인된 방호규정등(4종)의 효력을 표준설계인가 유효기간으로 한정

◆ 개정 전·후 표

현행	개정
제9조(물리적방호에 대한 원자력사업자의 책임) ① 원자력사업자는 대통령령으로 정하는 바에 따라 다음 각 호의 사항에 대하여 원자력안전위원회의 승인을 받아야 하고, 이를 변경하려는 경우에도 또한 같다. 다만, 총리령으로 정하는 경미한 사항을 변경하려는 경우에는 원자력안전위원회에 신고하여야 한다.	제9조(물리적방호에 대한 원자력사업자 등의 책임) ① 원자력사업자, 「원자력안전법」 제10조·제30조·제35조제1항에 따라 건설허가를 신청한 자, 같은 법 제12조에 따른 표준설계인가를 신청한 자 또는 같은 법 제63조에 따라 건설·운영 허가를 신청한 자는 대통령령으로 정하는 바에 따라 ----------
1. 제3조제2항 각 호의 사항을 위한 물리적방호 시설·설비 및 그 운영체제 2. 원자력시설등의 물리적방호를 위한 규정(이하 "물리적방호규정"이라 한다) 3. 핵물질의 불법이전 및 원자력시설등의 위협에 대한 조치계획(이하 "방호비상계획") 4. 전자적 침해행위에 대한 원자력시설 컴퓨터 및 정보시스템 보안규정(이하 "정보시스템 보안규정")	좌동
<신 설>	② 「원자력안전법」 제12조에 따른 표준설계인가를 신청한 자가 제1항에 따라 승인을 받은 경우 그 효력은 해당 표준설계인가의 유효기간이 종료하는 날까지로 한다. 다만, 원자력안전위원회는 유효기간 중이라도 물리적방호에 중대한 영향이 있다고 인정하면 승인받은 사항에 대한 시정 또는 보완을 명할 수 있다.
② 제1항 각 호의 사항에 대한 작성지침 등 세부기준은 총리령으로 정한다.	③ (현행 제2항과 같음)

ㅇ 개정 방사능방재법(원자력시설 등의 방호 및 방사능 방재 대책법)

◆ 부칙

- 제1조(시행일) 이 법은 공포한 날부터 1년이 경과한 날부터 시행한다.
- 제2조(건설허가를 신청한 자 등의 물리적방호에 대한 책임에 관한 적용례) 제9조제1항의 개정규정은 이 법 시행 당시 「원자력안전법」 제10조·제30조·제35조제1항·제63조에 따른 허가신청서가 제출된 경우 또는 같은 법 제12조에 따른 인가신청서가 제출된 경우에도 적용한다. 이 경우 이 법 시행일부터 1년 이내에 제9조제1항 각 호의 사항을 작성하여 원자력안전위원회에 제출하여야 한다.

◆ 개정 전·후 비교

구분		기존 법령	기존 운영	개정 법령
표준설계인가 신청		-	-	(표준설계)물리적방호규정등 신청
표준설계인가 승인		-	-	(표준설계)물리적방호규정등 승인
건설허가 신청		-	물리적방호규정등 신청	(예비)물리적방호규정등 신청
건설허가 승인		-	-	(예비)물리적방호규정등 승인
건설단계	운영허가 신청			(최종)물리적방호규정등 신청
	신연료 반입	원자력시설등의 사용개시 5개월 전 물리적방호규정등 제출	신연료반입 전 물리적방호규정등 승인 (신연료반입 전 최초검사)	(최종)물리적방호규정등 승인
	운영허가 승인			

ㅇ하위 법령 및 고시 개정(안)

◆ 배경 및 주요 내용

➢ 방사능방재법률 개정('26.3.31 공포, '27.4.1 시행)에 따라, 물리적방호규정등(4종)의 제출 시기, 처리 기간, 작성 방법 등 하위 시행령, 시행규칙 및 관련 고시를 정비하여 개정

◆ (시행령) 제출 시기 명확화 및 인허가 단계별 구분

➢ 법 개정에 따라 확대된 물리적방호규정등 승인 대상별 제출 시기를 명확화 (안제17조제1항개정)

➢ 인·허가 신청 시 물리적방호규정등도 제출토록 함으로써 안전성평가 시 보안성평가도 수행

현 행	개정안	개정이유
제17조(물리적방호규정등 승인신청) ② 법 제9조제1항 각 호 외의 부분 본문에 ~~ 대하여 승인을 받으려는 **원자력사업자는** 이에 관한 승인신청서를 **원자력시설등의 사용개시 5개월 전까지** 원자력안전위원회에 제출하여야 한다.	**제17조(물리적방호규정등 승인신청)** ② 법 제9조제1항 각 호 외의 부분 본문에 ~~ 대하여 승인을 받으려는 **자는 다음 각 호의 구분에 따라** 이에 관한 승인신청서를 원자력안전위원회에 제출하여야 한다.	• 신청 주체를 세분화하고 제출 시기를 명확화하기 위해 각호로 구분
<신 설>	1.「원자력안전법」제10조·제20조·제30조·제30조의2·제35조제1항·제39조의4제1항·제63조에 따른 허가 또는 같은 법 제12조에 따른 표준설계인가를 신청하는 자 : 해당 허가 또는 인가를 신청할 때	
<신 설>	2. 제6조에 따른 생산허가등을 받은 자: 그 허가를 받은 날부터 6개월 이내	• 18.5 페타베크렐 이상의 방사성동위원소 생산허가등을 받은 날부터 6개월 이내
<신 설>	3. 법 제2조제1항제10호아목에 해당하게 된 자 : 해당하게 된 날부터 6개월 이내	• 핵물질 사용·소지허가 받은 자 중 원안위 고시에 의해 확정된 후 6개월* 이내

ㅇ하위 법령 및 고시 개정(안)

◆ (시행령) 제출 시기 명확화 및 인허가 단계별 구분(계속)

➢ 개정법에 따라 표준설계인가, 건설허가 및 건설·운영허가를 신청한 자도 규정등을 제출·승인받아야 하므로, 기존 '물리적방호규정등'을 인·허가 단계별로 명칭 구분 (안 제17조제2항 신설)

현 행	개정안
<신 설>	**제17조(물리적방호규정등 승인신청)** ② 제1항에 따라 신청하는 물리적방호규정등은 다음과 같이 구분한다. **1. 표준설계물리적방호규정등** :「원자력안전법」제12조에 따른 표준설계인가를 신청할 때 제출하는 물리적방호규정등 **2. 예비물리적방호규정등** :「원자력안전법」제10조·제30조 또는 제35조제1항에 따른 건설허가를 신청할 때 제출하는 물리적방호규정등 **3. 최종물리적방호규정등** :「원자력안전법」제20조·제30조의2 또는 제39조의4제1항에 따른 운영허가나 같은 법 제63조에 따른 건설·운영허가를 신청할 때, 그 밖에 제1항제2호 및 제3호에 따라 제출하는 물리적방호규정등

➢ 변경승인 대상에 확대된 대상을 포함하기 위해 문구 수정 (안 제17조제3항 개정)

현 행	개정안
제17조(물리적방호규정등 승인신청) ② 원자력사업자는 법 제9조제1항 각 호 외의 부분 본문에 따라 물리적방호규정등을 변경하고자 하는 경우에는 그 변경할 사항과 이유를 적은 변경승인신청서를 원자력안전위원회에 제출하여야 한다.	**제17조(물리적방호규정등 승인신청)** ③ 물리적방호규정등을 승인받은 자는 법 제9조제1항 각 호 외의 부분 본문에 따라 물리적방호규정등을 변경하고자 하는 경우에는 그 변경할 사항과 이유를 적은 변경승인신청서를 원자력안전위원회에 제출하여야 한다.

ㅇ하위 법령 및 고시 개정(안)

◆ (시행령) 승인 등 처리기간 명확화

➢ 물리적방호규정등 승인 처리기간을 원안법상 인·허가 처리기간과 동일하게 설정하고 처리기간에 불산입되는 사항도 명시 (안 제17조의2 신설)

현 행	개정안	개정이유
<신 설>	제17조의2(승인 등의 처리기간) ① 원자력안전위원회는 제17조에 따른 물리적방호규정등의 승인 또는 변경승인의 신청을 받은 경우에는 24개월 이내의 범위에서 총리령으로 정하는 기간 이내에 처리하여야 한다.	• 승인신청서 제출시점이 '사용개시 5개월 전'에서 '인허가 신청시'로 변경됨에 따라 처리기간 명시 필요
<신 설>	② 다음 각 호의 어느 하나에 해당하는 기간은 제1항에 따른 승인의 처리기간에 산입(算入)하지 아니한다. 1. 신청서류의 보완 또는 수정에 드는 기간 2. 그 밖에 방호요건 이행의 적정성을 확인하기 위한 시험·평가 등 부득이한 사유로 인하여 추가로 필요한 기간	• 원안법 시행령 제19조제2항과 유사한 불산입 사항 명시

ㅇ하위 법령 및 고시 개정(안)

◆ (시행령) 최초검사의 실효성 강화

➢ 최종물리적방호규정등 승인 이후 받는 최초검사를 합격한 후 핵물질, 방사성물질 또는 방사성폐기물을 반입할 수 있도록 명시 (안 제18조 개정)

현 행	개정안	개정이유
제18조(검사) ① 법 제12조제1항에 따라 원자력사업자는 다음 각 호의 구분에 따라 원자력안전위원회의 검사를 받아야 한다.	제18조(검사) ① 제17조제2항제3호에 따른 최종물리적방호규정등의 승인을 받은 원자력사업자는 다음 각 호의 구분에 따라 원자력안전위원회의 검사를 받아야 한다.	• 최초검사 대상을 최종물리적방호규정등의 승인을 받은 원자력사업자로 한정
1. 최초검사 : 핵물질, 방사성물질 또는 방사성폐기물을 원자력시설에 반입하기 전에 해당 원자력시설에 대한 방호에 관한 검사. 2. 정기검사 : ~ 3. 운반검사 : ~	좌동	-
③ 제1항제1호 또는 제3호에 따른 최초검사 또는 운반검사는 해당 물질의 반입 또는 운반개시 14일 전까지 신청하여야 한다.	③ 제1항제1호에 따른 최초검사를 받으려는 자는 검사를 받으려는 날의 30일 전까지, 같은 항 제3호에 따른 운반검사를 받으려는 자는 해당 물질의 운반개시 14일 전까지 원자력안전위원회에 신청하여야 한다.	• 원안법상 사용전 검사 신청 기한과 동일하게 '검사를 받으려는 날의 30일 전까지'로 변경
<신 설>	④ 제17조제2항제3호에 따라 승인받은 물리적방호규정등이 이행된 상태가 제16조에 따른 방호요건에 적합한 경우 최초검사 합격으로 한다.	• 사업자가 물질(신연료) 반입 예정일에 앞서 최초검사를 받고 합격 후 핵물질을 반입하도록 하고, 최초검사 합격 판단 기준을 방호요건 적합 여부로 명시
<신 설>	⑤ 원자력사업자는 최초검사를 받아 이에 합격한 후가 아니면 해당 물질을 반입하여서는 아니 된다.	

ㅇ하위 법령 및 고시 개정(안)

KINAC 한국원자력통제기술원 9

◆ (시행규칙) 신청서식 구분 및 승인 처리기간 상세화

➢ 시행령에서 위임한 물리적방호규정등의 승인 및 변경승인의 처리기간을 구체적으로 명시 (안 제3조의2 신설, 붙임4 신설)

현행	개정안	개정이유
<신 설>	제3조의2(승인 등의 처리기간) 영 제17조의2제1항에 따른 물리적방호규정등의 승인 및 변경승인의 처리기간은 별표 1의4와 같다.	• 영 제17조의2제1항이 처리기간을 '24개월 이내의 범위에서 총리령으로 정하는 기간'으로 위임함에 따라 원안법상 처리기간을 참고하여 유형별 처리기간을 별표로 상세화

■ 원자력시설 등의 방호 및 방사능 방재 대책법 시행규칙[별표1의4] <신설2027.3.31.>

물리적방호규정등의 승인 및 변경승인 처리기간(제3조의2 관련)

신청인 구분	승인	변경승인
「원자력안전법」 제12조에 따라 표준설계인가를 신청하는 자	24개월	24개월
「원자력안전법」 제10조에 따라 발전용원자로 및 관계시설의 건설허가를 신청하는 자	24개월 (15개월)주)	24개월
「원자력안전법」 제20조에 따라 발전용원자로 및 관계시설의 운영허가를 신청하는 자	24개월 (15개월)주)	24개월
「원자력안전법」 제30조에 따라 연구용 또는 교육용 원자로 및 관계시설의 건설허가를 신청하는 자	24개월	24개월
「원자력안전법」 제30조의2에 따라 연구용 또는 교육용 원자로 및 관계시설의 운영허가를 신청하는 자	24개월	24개월
「원자력안전법」 제35조제1항에 따라 핵연료주기시설의 건설허가를 신청하는 자	24개월	24개월
「원자력안전법」 제39조의4제1항에 따라 핵연료주기시설의 운영허가를 신청하는 자	24개월	24개월
「원자력안전법」 제63조에 따라 방사성폐기물의 저장 · 처리 · 처분시설 및 그 부속시설의 건설 · 운영허가를 신청하는 자	24개월	18개월
「원자력안전법」 제45조에 따라 핵연료물질의 사용 또는 소지 허가를 받은 자 중 원자력안전위원회가 정하여 고시하는 자	30일	15일
영 제6조에 따른 원자력사업자(방사성동위원소 생산허가등을 받은 자 중에서 18.5 페타베크렐 이상의 방사성동위원소의 생산허가등을 받은 자)	20일	10일

주) 표준설계인가를 받은 경우로 한정

ㅇ하위 법령 및 고시 개정(안)

KINAC 한국원자력통제기술원 10

◆ (시행규칙) 물리적방호규정등 작성시 설계 성숙도 차이 반영 및 근거 기술

➢ 설계 또는 건설 단계에서의 물리적방호규정등 작성 시 운영 단계와 동일하게 적용하기 어려운 부분을 고려 (안 제5조 개정)

현 행	개정안	개정이유
제5조(물리적방호규정등의 작성) 법 제9조제2항에 따른 물리적방호규정등에 대한 작성지침 등 세부기준은 별표1과같다.	제5조(물리적방호규정등의작성) 법 제9조제2항에따른물리적방호규정 등에 대한 작성지침 등 세부기준은 별표 1과 같다. 다만, 영 제17조제2항에 따른 표준설계물리적방호규정등 또는 예비물리적방호규정등에 포함하기에 적합하지 아니한 사항은 기재하지 아니할 수 있다.	• 현행 물리적방호규정등은 운영 단계를 전제하고 있어, 부지 특성, 시설의 상세설계, 운영 인력·조직 등이 확정되지 않는 설계 또는 건설 단계에서는 동일하게 적용하기 어려워 그 근거를 시행규칙에 마련

➢ 물리적방호규정등 작성 시 방호요건 충족에 대한 판단 근거를 제시하도록 하여 심사의 실효성 확보 (별표1 '물리적방호규정등의 작성 지침 등 세부기준(제5조 관련) 개정)

현 행	개정안
1. 물리적방호규정등의 작성지침 가. 양적(量的)으로 표현이 가능한 사항은 양적으로 기술할 것 나.「보안업무규정」 제2조제1호에 따른 비밀에 해당하는 사항은 별도로 분리하여 작성할 것	1. 물리적방호규정등의 작성지침 가. 양적(量的)으로 표현이 가능한 사항은 양적으로 기술할 것 나.「보안업무규정」 제2조제1호에 따른 비밀에 해당하는 사항은 별도로 분리하여 작성할 것 다. 영 제16조에 따른 방호요건을 충족하고 있음을 확인할 수 있는 근거를 기술할 것

ㅇ하위 법령 및 고시 개정(안)

◆ **(고시) 물리적방호규정등 작성시 설계 성숙도 차이 반영 및 근거 기술**

➢ 설계 성숙도에 따라 표준설계물리적방호규정등과 예비물리적방호규정등에서 작성하기 적합하지 않은 항목은 사유를 제시하도록 함 (안 제3조 신설)

현행	개정안	개정이유
<신 설>	**제3조(일반지침)** 이 고시에서 정하는 세부작성 항목 중 표준설계물리적방호규정등 또는 예비물리적방호규정등에 포함하기에 적합하지 아니하여 기재하지 않는 항목에 대해서는 그 사유를 제시하여야 한다.	• 표준설계인가 및 건설허가 신청단계에서는 모든 항목을 작성하기는 어려우나, 사유를 제시하도록 하여 후속 인허가 단계에서 보완되어야 할 내용을 관리

ㅇ인·허가 단계별 심사 범위

◆ **원자력안전법상 인허가 단계**

➢ **표준설계인가**(원자력안전법 제12조, 시행규칙 제9조)

- **동일한 설계의** 발전용원자로 및 관계시설을 **반복적으로 건설하려는 사업자**는 반복건설에 따른 규제부담을 줄이기 위해 표준설계(**분야별 설계기준, 설계내용 및 설계·시공·성능 검증계획**)에 대해 인가를 받을 수 있음

➢ **건설허가**(원자력안전법 제10조)

- 발전용원자로 및 관계시설을 **건설하려는 사업자**는 예비안전성분석보고서(설비 전 분야에 대한 **예비 안전성 설계결과**), 방사선환경영향평가서 등을 제출하여 허가를 받아야 함

➢ **운영허가**(원자력안전법 제20조)

- 발전용원자로 및 관계시설을 **운영하려는 사업자**는 최종안전성분석보고서(설비 전 분야에 대한 **최종 안전성 설계결과**), 운영기술지침서, 방사선환경영향평가 등을 제출하여 허가를 받아야 함

ㅇ인·허가 단계별 심사 범위

◆ 원자력시설 단계별 설계 일반

➢ 일반적으로, 사업자/설계자는 단계별 설계를 수행하며, 이에 따라 규제자 역시 단계별 심사

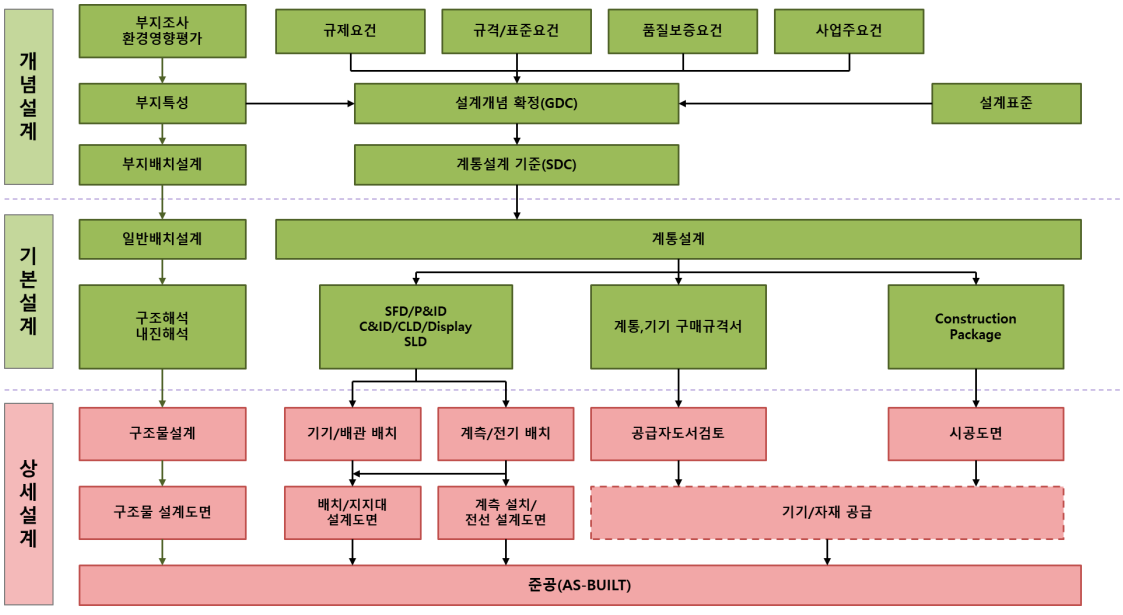
구분		1단계 (개념 설계)	2단계 (플랜트 수준 설계)	3단계 (계통 수준 설계)	4단계 (기기 수준 설계)
사업자 (설계 내용)	주요 설계 활동	• 안전/환경/**보안 관련** 요구되는 규제요건 및 표준 분석 • 상위 설계 요구사항 및 안전원칙 결정 • 사전설계에 대한 규제자와의 소통	• 안전/환경/**보안 영향**에 대한 예비평가가 가능한 수준의 설계 • 주요 구조물/계통/기기(SSC)의 예비 설계/배치/평가 결과	• 예비평가에 따른 분야별 세부 평가(결정론적/확률론적 안전성분석, 인간공학 분석, **보안성 분석** 등) • 모든 계통의 정의 및 주요 구조물/계통/기기(SSC)의 설계 요구사항 및 변수(안) 확정	• 안전/환경/**보안 영향에 대한 모든 분야별 평가 결과** 상세화 및 확정 • 모든 구조물/계통/기기(SSC)의 제조 요구사항 및 사양을 포함하는 (최종) 상세설계
	결과물	• 설계 원칙 • 설계 요구사항	• (예비) 건물도면, 계통 공정도면, 계장도면, 초기 3D 모델 등 • (예비) 안전/환경/**보안 관련 설계 요구사항**	• 계통 수준의 기술명세서 및 기능요건서 • 계통별 배관 및 기기 도면들 • 계통 및 기기 목록, 예비 3D 모델 • (예비) 안전성분석보고서, 환경영향, **보안성분석 보고서**	• (최종) 모든 SSC의 설계 사항, 최종 3D 모델 • (최종) 안전/환경/보안 영향 평가결과서 • (최종) 안전성분석보고서, 환경영향, **보안성분석 보고서**
규제자 (심사 범위)	표준 설계 인가	■	■	■	
	건설 허가	■	■	■	
	운영 허가	■	■	■	■

[표] 원자로 설계단계별 성숙도 및 규제자 심사 범위
(참조 : WNA, Design Maturity and Regulatory Expectations for SMRs(2021))

ㅇ인·허가 단계별 심사 범위

◆ 원자력시설 단계별 설계 일반

➢ 초기 요건/설계 단계에 반영되지 못하고 중간에 반영될 경우, 연계분야 설계수정이 힘든 구조



< 원전 일반 엔지니어링 프로세스 > (A/E 발표자료)

ㅇ인·허가 단계별 심사 범위

◆ 단계별 "정보시스템 보안규정" 검토 범위 및 주요내용(안)#1

- ➢ 시행규칙 제5조(별표) 및 고시(방호규정등 세부작성기준), RS-015에 따른 규정 항목 기준
- ➢ (SDA)식별/플랫폼 수준 -> (CP)시스템/계통 수준 -> (OL) 기기 수준의 보안평가 및 보안조치

세부항목	인·허가 단계			인·허가 단계별 검토 내용(예시)		
	표준설계인가	건설허가	운영허가	표준설계인가	건설허가	운영허가
1) 전자적 침해행위에 대한 원자력시설 컴퓨터 및 정보시스템 보안 대책에 관한 사항						
가) 원자력시설 컴퓨터 및 정보시스템 보안 계획	△	●	●	- **표준설계** 단계 사이버보안 규제요건 만족을 위한 수립된 **보안 계획**의 목적, 범위, 보안 전략 * 보안 원칙 및 방법, 프로세스 등 설계기반 사항	- **예비설계** 단계 사이버보안 규제요건 만족을 위한 수립된 **보안 계획**의 목적, 범위, 보안 전략	- **최종설계** 단계 사이버보안 규제요건 만족을 위한 수립된 **보안 계획**의 목적, 범위, 보안 전략 - **운영단계** 지속적 보안 이행 및 점검에 관한 **보안 계획**
나) 원자력시설 컴퓨터 및 정보시스템 보안 조직	△	●	●	- **표준설계** 단계 사이버보안 **계획 이행에 관한 조직** 구성, 임무 및 책임 * 표준설계 공정내 보안평가 및 보안설계 수행	- **예비설계** 단계 사이버보안 **계획 이행에 관한 조직** 구성, 임무 및 책임	- **최종설계** 단계 사이버보안 **계획 이행에 관한 조직** 구성, 임무 및 책임 - **운영단계** 지속적 **보안 이행 및 점검에 관한 조직** 구성, 임무 및 책임
다) 원자력시설 컴퓨터 및 정보시스템 분석	△	●	●	- 사이버보안 대상(필수계통, 필수 디지털자산)의 **식별 및 평가 방법** - **표준설계** 단계 **보안대상**(필수계통) 식별 및 평가 결과	- **예비설계** 단계 보안대상(필수계통, 필수디지털자산) **식별 및 평가 결과**	- **최종설계** 단계 보안대상(필수계통, 필수디지털자산) **식별 및 평가 결과** - 운영단계 보안대상 **관리(변경, 점검) 절차계획**
라) 단계별 보안 전략	△	●	●	- 보안대상 내 **보안등급 분류 및 방호구조**에 대한 **설계기준 및 방법** - **표준설계** 단계의 보안등급 분류, 네트워크 **방호구조 설계 결과** - **표준설계** 단계의 보안등급별 네트워크 **보안설비 기능/성능 사항**	- **예비설계** 단계의 보안등급 분류, 네트워크 **방호구조 설계 결과** - **예비설계** 단계의 보안등급별 네트워크 **보안설비 기능/성능 사항**	- **최종설계** 단계의 보안등급 분류, 네트워크 **방호구조 설계 결과** - **최종설계** 단계의 보안등급별 네트워크 **보안설비 기능/성능 사항** - 운영단계 지속적 방호구조 **관리(변경, 점검) 절차계획**

ㅇ인·허가 단계별 심사 범위

◆ 단계별 "정보시스템 보안규정" 검토 범위 및 주요내용(안)#2

- ➢ (SDA)식별/플랫폼 수준 -> (CP)시스템/계통 수준 -> (OL) 기기 수준의 보안평가 및 보안조치

마) 기술적·운영적·관리적 보안 조치	△	●	●	- 보안대상에 대한 사이버보안 **평가 방법 및 보안조치 방법** * 사이버 위협, 취약점, 영향 기반 - **표준설계** 단계의 보안대상*에 대한 **보안평가 결과 및 보안조치 이행결과** * 디지털플랫폼(PLC, DCS, FPGA 등)	- **예비설계** 단계의 보안대상*에 대한 **보안평가 결과 및 보안조치 이행결과** * 디지털플랫폼, 필수계통, 필수디지털자산	- **최종설계** 단계의 보안대상*에 대한 **보안평가 결과 및 보안조치 이행결과** * 디지털플랫폼, 필수계통, 필수디지털자산 - 운영단계 지속적 보안조치 **관리(변경, 점검) 절차계획**
바) 보안 조치의 감시 및 취약점 평가	—	△	●	N/A	- **예비설계** 단계 보안조치의 지속적인 감시와 평가, **취약점 관리 방법**	- **최종설계** 단계 및 운영단계 보안조치의 지속적인 감시와 평가, **취약점 관리 방법**
사) 그 밖에 원자력시설 컴퓨터 및 정보시스템의 보안에 관한 사항	—	—	●	N/A	N/A	- **운영단계** 사이버보안에 영향을 미치는 활동들의 **기록 및 비치, 로그(log) 관리 방법** * 시행규칙 별표2의 기록 및 비치 관련
2) 전자적 침해행위에 대한 원자력시설 컴퓨터 및 정보시스템의 보안에 관한 사항						
가) 전자적 침해행위 대응 조직 및 임무	—	△	●	N/A	- 전자적 침해행위 **대응에 관한 예비계획**	- 운영단계 전자적 침해행위 **대응에 관한 최종계획** * 조직, 임무 및 책임, 비상대응 절차, 유관기관 협조 체계 등
나) 전자적 침해행위 대응 시설 및 설비	△	●	●	- **표준설계** 단계 사이버보안 **모니터링(탐지, 경보, 로그)**에 관한 시설·설비의 종류, 목적, 기능 등	- **예비설계** 단계 사이버보안 **모니터링(탐지, 경보, 로그)**에 관한 시설·설비의 종류, 목적, 기능 등 * 예비 설계/배치, 설계 요구사항에 따른 예비 도면 및 분석보고서 등	- **최종설계** 단계 사이버보안 **모니터링(탐지, 경보, 로그)**에 관한 시설·설비의 종류, 목적, 기능 등 * 최종 설계/배치, 설계 요구사항에 따른 최종 도면 및 분석보고서 등 - 운영단계 사이버보안 모니터링 시설·설비의 **운영·관리 절차계획**
다) 전자적 침해행위 대응 교육 및 훈련	—	△	●	N/A	- **운영단계** 전자적 침해행위 대응 인력에 대한 **교육 및 훈련체계의 예비계획**	- **운영단계** 전자적 침해행위 대응 인력에 대한 **교육 및 훈련체계의 최종계획**

ㅇi-SMR 사이버보안 심사방향

◆ **수용 가능한 설계단계 이행안(예시) : 3가지 주요 input/output 문서**

- ➢ 규제요건/지침 만족을 위한 사이버보안 설계기준 문서(Design Criteria/Requirement.....)
- ➢ 사이버보안 분석 문서(Cybersecurity Analysis Report)
- ➢ 사이버보안 이행 문서(Cybersecurity Implementation Report)

① 시설 사이버보안 설계기준 문서(Design Criteria/Req.)

1.보안을 위한 조직활동/접근법

2.보안대상 분석 방법

3.보안등급 분류/구획화 방법

4.보안평가 및 보안조치 방법

-공격영향, 위협, 취약점을 고려한 보안평가 및 보안조치 전략

-(계통별) 생명주기(개발~운영)동안의 보안에 영향을 줄 수 있는 위협, 취약점을 분석한다.

-(계통별) 위협/취약점 평가결과와 요구되는 보안조치 사항들을 비교/검토하여, 보안요건들을 도출한다. 도출된 보안요건은 각 계통별 V&V에 포함하여 이행한다.

-요구되는 보안조치 사항 기술(RS-015내 보안조치 참조)

5.대응 시설 및 감시 방법

6.붙임 : 보안대상 분석결과, 보안방호구조(CSDA) 결과, 사이버보안 모니터링 시설/설비(기능/성능) 등

② Security Analysis Report 문서 (계통별)

-본 문서는 cybersecurity plan에 따라 필수시스템(계통) 개념단계부터 준비

-최악의 공격영향에 따른 보안등급 분류/구획화 분석

-생명주기(개발~운영)동안의 보안에 영향을 줄 수 있는 위협, 취약점 분석

-위협/취약점 평가결과와 요구되는 보안조치 사항들을 비교/검토하여, 보안요건들을 도출한다. 도출된 보안요건은 각 계통별 V&V에 포함하여 이행한다.

* 보안요건들 중 설계단계에 충분히 완화조치 되지 않는 것은 운영단계 보안정책/절차와 연계 및 해당근거 문서화

* 이행결과(security tasks report)는 계통의 단계별 V&V 보고서, 설계문서에 포함하여 발행가능(Section 수준)

③ Security Implementation Report 문서 (계통별)

-최종 Security Analysis Report별 이행 결과를 기술

-운영단계 보안정책/절차와 연계 기술

ㅇi-SMR 사이버보안 심사방향

◆ **설계단계 이행안 – 규제 검토범위 간 연계**

수용가능한 이행안

① 시설 사이버보안 설계기준 문서(Design Criteria/Req.)

1.보안을 위한 조직활동/접근법

2.보안대상 분석 방법

3.보안등급 분류/구획화 방법

4.보안평가 및 보안조치 방법

-공격영향, 위협, 취약점을 고려한 보안평가 및 보안조치 전략

-(계통별) 생명주기(개발~운영)동안의 보안에 영향을 줄 수 있는 위협, 취약점을 분석한다.

-(계통별) 위협/취약점 평가결과와 요구되는 보안조치 사항들을 비교/검토하여, 보안요건들을 도출한다. 도출된 보안요건은 각 계통별 V&V에 포함하여 이행한다.

-요구되는 보안조치 사항 기술(RS-015내 보안조치 참조)

5.대응 시설 및 감시 방법

6.붙임 : 보안대상 분석결과, 보안방호구조(CSDA) 결과, 사이버보안 모니터링 시설/설비(기능/성능) 등

② Security Analysis Report 문서 (계통별)

-본 문서는 cybersecurity plan에 따라 필수시스템(계통) 개념단계부터 준비

-최악의 공격영향에 따른 보안등급 분류/구획화 분석

-생명주기(개발~운영)동안의 보안에 영향을 줄 수 있는 위협, 취약점 분석

-위협/취약점 평가결과와 요구되는 보안조치 사항들을 비교/검토하여, 보안요건들을 도출한다. 도출된 보안요건은 각 계통별 V&V에 포함하여 이행한다.

* 보안요건들 중 설계단계에 충분히 완화조치 되지 않는 것은 운영단계 보안정책/절차와 연계 및 해당근거 문서화

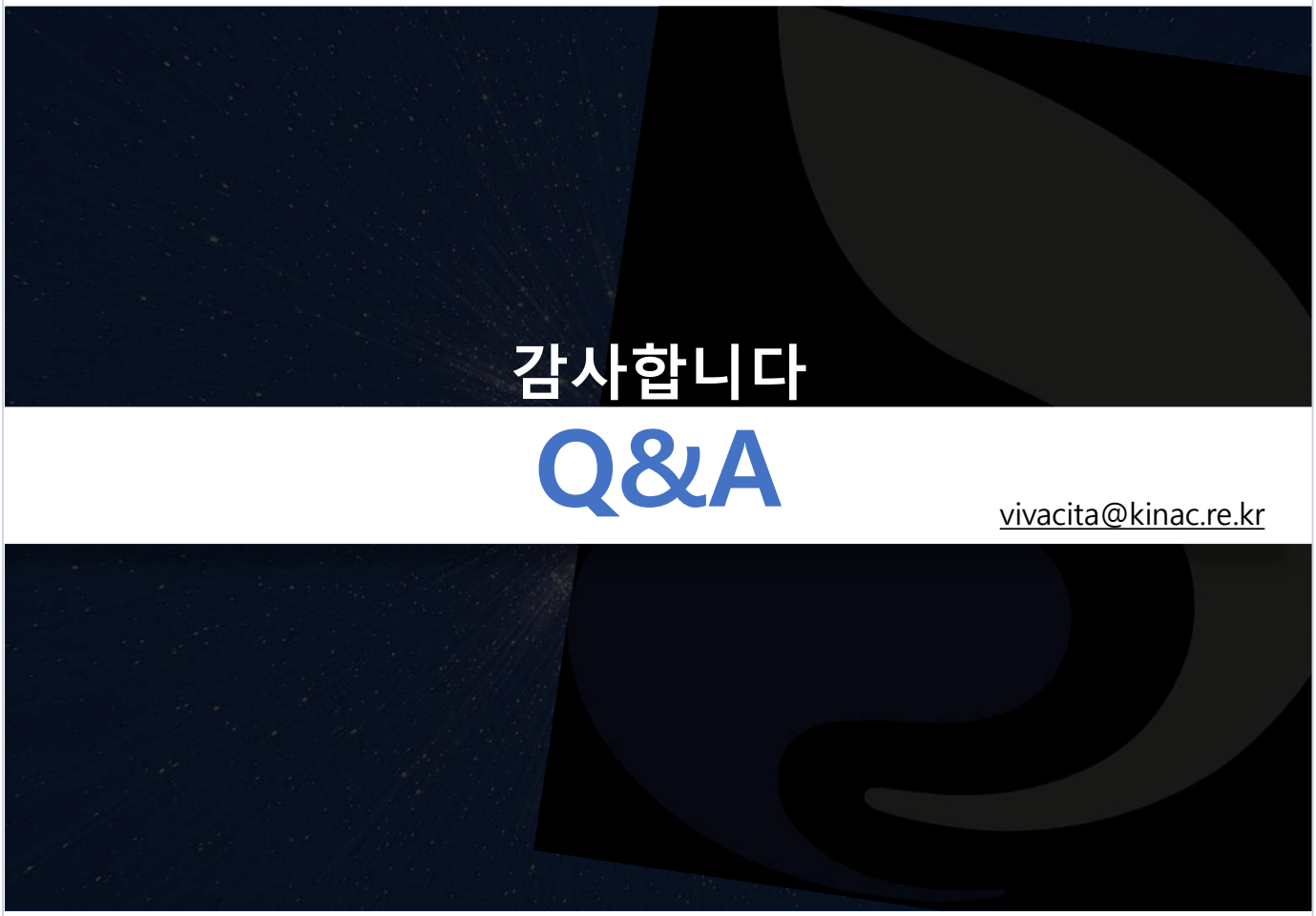
* 이행결과(security tasks report)는 계통의 단계별 V&V 보고서, 설계문서에 포함하여 발행가능(Section 수준)

③ Security Implementation Report 문서 (계통별)

-최종 Security Analysis Report별 이행 결과를 기술

-운영단계 보안정책/절차와 연계 기술

세부항목	인허가 단계			인허가 단계별 검토 내용(예시)		
	표준설계인가	건설허가	운영허가	표준설계인가	건설허가	운영허가
1) 전자적 침해행위에 대한 원자력시설 컴퓨터 및 정보시스템 보안 대책에 관한 사항						
가) 원자력시설 컴퓨터 및 정보시스템 보안 계획	△	●	●	- 표준설계 단계 사이버보안 규제요건 만족을 위한 수립된 보안 계획의 목적, 범위, 보안 전략 * 보안 원칙 및 방법, 프로세스 등 관련 문서로 기술	- 예비설계 단계 사이버보안 규제요건 만족을 위한 수립된 보안 계획의 목적, 범위, 보안 전략	- 최종설계 단계 사이버보안 규제요건 만족을 위한 수립된 보안 계획의 목적, 범위, 보안 전략 - 운영단계 지속적 보안 이행 및 점검에 관한 보안 계획
나) 원자력시설 컴퓨터 및 정보시스템 보안 조직	△	●	●	- 표준설계 단계 사이버보안 계획 이행에 관한 조직 구성, 임무 및 책임 * 표준설계 승정내 보안평가 및 보안설계 수행	- 예비설계 단계 사이버보안 계획 이행에 관한 조직 구성, 임무 및 책임	- 최종설계 단계 사이버보안 계획 이행에 관한 조직 구성, 임무 및 책임 - 운영단계 지속적 보안 이행 및 점검에 관한 조직 구성, 임무 및 책임
다) 원자력시설 컴퓨터 및 정보시스템 분석	△	●	●	- 사이버보안 대상(필수계통, 필수 디지털자산)의 식별 및 평가 방법 - 표준설계 단계 보안대상(필수계통) 식별 및 평가 결과	- 예비설계 단계 보안대상(필수계통, 필수디지털자산) 식별 및 평가 결과	- 최종설계 단계 보안대상(필수계통, 필수디지털자산) 식별 및 평가 결과 - 운영단계 보안대상 관리(변경, 점검) 절차계획
라) 단계별 보안 전략	△	●	●	- 보안대상 내 보안등급 분류 및 방호구조에 대한 설계기준 및 방법 - 표준설계 단계의 보안등급 분류, 네트워크 방호구조 설계 결과 - 표준설계 단계의 보안등급별 네트워크 보안설비 기능/성능 사항	예비설계 단계의 보안등급 분류, 네트워크 방호구조 설계 결과 예비설계 단계의 보안등급별 네트워크 보안설비 기능/성능 사항	- 최종설계 단계의 보안등급 분류, 네트워크 방호구조 설계 결과 - 최종설계 단계의 보안등급별 네트워크 보안설비 기능/성능 사항 - 운영단계 지속적 방호구조 관리(변경, 점검) 절차계획
마) 기술적·운영적·관리적 보안 조치	△	●	●	- 보안대상에 대한 사이버보안 평가 방법 및 보안조치 방법 * 사이버 위협, 취약점, 영향 기반 - 표준설계 단계의 보안대상에 대한 보안평가 결과 및 보안조치 이행결과 * 디지털플랫폼, 필수계통, 필수디지털자산 등	예비설계 단계의 보안대상에 대한 보안평가 결과 및 보안조치 이행결과 * 디지털플랫폼, 필수계통, 필수디지털자산 등	- 최종설계 단계의 보안대상에 대한 보안평가 결과 및 보안조치 이행결과 * 디지털플랫폼, 필수계통, 필수디지털자산 등 - 운영단계 지속적 보안조치 관리(변경, 점검) 절차계획
바) 보안 조치의 감시 및 취약점 평가	–	△	●	N/A	- 예비설계 단계 보안조치의 지속적인 감시와 평가, 취약점 관리 방법	- 최종설계 단계 및 운영단계 보안조치의 지속적인 감시와 평가, 취약점 관리 방법
사) 그 밖에 원자력시설 컴퓨터 및 정보시스템의 보안에 관한 사항	–	–	●	N/A	N/A	- 운영단계 사이버보안에 영향을 미치는 활동들의 기록 및 비치, 로그(log) 관리 방법 * 사용내역 열람의 기록 및 비치 관련
2) 전자적 침해행위에 대한 원자력시설 컴퓨터 및 정보시스템의 보안에 관한 사항						
가) 전자적 침해행위 대응 조직 및 임무	–	△	●	N/A	- 전자적 침해행위 대응에 관한 예비계획	- 운영단계 전자적 침해행위 대응에 관한 최종계획 * 조직, 임무 및 책임, 비상대응 절차, 유관기관 협조 체계 등
나) 전자적 침해행위 대응 시설 및 설비	△	●	●	- 표준설계 단계 사이버보안 모니터링(탐지, 경보, 로그)에 관한 시설 설비의 종류, 목적, 기능 등	- 예비설계 단계 사이버보안 모니터링(탐지, 경보, 로그)에 관한 시설 설비의 종류, 목적, 기능 등 * 최종 설계에서, 설계 요구사항에 따른 상세 도면 및 분석보고서 등	- 최종설계 단계 사이버보안 모니터링(탐지, 경보, 로그)에 관한 시설 설비의 종류, 목적, 기능 등 * 최종 설계에서, 설계 요구사항에 따른 상세 도면 및 분석보고서 등 - 운영단계 사이버보안 모니터링 시설 설비의 운영·관리 절차계획
다) 전자적 침해행위 대응 교육 및 훈련	–	△	●	N/A	- 운영단계 전자적 침해행위 대응 인력에 대한 교육 및 훈련체계의 예비계획	- 운영단계 전자적 침해행위 대응 인력에 대한 교육 및 훈련체계의 최종계획



vivacita@kinac.re.kr

03

PRESENTATION

14:55–15:20

2026. 10. 28.(수)

2026 한국원자력학회 추계학술발표회 · 원자력 사이버보안 워크숍

원자력시설 사이버보안 규제 변화, 이행 현황과 과제 — 디지털 I&C 시대, 대형원전에서 SMR·AR까지

국가 원자력시설 대상 생애주기별 보안내재화 지침 및 해설서 소개

정만현

국가보안기술연구소 (NSR)

국가보안기술연구소

국가 원자력시설 생애주기별 보안내재화 지침 및 해설서 소개

2026.10.28.

정만현

CONTENTS

| 01 보안 내재화의 필요성과 개념

| 02 지침과 해설서의 구성과 이해

| 03 지침과 해설서의 활용

01

보안 내재화의 필요성과 개념

NSR

변하고 있는 원자력의 위상

NSR

원자력발전의 위상 확대

최근 공식자료로 보는 위상 상승

40개국+
원자력 확대 지지 정책 · 입장
IEA, New Era for Nuclear Energy

420 GW
2025년 말 세계 원전 설비
IEA, Global Energy Review 2026

78 GW / 15개국
현재 건설 중인 원전 규모
최근 30년 중 높은 수준

Sources : IEA, The Path to a New Era for Nuclear Energy; IEA, Global Energy Review 2026

국가 전략 인프라로 위상 변화

1 **에너지안보**
24시간 공급 가능한
대규모 전원

2 **AI · 첨단산업**
데이터센터 · 반도체 등
전력수요 증가 대응

3 **탄소중립**
저탄소 전원으로
전원믹스 보완

4 **국가 전략산업**
원전 수출 · 공급망 ·
국제협력 의제로 확대

발표 핵심

원자력시설 보호는 발전소 보안을 넘어 **국가 전략 인프라의 신뢰성 확보** 문제입니다.

4 / 27

보안내재화가 필요한 이유

NSR

위상 상승이 보안내재화 필요성으로 이어지는 이유

01 전략 인프라화
에너지안보 · 수출 · 첨단산업 기반

02 디지털 의존도 증가
계측제어 · 운영지원 · 공급망 연결성 확대

03 공격면 확대
원격접속 · SW 공급망 · 유지보수 경로

04 사후 대응 한계
운영 후 패치 중심 보안은 추적성 · 입증성 취약

05 보안내재화 필요
요구사항 – 설계 – 구현 – 시험 단계에서 보안 반영

IEA Energy & AI 기사 — 데이터센터 전력소비 +17% (2025년)

New IEA report explores AI's growing energy footprint, options for meeting data centre power demand, and impacts on energy affordability, security and wider economy

A new report from the IEA assesses how the relationship between energy and artificial intelligence (AI) is evolving rapidly, drawing on the latest data and analysis and close tracking of technological and economic developments in the AI sector.

Building on the IEA's landmark *Energy and AI* report from April 2025, the new analysis published today finds that the field has continued to develop at speed. Driven by data centre investments, the capital expenditure of five large technology companies surged to more than $400 billion in 2025 and is set to increase by a further 75% in 2026. Electricity demand from data centres soared by 17% in 2025, and that of AI-focused data centres climbed even faster – well outpacing growth in global electricity demand of 3%.

국내 원전 수출체계 기사 — 민관합동 원전수출기획위원회

산업통상부 | 지역에는 선장을, 기업에는 활력을 | 보도자료

보도시점 2026. 5. 14.(목) 14:00 < 5.15.(금) 조간 > 배포 2026. 5. 14.(목)

글로벌 원전 르네상스 선점을 위한 'K-원전 원팀 체제 정비'

- 산업부, 원전수출전략협의회 통해 「원전 수출체계 효율화 방안」 발표
  · 즉시 △정부가 주도적으로 상대국과 교섭·협의 추진, △민관합동 원전 수출기획위원회 신설, △한전·한수원 등 국내 역량과 강점 결집
  · 연내 (가칭)'원전수출진흥법' 제정 추진
- 한전·한수원 사장, ①원전수출 협업 강화 이행을 위한 협약 체결, ②UAE 원전사업 정산 분쟁의 원만한 해결을 위한 중재지 변경(영국→한국) 합의

한 문장 원자력시설의 역할이 국가 전략 인프라로 확대될수록, **사이버보안**은 운영 이후의 점검 항목이 아니라 **설계 · 개발 단계부터 내재화되어야 하는 필수 품질속성**이 됩니다.

통합 위협 환경

NSR

복합 공격 시나리오 가능성 증가

사이버 위협
제어 · 감시 · 운영망 대상
원격 유지보수 · 연계망 침투

물리적 위협
테러 · 침투 · 불법 촬영
반출 및 내부자 협조

공급망 · 내부자
장비 · SW 납품 위 · 변조
계정 탈취 · 권한 오남용

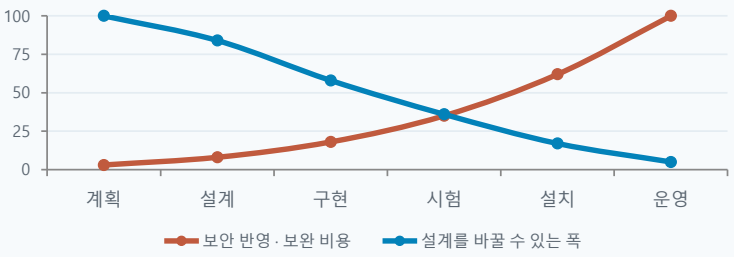
원자력시설 보호 경계

원자력시설 · 제어 / 감시 / 운영 시스템

경로는 셋, 표적은 하나
개별 대응이 아니라 **설계 단계부터 통합적으로 고려**해야 하는 이유

보안 반영 시점과 선택지

보안을 반영하는 시점에 따른 변화



※ 상대 수준 개념 도식 (실측 데이터 아님)

원전에서 특히 어려운 이유

가동 중 정지 부담
운영 중 변경은 출력 감소 · 정지를 수반

안전 관련 변경의 절차
인허가 · 재검증을 거쳐야 반영 가능

형상관리 대상 변경
문서 · 설계 · 시험 기록까지 함께 갱신

→ 늦게 반영할수록 선택지가 줄어듭니다

기존 접근

- 구축이 끝난 뒤 보안 점검 수행
- 취약점 발견 후 보완
- 보안부서 중심의 사후 확인
- 문제 발생 후 대응

보안내재화 접근

- 계획 단계부터 보안을 설계에 반영
- 취약점 발생 가능성 사전 감소
- 전 생애주기에 관련 조직 참여
- 사전 예방 + 운영 중 지속 관리

정리 보안내재화는 선택지가 남아 있을 때 결정하도록 만드는 접근입니다.

보안내재화의 필요성과 효과

사후 대응에서 사전 예방으로: 보안내재화의 효과

왜 필요한가 · CISA / NIST 메시지

- 반복되는 취약점은 사후 패치만으로 줄이기 어려움
- Secure by Design은 취약점의 근본 원인과 취약점 군을 줄이는 접근
- DevSecOps · Shift Left는 보안을 개발 초기와 운영에 통합

→ 개별 취약점 대응에서, 취약점이 생기는 구조 자체로 초점 이동

CISA, CISA Vulnerability Review FY 2024/2025, 2026.
NIST NCCoE, Secure Software Development, Security, and Operations (DevSecOps) Practices, March 2026.

실제 효과 · Google Android 사례

20% 미만	메모리 안전 취약점 비중 (2025년)
1,000배 +	Rust 메모리 안전 취약점 밀도 개선
4배 낮음	Rust 변경사항 rollback rate
25% 감소	code review 시간

Google Security Blog, Rust in Android: move fast and fix things, 2025.

메시지 보안내재화는 취약점을 더 빨리 고치는 접근이 아니라, 취약점이 만들어지는 구조 자체를 줄이는 접근입니다.

보안내재화 지침의 필요성

보안내재화를 조직 차원에서 수행하기 위한 방안

보안내재화를 어느 단계에서 무엇을 고려할지, 누가 책임을 가질지에 대한 공통된 틀이 없으면 개념만으로 업무에 적용되지 않습니다.

1 **개념**
처음부터 보안을 고려

→

2 **공통 기준**
무엇을 언제 고려하고 수행해야 하는가

→

3 **보안내재화 지침**
기관 담당자에게 공통된 방향과 기준 제시

지침의 역할

담당자 개인의 경험과 판단에 의존하던 것을, 조직의 공통 기준으로 옮깁니다.

보안내재화 지침 ·해설서 제정 경과

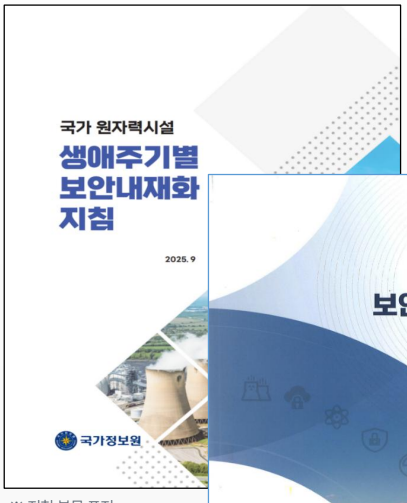
지침과 해설서가 만들어진 과정

1 **2024. 12**
「국가 원자력시설 생애주기별 보안내재화 지침」 최초 발표

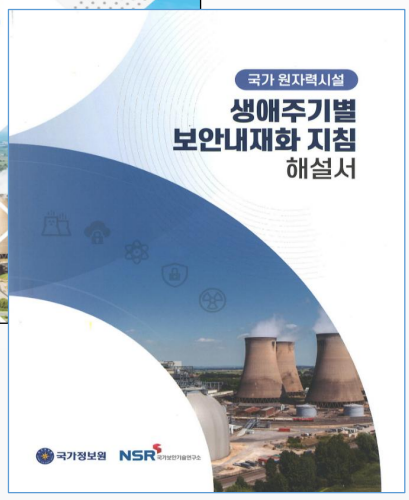
2 **2025. 09**
물리적 방호 요구사항을 포함한 통합 개정

3 **2025. 12**
「 원전 사이버보안 협의회 」에서 해설서 소개

4 **2026. 04**
「국가 원자력시설 생애주기별 보안내재화 지침 해설서」 발간



※ 지침 본문 표지



※ 해설서 본문 표지

02

지침과 해설서의 구성과 이해

NSR

지침과 해설서의 역할

NSR

지침과 해설서의 차이점

구분	지침	해설서
역할	무엇을 해야 하는가?	왜 필요한가, 어떻게 이해할 것인가?
구성	항 · 조 · 호 중심의 조문	조항별 해설과 Tips 중심
내용	기본 기준과 요구사항 제시	의미 · 취지 · 고려사항 설명
성격	적용해야 할 사항	이해와 적용을 돕는 참고사항

한 줄 정리

지침 = 기준. 해설서 = 그 기준을 정확하게 이해하기 위한 설명.

해설서의 역할

해설서 역할에 대한 정확한 이해

해설서가 하는 것

- 조항의 취지를 설명
- 의미와 고려사항 보완
- 용어와 개념의 이해 지원
- 적용 시 참고 가능한 Tip 제공

해설서가 하지 않는 것

- 새로운 의무나 요건 추가
- 모든 상황의 세부 절차 규정
- 특정 이행방법 하나만 강제
- 지침 대체

성격 — 해설서는 "How-to 매뉴얼"보다 "Understanding Guide"에 가까운 문서입니다.

해설서의 기본 읽는 방법

지침 조항을 읽을 때 생기는 질문

- 이 조항은 왜 필요한가?
- 이 표현은 무엇을 의미하는가?
- 다른 조항과 어떻게 연결되는가?
- 실제 적용에서 무엇을 고려할까?

해설서는 무엇을 더 설명하는가?

해설 — 왜 · 무엇 중심

- 조항의 의미와 요구 취지
- 개념과 적용 범위 설명
- 요구사항 자체를 이해하는 데 초점

Tips — 참고할 수 있는 방법 중심

적용 시 참고사항과 예시

- 실무적으로 고려할 수 있는 사항
- 이행방법을 찾는 데 활용하는 정보

주의 — Tips은 추가 의무사항이 아니라, 이해와 적용을 돕기 위한 참고 정보입니다.

해설서의 기본 활용 구조

조항을 읽는 방법

1	2	3	4
지침 조항	**해설(목적과 설명)**	**Tips(실행 고려사항), 참고(지침 및 표준)**	**실제 업무 적용**
무엇을 요구하는가?	왜 필요한가? 무슨 의미인가?	적용 시 무엇을 참고할 수 있는가?	기관 · 시설 · 사업 특성에 맞게 적용

해설서를 활용하기 위해서는 '조항 -> 의미-> 참고사항-> 적용' 순으로 조항을 읽으면 됩니다.

해설서의 의미

해설서는 지침 조항과 실제 업무 사이에 이해의 다리를 놓는 문서입니다.

해설서의 구조 예시 – 실제 조항 한 개(서식)

제2장 **보안내재화 주요 원칙**

제6조(생애주기) ① **사이버보안 관점에서 원자력시설 생애주기는 다음과 같이 계획, 개발계획, 설계, 구현, 시험, 설치, 운영, 해체 등의 8단계로 구분한다.**

1. 계획 : 정보화 사업 보안에 근거한 사업 시행 계획 수립
2. 개발계획 : 시스템 개발 계획을 위해 통합 설계팀 구성하고 원자력시설 전 생애주기 보안내재화 보안 목표 및 전략 수립
3. 설계 : 위협 시나리오 기반의 위험 평가를 통한 보안 요구사항 식별 및 적용
4. 구현 : 안전한 하드웨어 및 소프트웨어 개발을 위한 개발환경 보안, 안전한 코딩 및 단위 시험, 취약점 분석, 공급망 보안 수행
5. 시험 : 통합 시험 및 검증을 위한 절차와 기준 수립, 모의 침투시험, 소프트웨어 확인 및 검증(V&V), 보안 기능 확인
6. 설치 : 안전한 설치 및 배포 절차 수립·이행, 시스템 설치 적합성 확인(or/and 시스템 사이버보안 영향성 평가·조치)
7. 운영 : 시스템 운영 및 보안관리를 위한 자산 관리, 형상 관리, 보안 모니터링, 자산 공급망 관리, 침해대응 및 복구, 백업 수행
8. 해체 : 시스템의 데이터 안전한 폐기와 보존 자산의 안전한 관리 수행

해설 목적 및 설명 — **조항의 배경 · 취지 · 적용 범위**

- 원자력시설 컴퓨터 및 정보시스템은 다양한 사이버 위협에 대응하고 보안 요구사항을 일관되고 체계적으로 적용하기 위해 계획부터 해체까지 생애주기 각 단계에 적합한 보안조치를 적용하여 보안성을 지속적으로 유지하여야 한다.
- 국제 기준에서 제시하는 사이버보안 위험관리 방식도 지침과 동일하게 생애주기 관점을 사용한다.

Tips 실행 고려사항 — **조직 · 절차 · 시스템 · 문서 측면**

- 지침의 원자력시설 생애주기는 일반적인 원자력시설 건설 생애주기와는 상이한 부분이 있다. 다만 큰 틀에서는 다음 예시와 같이 대응시킬 수 있다.

원자력시설 건설 생애주기	사이버보안 관점 원자력시설 생애주기
계획, 입지	계획
설계	개발계획, 설계
건설	구현, 시험, 설치(일부)
시운전	설치(일부)
운전, 운전정지	운영
해체	해체

참고 지침 및 표준 — **관련 법령 · 국제 규범**

1. IAEA NSS No. 17-T, Rev. 1, Computer Security at Nuclear Facilities, 2021
   관련 항목 Section 6. Facility and System Computer Security Risk Management Considerations during Specific Stages in the Lifetime of a Facility
2. IEC 62645:2019, Nuclear power plants – Instrumentation and control systems – Requirements for security programmes for computer-based systems
   관련 항목 Clause 6. Life-cycle implementation for I&C programmable digital system security
3. IEC 62859:2016, Nuclear power plants – Instrumentation and control systems – Requirements for coordinating safety and cybersecurity
   관련 항목 Clause 6.3. Safety and cybersecurity coordination during the I&C system lifecycle
4. 국가 정보보안 기본지침(2020, 국가정보원)
   관련 항목 제2장 정보화사업 보안

지침 및 해설서의 전체 구성

지침과 해설서의 전체 구조

제1장
총칙
목적 · 적용범위 · 역할과 책임 등 기본 틀
적용 경계와 책임

제2장
보안내재화 주요 원칙
전 생애주기에 적용되는 공통 원칙
항상 적용되는 관점

제3장
생애주기별 보안내재화
계획부터 해체까지 단계별 고려 · 수행사항
단계별 적용과 연결

제4장
보안내재화 관리
운영을 포함해 지속적으로 관리해야 할 사항
변화에 대응하는 관리

읽는 흐름
기본 틀 → 공통 원칙 → 단계별 적용 → 지속적 관리

제1장 총칙의 주요 내용

보안내재화의 기본 틀

WHY
왜 수행하는가?
- 지침의 목적
- 보안내재화의 기본 방향

WHERE
어디까지 적용하는가?
- 적용 대상
- 적용 범위
- 생애주기 범위

WHO
누가 책임지는가?
- 기관의 책무
- 책임자
- 담당 조직과 역할

적용 범위와 책임이 정해지지 않으면 기술적 조치를 논의해도 실제 이행으로 이어지기 어렵습니다.

총칙의 의미
총칙은 단순한 서문이 아니라,
이후 모든 보안내재화 활동의 적용 경계와 책임 구조를 정하는 부분입니다.

제2장 보안내재화 주요 원칙

NSR

무엇을 항상 고려해야 하는가?

1 거버넌스 · 위험관리
정책 / 절차 / 위험관리

2 보호 아키텍처 · 기술
심층방호 / 분리 / 접근통제

3 운영 · 모니터링
감시 / 로그 / 위기 · 연속성

4 조직 · 사람
역할 / 교육 · 훈련 / 인적 보안

5 공급망 · 규제
외부 공급자 / 규제 / 표준

읽는 법

특정 단계의 체크리스트가 아니라 **전 단계에 적용되는 공통 관점**입니다.
개별 원칙을 외우기보다 다섯 영역으로 먼저 묶어 이해하십시오.

제3장 : 생애주기별 보안내재화

NSR

보안을 생애주기와 연결

1 계획
보안 목표와 방향 설정

2 개발계획
보안 전략 · 역할 정의

3 설계
보안 요구사항 구체화

4 구현
보안기능 ·조치 반영

5 시험
구현 여부 확인

6 설치
안전한 배포와 이관

7 운영
유지 · 모니터링· 개선

8 해체
정보 · 자산의 안전한 종료

※ 단계 구분은 지침 제3장의 구성을 따릅니다. 사업 유형에 따라 일부 단계는 통합되거나 반복될 수 있습니다.

관점

보안 활동은 한 번 수행하고 끝나는 이벤트가 아니라, **생애주기를 따라 이어지는 과정**입니다

생애주기 단계 간 연결성

NSR

단계별 활동보다 더 중요한 것은 연결

01	02	03	04	05
계획	설계	구현	시험	운영
보안 목표 · 방향	보안 요구사항	보안기능 · 조치	구현 여부 확인	유지 · 개선

계획에서 정한 목표가 설계 요구사항이 되고, 설계 요구사항이 구현과 시험의 기준이 되는것 처럼
앞 단계의 결정이 다음 단계의 입력이 됩니다.

핵심 내용

이 지침은 단계별 체크리스트가 아니라, 보안 활동의 연속된 흐름으로 이해하는 것이 중요합니다.

제4장 보안내재화 관리

NSR

구축 이후에도 보안은 계속됨

지속 관리 순환

자산 파악	형상 · 변경관리	모니터링
취약점 · 위협 대응	평가 · 개선	자산 · 상태 갱신

한 바퀴 돌고 끝나는 절차가 아니라,
상태가 바뀔 때마다 다시 도는 구조입니다.

다시 돌게 만드는 변화

- 공급망 변화
- 외부 위협 변화
- 시스템 변경
- 규제 · 정책 변화

4장의 관점

'한 번 구축하고 끝나는 보안'이 아니라,
변화하는 상태를 계속 관리하는 구조로 이해하는 것이 적절합니다.

03

지침 및 해설서의 활용

NSR

담당 업무별 활용 방안

NSR

담당 업무에 따라 다른 활용 지점

1 정책 · 제도 담당

- 지침의 취지와 목적
- 적용 대상과 범위
- 제도적 이해 관점

2 사업 기획 · 관리 담당

- 사업 초기 보안 요구사항
- 사업 단계별 고려사항
- 일정 · 예산 반영 시점

3 설계 · 개발 담당

- 설계 · 구현 요구사항의 의미
- 보안 요구 반영 관점
- 시험 단계 확인사항

4 운영 · 보안 담당

- 지속 관리 대상
- 모니터링 항목
- 개선 · 대응 관점

활용 원칙

같은 문서지만 담당 업무에 따라 보는 지점이 다릅니다.
생애주기에 참여하는 여러 담당자가 필요한 부분을 찾아보는 문서입니다.

24 / 27

지침 및 해설서 활용 절차

처음부터 끝까지 읽기보다, 이렇게 활용하십시오

1	전체 구조 확인	총칙 → 주요 원칙 → 생애주기 → 관리 순으로 문서의 뼈대를 먼저 봅니다
2	담당 업무의 생애주기 단계 확인	내 업무가 계획 · 설계 · 구현 · 시험 · 운영 중 어디인지 특정합니다
3	관련 지침 조항 확인	해당 단계에 걸리는 조항만 찾아 읽습니다
4	해설과 Tip으로 의미 보완	조항의 취지와 적용 시 고려사항을 확인합니다
5	기관 · 시설 · 사업 특성에 맞게 적용	같은 조항도 시설 특성과 사업 규모에 따라 다르게 적용됩니다

요약

필요한 조항을 찾아 들어가는 방식이 해설서를 가장 효과적으로 쓰는 방법입니다.

지침과 해설서의 핵심 메시지

오늘 기억해 주실 세 가지

01

생애주기 전 단계

보안내재화는 특정 보안기술이 아니라, 생애주기 전 단계에 보안을 반영하는 접근입니다.

02

기준과 설명

지침은 기준을 제시하고, 해설서는 그 기준을 정확하게 이해하도록 돕습니다.

03

연결고리

해설과 Tip은 새로운 요구사항이 아니라, 지침과 실제 업무를 잇는 연결고리입니다.

보안내재화의 관점

결국 바뀌는 것은 보안을 보는 시점입니다 —

구축 이후에 추가하는 활동에서, 처음부터 포함하는 활동으로.

국가보안기술연구소
감사합니다

04

PRESENTATION

15:20–15:45

2026. 10. 28.(수)

2026 한국원자력학회 추계학술발표회 · 원자력 사이버보안 워크숍

원자력시설 사이버보안 규제 변화, 이행 현황과 과제 — 디지털 I&C 시대, 대형원전에서 SMR·AR까지

원전 사이버보안 심층방호: 기술기준 분석 및 적용 방안

이정권

한국전력기술 (KEPCO E&C)

KNS 2026 추계학술대회 사이버보안 워크숍

원전 사이버보안 심층방호: 기술기준 분석 및 적용 방안

2026. 10. 28(수)

한국전력기술㈜ SD
계측제어설계실 이정권

원전 사이버보안 심층방호: 기술기준 분석 및 적용 방안

발표 순서

1. 개요
   - 기술기준 DiD 요건 Mapping
   - 핵심 용어 비교
   - Safety vs Cyber DiD
2. NRC RG
   - RG 5.71 DiD 개요
   - DG-5103 3-Tier · DCSA
3. IAEA
   - 17-T DCSA
   - Boundary · Data Flow 통제
   - Blended Attack DiD 설계
4. IEC
   - 62645 Security Degree (SD)
   - Security Zone
5. 적용 방안
   - Graded Approach
   - MCR Sub-zone
   - Alternative Control
   - Independence · Diversity
6. 결론
   - DiD 적용 시사점

2

1. 개요 : 기술기준·표준·규제지침 DiD 요건 Mapping

newpower, newstandard KEPCO E&C

문서 (발행)	성격 · 대상	DiD 관련 핵심 조항 (해당 Paragraph 병기)	특징 (해당 Paragraph 병기)
NRC RG 5.71 R1 (2023.02)	규제지침 **CSP for NPPs**	§C.3.2 DiD Protective Strategy (Architecture + Strategy) §C.3.2.1 Defensive Architecture · Figure 6 §C.3.3 Security Controls / App. B · C / 10 CFR 73.54(c)	▪ **Level 4(최고)~0(최저) 동심 5단**, –L4→L3 · L3→L2 One-way, Deny-all · Permit-by-Exception 명문화 ▪ **Data Diode 단독 시 우회 경로**(Supply Chain · PMMD · Wireless · 물리접근) **차단 불가** → 다중 Layer
KINAC/RS-015 R2 (2023.12)	심 · 검사 기준 **원자력시설 컴퓨터·정보시스템 보안**	§2.2.5 심층방호 보호전략 (방호구조 + 방어전략 2요소) §2.2.5.1 일반사항 ~ §2.2.5.2 사이버보안 방호구조 §2.2.5.2.5 동일 Level 내 구획화 (신설) / §2.2.6 보안조치 (기술·운영·관리)	▪ **RG 5.71 체계 준용** ▪ R2에서 "심층방호 전략" → "심층방호 보호전략"으로 용어 정정 ▪ 동일 Level 내 중요도 고려 구획화 신설 (§2.2.5.2.5)
DG-5103 (RG 5.96 R1 Draft, 2026.06)	규제지침 **Establishing RI & TI CSP for Commercial NPs**	§C.65~C.105 3-Tier Analysis (Facility→Function→System) §C.112~C.119 Level화 · Computer Security Zone §C.156 DCSA 3원칙 / 10 CFR 73.110	▪ 고정 Level 대신 "**분석이 Architecture 결정**"으로 전환 ▪ Critical 등급화 · Zone 배정 → Most/Least/Noncritical 3구분(선택) ▪ DCSA 3원칙 제시, Zone당 System 수 제한 → Common-Cause Access 축소
IAEA NSS 17-T R1 (2021.09)	기술지침 **CS Techniques for NFs**	§4.74~4.82 DCSA DiD 요구 (Layer 간 · 내) §4.83 Trust Model · §2.22~2.26 Zone · §5.17~5.20 §8.2~8.21 구현 및 Level별 요구	▪ DiD를 DCSA Specification 요구사항으로 제시 ▪ **Level 1~5 요구**(§8.16~8.21)·**Zone 구축 11항목**(§5.18 a~k) - **설·심사 기준표**
IAEA NSS 33-T (2018)	기술지침 **CS of I&C Systems at NFs**	§4.141~4.151 Compromise 대응 DiD §2.28~2.30 Security Zone / §4.152~4.155 요건 명세	▪ **DiD 정의**(§4.142) · **Single Failure 불허**(§4.143) - **I&C Lifecycle 관점 기술** ▪ 인적 · 기술 조치 균형 분석 · 정당화 요구 (§4.145~4.146)
IAEA NSS 42-G (2021)	이행지침 **CS for Nuclear Security**	§2.41~2.45 DiD 정의 · Single Failure · Concentric Rings §7.24 CSP 내 DiD 적용 방법	▪ **CSP 수준 DiD 기술 방법 제시** (§7.24) –Diverse · Independent Measure + SoD ▪ Concentric Rings 구조, 인접 Zone 간만 직접 연결 (§2.44)
IAEA NR-T-3.30 (2020)	Nuclear Energy Series **CS Aspects of Design for I&C Systems at NPPs**	§2.6 DCSA · §2.6.1 Computer Security DiD §2.6.2 Computer Security Zone	▪ **Safety DiD · Security DiD 명시 구분** (33-T 구분 인용 · 확장) ▪ Security Measure의 Credited Safety Function 저해 금지 강조 ▪ 상이 Vendor도 공통 Third-party SW로 CCF 발생 가능 경고
IEC 62645 Ed.2 (2019.11)	국제표준 **NPP I&C · EPS Cybersecurity**	§5.4.3.1 Classification Scheme (S1~S3) §5.4.3.2 Baseline 20개 + SD별 추가 요구 · 통신 방향 §5.4.3.3 Zone · Decoupling / §6.4.4.3 Wireless 금지 / Annex B.1	▪ **Consequence 기반 3등급(S1~S3) · IEC 61226 Category 연계** –1:1 대응 아님, 상향 Rule 명시 –SD별 Baseline · 추가 요구 조문화 ▪ IEC 62859(Safety · Security 조율) ▪ IEC 63096(Control Catalogue)과 연계 운용

3

1. 개요 : 핵심 용어 비교

newpower, newstandard KEPCO E&C

개념 기준서 →	• 10 CFR 73.54 • RG 5.71 Rev.1 - NEI 08-09 Rev.7 - NEI 10-04 Rev.3 - NEI 13-10 Rev.7 • KINAC/RS-015 Rev.2	• 10 CFR 73.110 • DG-5103 (RG 5.96 Rev.1 Draft)	• NSS 17-T Rev.1 • IAEA NSS 42-G • NSS 33-T • NR-T-3.30 • NSS 13 • NSS 20	• IEC 62645 Ed.2 • IEC 63096 Ed.1 • IEC 62859 + AMD1 • IEC 61226	IACS 일반 표준 (원전용 아님) • IEC 62443 Series • IEC 62443-3-2 • IEC 62443-3-3 • IEC 62443-4-2
보호대상 자산 보호 대상으로 식별하는 디지털 자산 단위	**CDA** (Critical Digital Asset) ▪ **SSEP Function** 수행·지원 자산, ▪ CS 단위 식별 (RG 5.71 §C.3.1)	**Critical System** ▪ **73.110(a) Consequence** 유발 가능 계통 (DG-5103 §C.112–C.113)	**SDA** (Sensitive Digital Asset) ▪ **중요 Facility Function** 수행·지원	**I&C PDS** (Programmable Digital System) ▪ **Security Degree(SD) 할당 단위**	**IACS Asset · Component** ▪ 제어시스템 장치·SW, **Component 요건은 4-2**
보호 강도 등급 자산·구역에 요구되는 보호 수준	**Level 0~4 (Level 4 최고)** ▪ **안전·보안 기능 CDA = 4등급**	**Most / Least / Noncritical** ▪ **Most Critical = 전체 Control 평가** (DG-5103 §C.112)	**Level 1~5 (Level 1 최고)** ▪ Computer Security Level별 Requirement 차등 (17-T §8.13–8.21)	**S1~S3 (S1 최고)** ▪ Security Degree, **Category A → S1** (IEC 62645 §5.4.3.1.3)	**SL 0~4 (SL 4 최고)** ▪ **SL-T** 목표 · SL-C 능력 · SL-A 달성
방호구조 등급 계층과 데이터 흐름 규칙을 정한 전체 구조	**Defensive Architecture** ▪ **L4→L3·L3→L2 One-way** (RG 5.71 §C.3.2.1)	**DCSA** (Defensive Cybersecurity Architecture) ▪ **Passive·Deterministic 수단** + Active Control 조합	**DCSA** (Defensive Computer Security Architecture) ▪ **Level·Zone 기반** Defensive Architecture (17-T §8.5)	**Security Architecture** ▪ SD별 **Security Zone** 구성 (IEC 62645 §5.4.3.3)	**Zone & Conduit Model** ▪ **3-2 Risk Assessment**로 Zone·Conduit 설계
등급 내 분할 같은 등급 안에서 자산을 다시 묶는 단위	**Segmentation (구획화)** ▪ **동일 Level 내** CDA 논리·물리 분리 (RG 5.71 §C.3.2.1) (RS-015 §2.2.5.2.5)	**Computer Security Zone** ▪ Critical System 배치, **분류별 보호 강화** (DG-5103 §C.117–C.118)	**Computer Security Zone** ▪ 동일 Level 자산 그룹, **Sub-zone 구성 가능**	**Security Zone** ▪ **동일 SD** 시스템의 묶음	**Zone** ▪ **동일 Security Requirement** 자산 그룹
경계 통제 등급·구역 사이 통신을 통제하는 수단	**Boundary Device** ▪ 경계보호시스템, ▪ **Data Diode (One-way)** · Firewall	**Deterministic Device** ▪ **Data Diode 등으로 Attack Pathway 제거**	**Zone Boundary Device** ▪ 는 보호 대상 중 가장 **높은 Level을 상속** (17-T §5.35, §8.7)	**Boundary Device** ▪ Security Zone 경계의 **통신 통제·Decoupling**	**Conduit** (통신도관 통제) ▪ Zone 간 통신경로 묶음, **Conduit별 보안요건**
등급화 원리 보호 수준을 정하는 판단 기준	**Consequence-based Graded Approach** ▪ **SSEP 침해 결과** 기준 (RG 5.71 §C.3.2) ▪ CDA 전체 보호 + Level별 차등	**Consequence-based Graded Approach** ▪ **73.110(a) Consequence** 기준 ▪ Critical 등급별 통제 범위 차등	**Graded Approach** ▪ **Facility Function 침해 Consequence** 기준	**Graded Approach** ▪ **Category A는 통상 S1 후보,** ▪ 단 1:1 강제 아님 (IEC 62645 §5.4.3.1)	**Risk-based SL-T** ▪ Zone별 **Risk Assessment**로 목표 SL 설정

❖ RG 5.71 / RS-015 / IEC 62443 → 숫자가 클수록 높은 보호
❖ IAEA NSS 17-T / IEC 62645 → 숫자가 작을수록 높은 보호

4

1. 개요 : Safety DiD와 Cyber DiD 비교

newpower, newstandard KEPCO E&C

개념 기준서 →	Safety DiD (안전 심층방호) ▪ 원자력안전법 · 원자로시설 기술기준 · 10 CFR 50 · IAEA INSAG-10 · IAEA SSR-2/1 Rev.1 (2016) · SSG-39 (2016) · IEC 61226	Cyber DiD (사이버보안 심층방호) ▪ 방사능방재법 · KINAC/RS-015 Rev.2 (2023.12) · 10 CFR 73.54 / 73.110 · RG 5.71 Rev.1 · RG 5.96 · IAEA NSS 17-T Rev.1 · NSS 42-G · NSS 33-T · IEC 62645 Ed.2 · IEC 62859
목적 방호로 달성할 목표	**Accident Prevention · Control · Mitigation** ▪ Equipment Failure · Human Error · Natural Hazard로 인한 사고의 예방·제어·완화	**Protect SSEP Functions from Cyberattacks** ▪ 의도적·악의적 Cyber Attack으로부터 SSEP 기능의 무결성·신뢰성 유지 및 예방·탐지·대응·완화·복구 (RS-015 §2.2.5)
위협 · 실패 가정 설계가 전제하는 위협	**Random Failure · CCF · External Hazard** ▪ 비의도적 사건, Random Single Failure·Software CCF 가정	**Intelligent Adversary** ▪ Insider·Outsider·국가 수준 공격자, 취약점 선택 공략·동시 다중 침해 가정
설계 기준 방호 수준의 기준 사건	**DBA · DEC** ▪ Design Basis Accident · Design Extension Condition 기반 Safety Analysis	**DBT**(Design Basis Threat) · **Consequence Scenario** ▪ DBT기반 Threat · Vulnerability · Consequence 분석 및 자산·통신경로 기반 위험평가 ▪ 결과 기반 시나리오(CEAS/CEIS, 10 CFR 73.110) 분석
등급 체계 중요도별 요건 차등	**Safety Classification** ▪ IEC 61226 Category A / B / C (A 최고), IEEE Class 1E, Safety / Non-safety	**Security Level · Degree** ▪ RS-015 · RG 5.71 : 0~4 (4 최고) / IAEA 1~5 · IEC 62645 S1~S3 (1 최고)
계층 구조 방호 계층 단위 · 배치 축	**Levels of DiD 1~5 + Physical Barrier** ▪ 사고 진행 단계(시간 축) : Normal → AOO → DBA → DEC → Off-site Emergency	**Security Level · Zone · Boundary** ▪ 토폴로지/신뢰 경계(공간 축): 외부(저신뢰) → 내부(고신뢰) + 기능 연속성(예·탐·대·완·복)
독립성 원리 계층 동시 실패 방지	**Redundancy · Independence · Diversity** ▪ Single Failure Criterion, Physical · Electrical Separation	**Diverse · Independent Measures** ▪ 인접 Layer 간 Diverse·Independent 조치, Zone Decoupling (17-T §4.77, §4.81) ▪ 단방향·결정론적 격리, 논리적 구획화
실패 시 상태 기능 상실 시 목표 상태	**Fail-Safe** ▪ 고장 시 안전 상태(Safe State/Trip) 전환	**Fail-Secure (Safety First)** ▪ 조치 실패 시에도 Function의 Security 유지 (17-T §4.78~4.79), ▪ 단, 안전 기능 저해 금지(Safety First, IEC 62859)
대표 조치 계층별 구현 수단	**Protection System · ESF · Containment** ▪ APR1400 : PPS · ESF-CCS · DPS, Containment Building, Emergency Response	**Defensive Architecture + Security Controls** ▪ Level · Zone · Boundary + Technical · Operational · Management Control
검증 방법 방호 효과의 확인 수단	**Deterministic Analysis · PSA · EQ** ▪ Deterministic Safety Analysis, PSA, Equipment Qualification	**Risk Assessment · 보안 조치 평가 · 취약점 평가** ▪ Communication Matrix 검증, Vulnerability Assessment, Incident Response 훈련

근거 : [IAEA NSS 33-T §2.3 · §4.141~4.151], [NSS 17-T Rev.1 §4.74–4.83], [NSS 42-G §2.42–2.43], [RS-015 R2 §2.2.5.2.4], [RG 5.71 Rev.1 §C.3.2], [IEC 62645 §5.4.3.1]

5

2. NRC RG : RG 5.71 Cyber Security DiD 개요

newpower, newstandard KEPCO E&C

Digital I&C 확대와 규제 Paradigm 전환 — 중첩 방어 Layer로서의 DiD

배경

Digital 전환으로 확대된 Attack Surface

- 원전 I&C 디지털화, SMR · 신규노형 도입 확대
- Air Gap만으로 방호 불성립
- 우회 경로(공급망·PMMD·무선·물리접근) 상존
- 단일 Control 의존 구조 한계 노출

DiD 설계

Control 충족 점검 → 방어 Layer 중첩으로

- Boundary만으로 DiD 불성립
- 단일 Control 실패 → SSEP 침해 직결 안됨
- Multiple · Diverse · Mutually Supporting
- 보안기능 (Prevent, Detect, Respond, Mitigate, Recover) 연속성 적용

규제 동향

Prescriptive 목록 → Risk-informed

- RG 5.71 R1 : Architecture + App. B · C
- RG 5.96 R1 Draft : **Risk-informed DCSA**
- NSS 17-T R1 : Level · **Zone DCSA**
- IEC 62645 : S1~S3 (**Consequence**)

RG 5.71 R1 (RS-015 R2) DiD 보호 전략(Protective Strategies) = ① 방호 구조 + ② 방어 전략

① 방호 구조(Defensive Architecture) [RG 5.71 Rev.1, Figure 6, §C.3.2 · App. C.7]

- Boundary Protection Devices (경계보호장치)로 분리된
- 동심 5단 구조 + 각 Security Level 내부 Compartmentalization (구획화)
- DD : Data Diode (Deterministic One-Way Communication Device)

② 방어 전략 (Defensive Strategy) [RG 5.71 R1, App. C.6 · App. B & C]

- Multiple · Diverse · Mutually Supporting Tool · Process로 적시 Detect · Protect · Respond
- App. B(Technical) + C(Operational · Management) Control 다층 중첩 → 1개 실패 시 다른 Control이 방어. 단일 Strategy · Control 실패가 SSEP Function 침해로 이어지지 않아야 함
- Data Diode 단독으로 우회 경로(공급망·PMMD·무선·물리접근)를 차단하지 못한다고 보고, 다중 계층을 요구
- 상위 Level 이동(Data · SW · Firmware · Device)은 문서화된 검증 절차로 Malware 부재 확인 필요 (App. C.6)

6

2. NRC RG : DG-5103 (RG 5.96 R1 Draft) Risk-informed 3-Tier Analysis와 DCSA

newpower, newstandard KEPCO E&C

Three-Tier Analysis [§C.65~C.105, Fig. 3]

Tier 1 Facility 수준
CEAS(Cyber-Enabled Accident Scenario)
CEIS (Cyber-Enabled Intrusion Scenario)
73.110(a) Consequence Scenario 식별 → 가능하면 Secure by Design · PPS 변경
→ 수용 → 종료

Tier 2 Function 수준
AFSA(Adversary Functional Scenario Analysis)
Adversary Pathway 식별 → Passive · Deterministic DCSA로 제거 (즉시 성공 가정)
→ 수용 → 종료

Tier 3 System [선택]
ATS(Adversary Technical Sequence)
미완화 Risk 시에만 → Prevent · Detect · Respond 등급화
→ 수용 → 종료

※ 각 Tier는 Risk 수용 가능 입증 시까지만 수행 — 분석 결과가 Architecture 결정

분석 산출 ▶ Critical System 등급화 · Zone 배정 [§C.112~C.119]

- **Most Critical** 전체 Control 평가
- **Least Critical** Performance 기반 정당화
- **Noncritical** DiD 강화 권고

※ 각 Critical System → Physical · Logical Boundary 확보 Computer Security Zone · Zone당 System 수 제한으로 Common-Cause Access 축소

DCSA 3원칙 [§C.156~C.160]

① Defensive model	② Cyber DiD	③ Least functionality
Risk별 Logical·Physical 경계 최임계 = 최고 Level	상호보완 · 중복 Control 단일 실패 → SSEP 침해 불가	불필요 기능 제거 → 비활성화 → 사용 방지 보호 조치 (3단계)

Zone 설계 4대 고려사항 [§C.157, §C.158]

- **Boundary 정렬** Logical = Physical 경계, Diode로 제한
- **Function 수 제한** 불필요 Function은 별도 Zone 분리
- **Simplicity 우선** 단순한 Zone일수록 이상 탐지 용이
- **Attack Pathway 최소화** 최임계 System → 최고 보안 Zone

※ CSOC(SIEM 연속 Monitoring) 도입 시 CSOC 자체의 Attack Pathway 여부를 AFSA · ATS로 판단 필요

종전 접근 방법론과의 비교

	RG 5.71	DG-5103 (Risk-informed)
적용 대상	Part 50·52 LWR	Part 50·52·53 Tech-inclusive ☛
CDA 범위	SSEP 영향 Asset	73.110(a) 유발 System (§C.56)
조치 방식	App. B·C 일괄 적용	Performance · 수단 사업자 정당화
입증 초점	조치 '수행 여부'	구조의 '효과성' (Attack Pathway 차단)

Prescriptive Control 목록(RG 5.71) ▶ Consequence 중심 · Performance-based(RG 5.96 R1 Draft) : 보호 완화가 아닌 'Consequence 기반 집중'과 '효과성 입증'으로 이동

☛ DG-5103 = RG 5.96 Rev.1 Draft (2026.06 공람) : 적용 대상 R0(**10 CFR Part 53** 전용) → **10 CFR Part 50·52·53으로 확대**

❖ [§xx]는 DG-5103 (RG 5.96 R1 Draft)의 Paragraph No.를 의미함. ❖ PPS : Physical Protection System

7

3. IAEA : 17-T Defensive Computer Security Architecture (DCSA)

newpower, newstandard KEPCO E&C

1. Facility CSRM: Computer Security Requirements 결정

Facility Function
① Function Compromise로 발생 가능한 최대 Consequence 식별
② Consequence가 클수록 높은 Security Level 할당

Security Level (1~5)
① Level 1 최고, Level 5 최소 (§2.20(b))
② Compromise 시 최악 Consequence에 비례하여 배정 (§2.26)
③ 그림의 점선 Arc = Level Boundary, 안쪽일수록 엄격

- Level 5 · 최소
- Level 4
- Level 3
- Level 2
- Level 1 · 최고

System이 Function 구현 / Level → Zone

2. System CSRM: System별 Security Measure 구현

System (Sa · Sb · Sc)
S_a S_b S_c

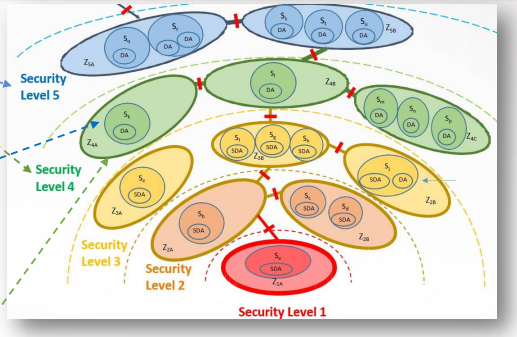
① Facility Function 구현 · 지원 · 보호 단위
② 각 System은 정확히 **하나의 Zone**에 배치 (§2.20(c))
③ Level 1은 이상적으로 Function 1개당 System 1개 (§2.21(a))
④ 상위 Level일수록 단순, Z1A는 단일 Deterministic System (§2.21(b))

Security Zone (Z1A · Z2A · Z4B)

Security Level 4: S_a S_b Z_{4A} | Z_{4B} | Z_{4C}

① 공통 Security Requirement를 갖는 System의 Logical · Physical Group
② 각 Zone은 **하나의 Level**에 배정 (§2.20(d))
③ 한 Level에 복수 Zone 가능, Z4A · Z4B · Z4C (§2.20(e))
④ Zone 내부 = 내부 통신용 Trusted Area (§5.18(a))

Defensive Computer Security Architecture (DCSA)



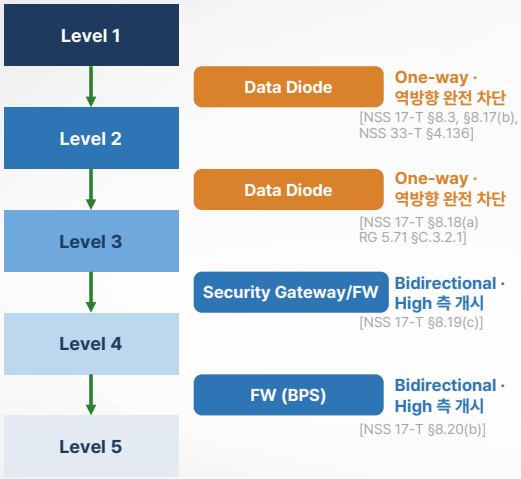
DiD 관점 의미

- ❑ **Simplicity = 방어력**
  - 상호작용 지점 축소 → Attack Surface · 검증 부담 동시 감소 (§2.21(b) · §8.2)
- ❑ **Zone 수 = Layer 수**
  - 한 Level에 복수 Zone 가능(§2.20(e)), Zone Boundary마다 Decoupling 배치 → 외부→Level 1 경로의 통과 Layer 증가 (§2.25)
- ❑ **하위 Level도 방어 Asset**
  - Level 4 · 5 Zone은 보호 대상이자 조기 탐지 Layer — 상위 Level SDA 영향 전 Attack 억제 · 완화 기회 제공 (§2.25)

❖ (§xx)는 IAEA NSS 17-T Rev.1 Paragraph No.를 의미함

8

3. IAEA : Boundary Protection 및 Level 간 Data Flow 통제



- **Decoupling :**
  - Level 간 연결(상시 · 간헐 · Removable Media)을 끊거나 제한해 공격 전파를 막는 조치
  - Level 차이가 클수록 강하게 적용 (예: L1–L2 One-way)
  - [NSS 17-T §5.18(e)(f), §8.7]
- **Initiation :**
  - 연결은 보안 Level이 높은 측(번호가 작은 Level)만 개시, 낮은 측 개시는 Deny-all
  - 예외는 Risk 분석 후 허용
  - [NSS 17-T §5.18(h) · RG 5.71 §C.3.2.1 · IEC 62645 §5.4.3.3.2 d)]
- **Air Gap · Remote :**
  - L1 · L2 Remote Maintenance 불허, 최고 보안 L1은 모든 Remote Access 금지
  - L3 이하: 승인·감시 하 제한적 허용
- **No Bypass :**
  - Monitoring · Maintenance 장치도 Boundary Control을 우회할 수 없음
  - 여러 Zone을 한 번에 관통하는 직접 연결 경로 금지
  - [NSS 17-T §8.4, §8.7]
- **Entry Point :**
  - 의도적으로 지정된 Entry Point에서만 Data Content 검사 · Event Log Monitoring 수행
  - Boundary Device는 자체 공격 내성 확보, 이상 시 Alert 발생
  - [NSS 17-T §8.8 · NEI 08-09 App. E §6]

근거 : [NSS 17-T Rev.1 §5.18, §8.3–8.20], [NSS 33-T §4.136], [RG 5.71 Rev.1 §C.3.2.1, App. C.7], [IEC 62645 §5.4.3.3], [NEI 08-09 App. E §6]

9

3. IAEA : Blended Attack 대응을 위한 DiD 추가 설계방안(제안)

5×5 Pathway 조합 Matrix

열 = 후행 경로 / 행 = 선행 경로

선행→후행	Wired	Wireless	PMMD	Supply Chain	Physical Access
Wired	—	○	○	○	● 출입통제 무력화
Wireless	● Rogue AP 경유	—	○	○	● 무선 경보 교란
PMMD	● Media 경유 침투	○	—	○	○
Supply Chain	● 휴면코드 활성화	○	● 오염 Media 반입	—	○
Physical Access	● Port·Cable 직접 접속	● AP 부착	● 현장 Media 삽입	● 반입품 변조	—

● 우선 분석 조합 물리적 접근은 4개 경로의 선행 조건, 사이버는 물리적 접근의 선행 조건 (양방향)

Security Invariants (설계 불변조건)

- 물리방호 기능의 침해가 사이버 탐지 기능을 동시에 무력화하지 않으며, 그 역도 성립(교차 독립성)
- 물리 경보와 사이버 이벤트는 독립적으로 수집 · Correlation 분석으로 결합 징후를 탐지

DiD 설계 착안점

- PPS CDA는 복합공격의 경첩(Hinge) : 사이버 침해 하나로 두 계층이 동시 붕괴하는 순환 의존
  - ☛ 최고 Level 배치 + Non-digital 대체수단 필요
- 사이버·물리 DBT가 별도
  - ☛ 조율된(Coordinated) 방식으로 개발 (NSS 42-G I-29, I-30)
- 사이버로 허위 화재신호를 발생시켜 화재연동 출입문 해제시
  - ☛ Fail-Safe ↔ Fail-Secure 충돌 지점 → 생명안전 우선 + 신호 발생원 확인, 보상적 보안 조치
- 원전 적용 :
  - ☛ PPS 독립 유지 + Non-digital 대체수단 사전 정의

DiD 추가사항 분류체계 (제안)

#	추가사항	설계 조치	원전 적용 예시	근거 Section
A-1	**경로 조합** 시나리오 편입	5×5 조합 매트릭스, 사이버·물리 DBT 조율	CDA 평가에 조합 시나리오 추가	NSS 17-T §4.49, §4.122
A-2	물리방호 설비(PPS) **공통원인 차단**	비디지털 대체수단, 무결성 이상 시 수동 전환	PPS 독립 + 보상조치 사전 정의	NSS 17-T §A.16 · RG 5.71 App. C.5
A-3	탐지 계층 교차 **독립·상관분석**	물리 경보–사이버 감시 독립, 결합 이벤트 상관분석	캐비닛 개폐 신호 → 사이버 로그 단방향	NSS 42-G §2.23 · RG 5.71 App. C.6
A-4	물리방호 **경로분석**에 사이버 통합	탐지–지연–대응 시간선에 사이버기인 경로 포함	출입통제 침해 탐지 < 적대자 작업시간	RG 5.96 R1 Draft CEIS · §C.88
A-5	**비상모드·생명안전** 연동 억용 차단	비상 해제 신호 발생원 무결성 확인, 경비 자동 배치	화재연동 출입문, EOP 중 완화 통제 점검	IEC 62859
A-6	**내부자 권한** 물리·논리 구획화	물리접근·논리 권한자 분리, 2인 규칙	PPS 캐비닛 접근권자 ≠ EWS 권한자	NSS 17-T §4.52(b)
A-7	**공급망** 물리적 연속성	변조방지 포장, chain of custody, 베이스라인 대조	입고~설치 단일 추적체계	RG 5.96 R1 Draft §C.145~C.151
A-8	**조직·대응** 체계 통합	보안계획–CSP 조율, 합동 대응·훈련	침입 경보 → CDA 무결성 점검 자동 트리거	NSS 17-T §A.16~A.18

10

4. IEC : 62645 Graded Approach with Security Degree (SD)

Security Degree(SD): 계통 침해시 잠재 결과에 비례해 보호 수준을 정하는 3등급 체계 **S1(최고) · S2 · S3** + 전 System 공통 BR

① **Safety Category 분류** — IEC 61226 Cat. A · B · C · NC
② **SD 부여** — IEC 62645 S1 · S2 · S3
③ **Security Control 선정** — IEC 63096 SD별 Catalogue
④ **Security Zone 구성** — IEC 62645 §5.4.3.3 (다음 장)

Safety Category → SD 부여 Rule (IEC 62645 §5.4.3.1)

Safety Cat.	부여 SD	상향 판단 기준 (Cyber Threat 영향)
Cat. A	S1	최고 등급 고정
Cat. B	S2 (최소) → S1	Cat. A Function 영향 특정 Threat Scenario 분석
Cat. C	S3 (기본) → S2 · S1	Cat. A/B Availability 영향 주요 Process 직접 · 즉각 영향
NC	S3 (기본) → S2	주요 Process 직접 · 즉각 영향

※ Safety Category는 SD 하한만 결정, **Cyber Threat 영향 분석** 결과에 따라 **상향**

SD 적용 핵심 원칙

Consequence 기반 등급화
최악 Consequence(Safety · Plant 성능)로 SD 결정, Safety Category와 1:1 대응 아님 (§5.4.3.1)

BR + SD별 추가 요구
전 System 공통 BR 위에 SD별 추가 요구 · 통신 방향 Rule 적용 (§5.4.3.2)

Zone 단위 일괄 보호
동일 SD System을 Security Zone으로 Grouping, Zone Boundary에 Decoupling 적용 (§5.4.3.3)

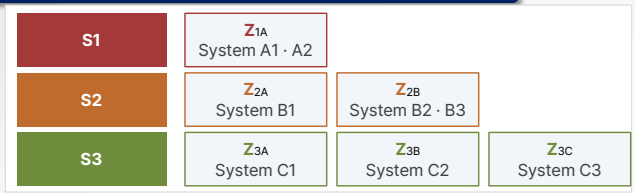
중대 변경 시 재평가
Threat 또는 Architecture 중대 변경 시에만 SD 재평가 → 안정적 설계 기준선 유지

SD = Safety Category 하한 + Cyber Threat 영향 상향의 Consequence 기반 등급 → Security Control 선정 · Zone 구성 기준

11

4. IEC : 62645 - Security Zone

Security Degree (SD) and Security Zone (IEC 62645)



- 동일 SD라도 조직 · 책임, 위치, Architecture · 기술적 사유로 복수 Zone 분할 가능
- Zone = Attack 전파 완화 수단으로 구현
- Zone = Logical · Physical Group, SD = 요구 보호 정도 — 상호 연관되나 별개 개념 (§5.4.3.3 · §6.4.5)

Zone이란? (§3.21 · §5.4.3.3.1 ~ §5.4.3.3.4)

- **정의 :** Graded Approach의 실질적 구현 방법 - Safety · Plant Performance 측면 중요도가 유사한(동일 SD) I&C System을 묶어 **Security Control을 일괄 적용하는 Logical Zone**
- **Zone 설정 기준 :** 조직적 사유(소유 · 책임), 위치(Localization), Architecture · 기술적 측면
- **SD와의 구별 : Zone** = System의 Logical · Physical Grouping / **SD** = 요구 보호 정도 - 'S2 Zone'처럼 통칭 가능하나 별개 개념
- **주의 : 'Zone' = Security Zone** - Safety Zone 및 지리적 분리와 구별 필요 (일부 관련성 존재)

Design 단계 Zone 정의 (§6.4.5)

- **§6.4.5.1 : Security Zone은** Design 단계 정의 원칙(should), 대안으로 Implementation 단계(§6.5) 정의 가능
- **§6.4.5.2 : System의 Zone 배정 시** Planning 단계 부여 SD와 §6.4.4 식별 Communication Pathway를 함께 고려 필요 (shall)

Security Zone (IEC 62645) 설계 요건

요소	내용
a) 동일 SD로 구성	▪ 각 **Zone**은 동일 SD System으로 구성 ▪ 낮은 SD System 포함 시 SD 상향하여 동일 요구 충족 (should)
b) Zone 내부 Barrier 불요	▪ 동일 **Zone** 내 System 간 Security Barrier 불요 ▪ 단, System 다수 · **Zone** 간 Interface 존재 시 Barrier 유효
c) Network 장비 소속	▪ Switch · Cable은 상호연결 System과 정합하는 **Zone**에 위치 (shall) ▪ 상이 SD **Zone**에 걸칠 경우 SD별 통신 요구 · 전용 Security Control 적용
d) 통신 개시 방향	▪ 상위 Zone → 하위 **Zone**으로만 개시 (should)
e) Boundary Decoupling	▪ Boundary에 Data Flow Decoupling Mechanism 요구 – 관련 System SD와 정합

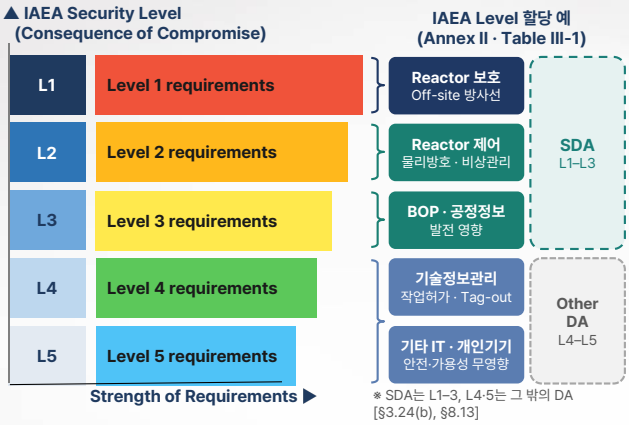
IEC 63096 §19.1 — Zone 구현 Architecture Control

- **§19.1.1 SD :** 동일 SD 내 전 요소에 일관된 Security Control 적용 보장, 보호 요구 계층화로 구현 복잡도 감소 — 일부 과보호 감수
- **§19.1.2 Security Zone :** SD 요구 보호 충족을 위해 Security Control이 적용되는 Physical · Logical(Virtual 포함) Boundary, Zone 간 분리 장비 견고성은 SD에 연동(Data Diode vs Fire wall vs Router) — Diode 선호 이유는 Deterministic 보호 방식
- **Zone 포함 원칙 :** System은 가급적 단일 Zone에 완전 포함, Zone 내 동일 Trust Level 가정 → Security Control 구현 목적의 신규 System 간 양방향 연결 생성 금지

❖ (§xx)는 IEC 62645 Section No.를 의미함

12

5. 적용 방안 : Graded Approach – IAEA Security Level × Consequence



L1	**Off-site 방사선 영향** 가능 계통 (1E/F1A · Cat. A 대응), 예: **Reactor Protection** [17-T §II-4(1), Table III-1]
L2–3	L2 : 비상관리·정상운전 안전·**주공정**·물리방호 저하 / L3 : 안전 영향 없이 **발전·운전지원** 영향 [§II-4(2)(3)]
L4–5	L4 : **장기 성능 영향** (기술정보관리), L5 : **영향 없음** → SDA 외 DA, 조기 탐지 기여 [§II-4(4)(5), §3.24(e)]

Graded Approach 원칙

- **Consequence 기반 :**
  - Function 침해 시 **최악 결과에 비례**해 Level 할당 [§2.26, §3.22]
  - Safety Class와 **자동 연계 아님**, 보안상 중요 계통은 상향 [§II-3]
- **Level 할당 규칙 :**
  - Function은 **단일 Level**, 계통은 Function Level 상속 [§4.64, §2.13]
  - Analog·사람 등 **대체 수단** 존재 시 완화 가능 [§II-6]
- **Level별 대표 요구사항 (L1–L2) :**
  - L1 : **유입 Data Flow 금지**(Outward only), Remote 금지, 2인 규칙 [§8.17]
  - L2 : L2→L3 **단방향**(ACK만 허용), Remote 금지 [§8.18]
- **Level별 대표 요구사항 (L3–L4) :**
  - L3 : Internet 금지, **Security Gateway**, Remote 사안별 [§8.19]
  - L4 : Gateway, Remote 통제 하 허용 [§8.20] · 공통 : Generic [§8.16]

Special Asset 처리

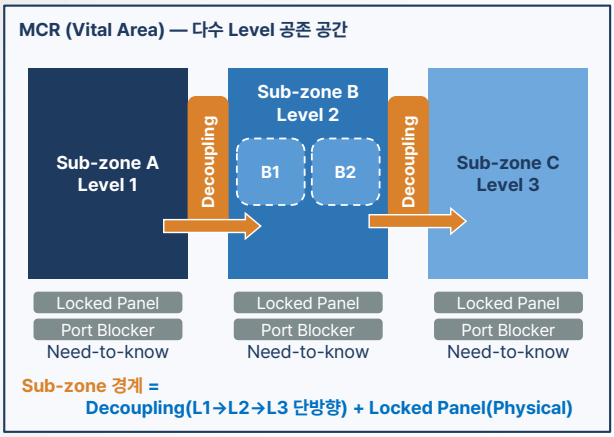
- **Analog 계통 :**
  - Facility Function 수행 Analog 계통도 Level · Zone 할당 가능 [17-T 각주 9]
- **Boundary · 다중 자산 :**
  - Zone Boundary Device는 보호 대상 중 **최고 Level** [§5.35]
  - Diverse 다중 자산은 **Primary System** 기준 Level 할당 [§II-7]
- **Unassigned 자산 :**
  - CSP 통제 밖 계통은 Unassigned, **어느 Level도 신뢰 금지** [§3.24(f)]
  - 미승인 반입 기기는 평가 전 상위 Level 근접 제한 [§8.14–8.15]

근거 : [IAEA NSS 17-T Rev.1 §2.13, §2.26, §3.22–3.24, §4.64, §5.35, §8.13–8.21, Annex II §II-3–II-7, Annex III Table III-1]

13

5. 적용 방안 : MCR 내 Physical 구획화 (Sub-zone 구성)

Zone : 공통 Security Requirement를 공유하는 System의 Logical · Physical Group
(Zone 내 System 중 가장 엄격한 Level을 Zone 전체에 적용)
[NSS 17-T §5.18(a) · NSS 33-T §2.28 · IEC 62645 §5.4.3.3]



- Logical Network : 상이 Level 간 직접 연결 없이 강한 Decoupling [17-T §III-26(a)]
- Physical Boundary : Locked Panel*, Port Blocker, Secure Conduit 활용 [§III-26(c)]
  (*전면 조작부의 HFE 운전성 보장 필요)
- B1·B2 : 동일 Level 내 구획화 [17-T §5.18(k) · IEC 63096 §19.1.2(B)]

Zone 구성 원칙

- **Level 기반 Grouping :**
  - **각 Zone은 동일 Level System**만 포함, 보호수준이 낮은 System 편입 시 Zone Level로 상향 [NSS 17-T §2.9 · §5.18(a) · IEC 62645 §5.4.3.3.2 a)]
- **Boundary 결합 :**
  - **Zone 경계** = **Physical Access Control + Data Flow Decoupling** [NSS 17-T §2.24 · IEC 62645 §5.4.3.3.2 e)]
- **구획 기준 :**
  - 조직(Ownership) · 위치 · Architecture 기준 세분화, 1 Security Degree → 다수 Zone 가능 [IEC 62645 §5.4.3.3.1, §5.4.3.3.3]

MCR Sub-zone 구성

- **다수 Level 공존 :**
  - **MCR은 상이 Level System 공존** — Physical · Logical Control로 Sub-zone 분할 · Sub-zone별 Level 부여 [NSS 17-T §III-26~27]
- **Sub-zone 수단 :**
  - Locked Panel, Port Blocker, Secure Network Conduit, Limited Access Area [NSS 17-T Annex III §III-26(c)]
- **Need-to-know :**
  - Zone 내부에서도 Need-to-know 원칙, 하위/상위 연결 Subsystem은 Sub-zone 고려 [IEC 63096 §19.1.2(B)]

근거 : [IAEA NSS 17-T Rev.1 §2.9, §2.24, §5.18(a)(k), Annex III §III-21~27] · [IEC 62645:2019 §5.4.3.3] · [IEC 63096:2020 §19.1.2]

14

5. 적용 방안 : Security Control + Alternative Control

newpower, newstandard KEPCO E&C

NEI 08-09 기반 Control 적용

경로 A — NEI 08-09 Rev.7 : 무엇을, 어떤 절차로

- **성격 :** 사업자 CSP Template — NRC 수용 산업계 표준 양식
- **핵심 산출물 :** CDA 목록, Control별 적용/대안/미적용 판정, 지속 Monitoring 계획
- **DiD 반영 :** App. D(Technical) · E(Op. · Mgmt) Control 적용, 미적용은 정당화
- **강점 :** 규제 소통의 공통 언어 — 심사 예측가능성 확보
- **한계 :** '적용했는가'는 답하지만 '충분한가'는 별도 입증 필요

예시 ① Safety EWS Control 판정 기록

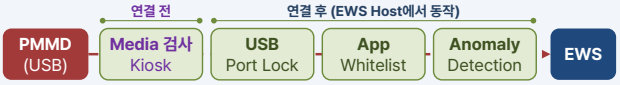
App. D : Access Control · Account Management	적용	Role-based Account, 공용 계정 폐지
App. E : Malware 방지	대안	AV 설치 불가 → Whitelisting
App. D : Remote Access	미적용	One-way 경계로 접근경로 없음

EPRI CS TAM을 통한 효과성 평가

경로 B — EPRI CS TAM Rev.1 : 얼마나 효과적인가

- **성격 :** TAM — Control 효과성의 공학적 판정
- **핵심 산출물 :** Pathway별 Control 조합 평가표, 대안 등가성 논증, Residual Risk
- **DiD 반영 :** Control 집합의 Pathway 차단 겹수 평가
- **강점 :** Multiple · Diverse 논증 — Risk-informed 규제 정합
- **한계 :** 결론이 평가 가정 · Threat Model에 좌우 — 가정 문서화 필수

예시 ② PMMD Attack Pathway × Control 조합 평가



평가 : 한 겹 돌파 시에도 나머지가 경로 차단 → Multiplicity · Diversity 충족

두 경로 결합 — 이행 순서 (사례 : Safety EWS)

CDA 식별 (NEI 08-09)	Control 적용 판정 (NEI App. D · E)	미충족 항목 도출 Alternative 후보	효과성 평가 (EPRI CS TAM)	DiD 충분성 입증 · 문서화
Safety System EWS를 CDA로 식별, Level 4에 배치	App. D · E 항목별 적용 / 대안 / 미적용 판정 기록	Legacy OS로 Patch · AV 불가 → 대안조치 후보화	PMMD 경로에 보안조치 4겹 조합 평가	Residual Risk · 평가 가정 문서화 후 규제 심사 대응

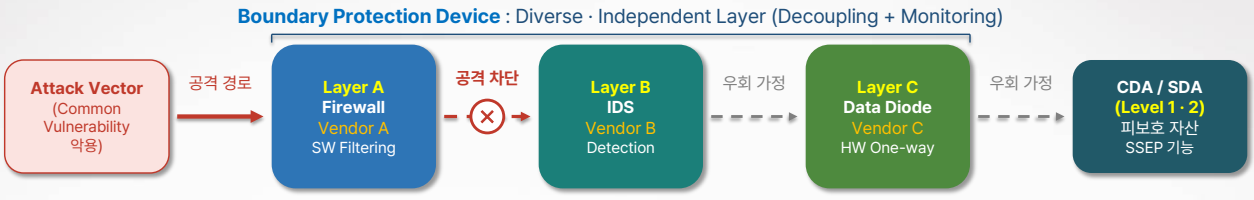
NEI 08-09 적용 판정 + EPRI TAM 효과성 평가 병행 문서화로 설계 근거 강화

15

5. 적용 방안 : DiD Independence · Diversity

newpower, newstandard KEPCO E&C

Diversity 기반 DiD — CCF 방지 개념



- Single Tactic(단일 공격 기법)으로 다계층 동시 우회 가능성 차단 [17-T §4.77]
- Layer 경계 = **Boundary Protection Device** : Decoupling(FW · Diode) + Monitoring(IDS)
- Tech. 다양성 : Layer별 보호 원리 상이 (Filtering · Detection · One-way) [33-T §4.140]

- **Independence · Diversity :**
  - Common Vulnerability를 악용한 단일 Attack Vector의 다중 Layer 동시 우회 방지
  - Independent · Diverse Measure 사용 [NSS 17-T §4.77, §3.24(d)]
- **Level별 강도 :**
  - 인접 Layer 간 Measure를 Diverse · Independent하게 운영
  - L1 · L2는 더 엄격하게 적용 [NSS 17-T §4.81]
- **Vendor Diversity 한계 :**
  - 상이 Vendor도 공통 3rd-party SW 사용 시 공통 Vulnerability 존재
  - SW 구성까지 확인 필요 [NR-T-3.30 §2.6.1]

- **Physical Sub-zoning :**
  - 상이 Level Asset 공존 시 Physical Control로 Sub-zone 형성
  - Locked Panel · Port Blocker · Secure Network Conduit [NSS 17-T §III-26(c)]
- **정기 검증 :**
  - Measure Adequacy · Effectiveness 정기 Review
  - Vulnerability Assessment 정기 수행 [NSS 17-T §8.16(k)(l)]
- **Diversity–Complexity 균형 :**
  - Diversity 확보와 System Complexity 간 균형 [NSS 42-G §2.43]

근거 : [NSS 17-T R1 §3.24, §4.73–4.81, §5.18(f), §6.11–6.20, §8.16, §III-26] · [NSS 42-G §2.43] · [NSS 33-T §4.109–4.151] · [NR-T-3.30 §2.6.1] · [DG-5103 §C.95–96]

16

6. 결론 : 원전 DiD 적용 시사점

newpower, newstandard KEPCO E&C

규제 충족 → Pathway 기반 효과성 입증

기준 동향	설계·검증 시사점	운영·규제 제언
▪ **Prescriptive 목록**(RG 5.71) → **Risk-informed · Performance-based**(DG-5103, NSS 17-T R1)로 이동 ▪ 등급 표기는 상이(L0~4 / L1~5 / S1~S3)하나 **Consequence 기반 Graded Approach** 공통 ▪ Level 간 경계 + **Level 내 구획화** 공통 요구 (RS-015 R2 §2.2.5.2.5 · 17-T §5.18(k)) ▪ 상위 Level Boundary는 **One-way · Deterministic Device**, 단독 불충분 → 우회 경로 병행 관리	▪ **Level × CDA 유형 분리 판정** : Level은 Consequence, Direct · Indirect · BOP · EP는 NEI 13-10 ▪ MCR 등 다수 Level 공존 공간은 **Physical Sub-zone**(Locked Panel · Port Blocker) + Decoupling ▪ 인접 Layer **Diverse · Independent** 구성, 3rd-party SW 공통 Vulnerability 점검 ▪ **Blended Attack** 조합 Scenario 편입, PPS 독립 + Non-digital 보상조치 사전 정의	▪ 신규노형 **DG-5103 3-Tier Analysis · DCSA 3원칙** 반영 검토 필요 ▪ NEI 08-09 판정 + **EPRI CS TAM 효과성 평가** 병행 문서화 ▪ **Cyber · Physical DBT** 조율 및 Security Plan–CSP 합동 훈련 필요 ▪ SMR · 신규노형은 Design 단계부터 **Secure by Design** 적용

추진 단계

① Level · Zone 할당	② Attack Pathway 차단	③ Level 내 구획화	④ 효과성 입증
Consequence 기반 Level 부여, CDA 유형 판정 → Zone 배정	전 CDA 경로 실물 추적, Boundary Device로 우회 제거	MCR Sub-zone + PVLAN · 802.1X, Lateral Movement 차단	EPRI CS TAM · Single Failure 시험 → Residual Risk 문서화

원전 DiD는 Control 개수가 아닌, 한 Layer 무력화 시에도 다음 독립 Layer가 Detect · Block · Recover함을 입증하는 것

17

Thank You!

경청해 주셔서 감사합니다

질의응답 (Q&A)

궁금하신 점을 자유롭게 질문해 주십시오

한국전력기술(주) SD 계측제어설계실 이정권

18

05

PRESENTATION

16:05–16:30

2026. 10. 28.(수)

2026 한국원자력학회 추계학술발표회 · 원자력 사이버보안 워크숍
원자력시설 사이버보안 규제 변화, 이행 현황과 과제 — 디지털 I&C 시대, 대형원전에서 SMR·AR까지

MSR 추진선박 개발 현황과 사이버보안 연계 이슈

김종원

삼성중공업

MSR 추진선박 개발 현황과 사이버보안 연계 이슈

삼성중공업

2026. 10.

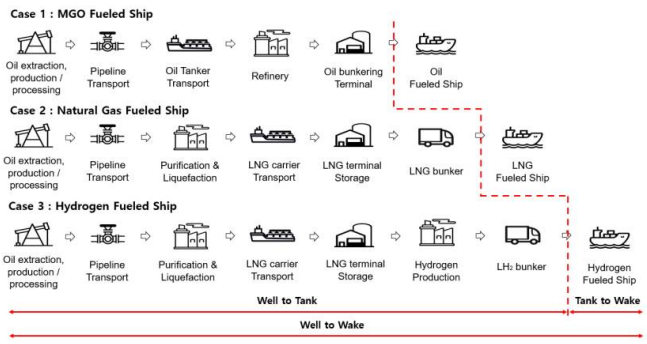
Strictly Private & CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

2026 추계학술발표회 워크샵

탄소배출 규제와 친환경 선박 개발 필요성

- MEPC (Marine Environment Protection Committee) 80 (‘23.7월)
  - ✓ 온실가스 배출 감축치 상향 조정
  - ✓ LCA (Life Cycle Assessment) 도입 논의
  - ✓ 기후변화 이슈에 대응 가능한 “무탄소 에너지원“ 원자력(SMR 중심) 관심 대두

– 출처 : 동아일보

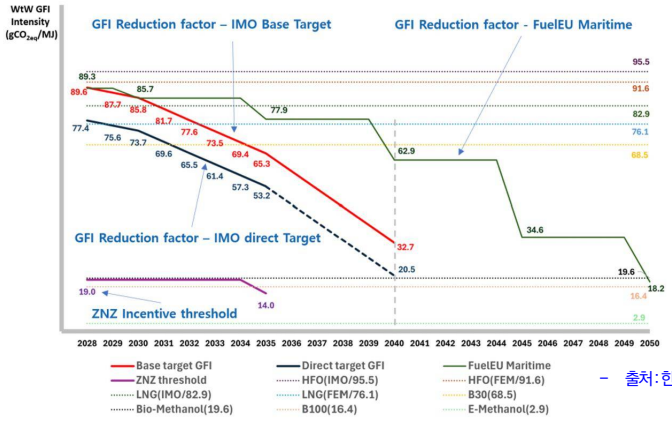


– 출처 : J. Mar. Sci. Eng. 2020, 8, 660

CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

탄소배출 규제와 친환경 선박 개발 필요성

- **MEPC (Marine Environment Protection Committee) 83 (‘25.4월)**
  - ✓ 국제해운의 온실가스 배출 저감을 위한 중기조치(Mid-term Measures) 이행 개정안 승인
  - ✓ 2025년 10월 채택, 2027년 3월 1일 발표 예정 → **채택 1년 연기 → MEPC 85차 (’26.10월 이후)**
  - ✓ 탄소연료 사용 시 추가 항목 : IMO 중기조치에 따른 Fund, FuelEU Maritime, EU ETS 원자력 연료의 ZNZ 여부 및 보상 금액



– 출처: 한국선급 브리핑

연료 종류	WtW 발자국 (gCO2e/MJ)	연료가격 ($/톤 FOE)
VLSFO	91.74	600
B30	68.72	750
LNG(디젤)	76.08	700
바이오LNG	20	1,250
그린메탄올	10	2,000
e-암모니아	5	2,250

CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

해양 원자력 관련 동향 분석 (실증 모델)

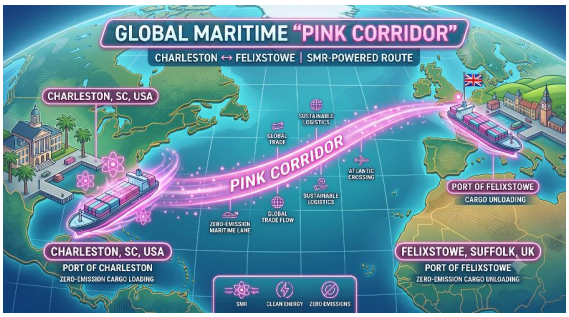
- **미국 교통부 산하 해양청(MARAD) : SMR 선박 도입 개발 계획 착수 (‘26.5월)**
  - ✓ 차세대 고효율 동력원으로 주목받는 원자력 추진 기술의 글로벌 주도권 확보 방침
  - ✓ 선박 추진을 위한 SMR 모델 개발 지원을 위한 정보 요청서(RFI, Request For Information) 발표
    - 미국 조선업을 다시 활성화하고 글로벌 에너지 지배력을 확고히 하기 위한 전략적 행보
    - 글로벌 경쟁국들이 해양 산업 전반에 원자력 추진 기술을 빠르게 통합하고 있는 상황에서의 선제적 대응 필요

–출처: AI

CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

해양 원자력 관련 동향 업데이트 (실증 모델)

- **Pink Corridor : 원자력 녹색해운항로 실증 ('26.9월)**
  - ✓ 로이드 선급(LR), 머스크(A.P. Moller – Maersk), Core Power 주도 대서양 횡단 상업용 원자력선 실증
  - ✓ 미국 동해안과 영국을 잇는 최초의 원자력 녹색해운항로 공동 가동
  - ✓ 15,000 TEU급 원자력 컨테이너선의 실제 항로 운항 시나리오와 기항지 인프라 요건 정밀 검증
    - Nuclear as a Service (NaaS) 모델 확립
    - 미·영 양자 기항 허가 및 규제 프로토콜 연구
      - 사전 항만 기항 허가 : 사전 비상대응 프로토콜 수립
      - 방사선 비상계획구역(EPZ) 선체 국한
      - 디지털 트윈 기반 원격 감사 : 기항 시 항만국 통제관에게 실시간 원격 노심 상태 데이터 투명 공개 체계 연동

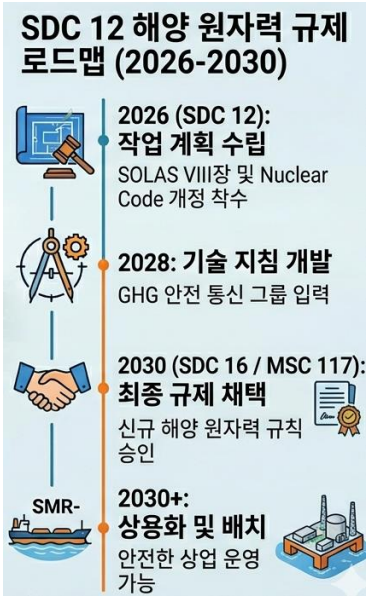


-출처:AI

CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

해양 원자력 관련 동향 분석 (Rule & Regulation)

- **SDC(Sub-Committee on Ship Design and Construction) 12차 회의 ('26.1월)**
  - ✓ 원자력 상선 규제 업데이트 '작업 계획(Work Plan)' 수립
    - '원자력 상선 안전 규칙(Nuclear Code)'을 전면 개정하고, SOLAS 제8장 (원자력 선박)을 최신 기술에 맞게 수정하기 위한 작업 계획안 수립
    - IMO SOLAS 제8장(Chapter VIII: Nuclear Ships)에는 **사이버 공격 관련 조항 불포함**
    - '26년 5월, MSC 111차 회의 제출되어 최종 승인 예정
  - ✓ 해양 원자력 규제 중장기 로드맵 (목표 일정)
    - ~ 2029년 : 새로운 가이드라인 및 규정 개정안(초안) 개발 1차 완료
    - 2030년 (SDC 16차) : 개정된 원자력 규약(Nuclear Code) 및 SOLAS 제8장 개정안 내용 최종 확정
    - 2030년 (MSC 117차 / 118차) : 해사안전위원회를 통한 해당 법안의 최종 승인(Approval) 및 채택(Adoption)



CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

해양 원자력 관련 동향 분석 (Rule & Regulation)

IAEA : “Transportable” NPP로 접근

- ✓ 2008년~2013년 이동가능 원자로에 대한 긴급 검토 (Preliminary)
- ✓ 보고서 업데이트 진행 中
  - 방사성 물질의 이송과 관련된 SSR-6 (Regulations for the Safe Transport of Radioactive Material)의 업데이트
  - 핵연료의 장전 여부, 방사화 여부, IMDG, INF Code와의 연계가 주요 쟁점

Examples of Nuclear Shipping Propulsion Projects

	Italy-based	Norwegian-based[1] (NuProShip)	UK-based	China-based	South Korea-based	South Korea-based
Nuclear Technology Developer	newcleo	USNC, Kairos Power	TerraPower			
Shipbuilding Company	FINCANTIERI	VARD	CSSC	CSSC	HMM	
Mentioned Classification Society	RINA	DNV-GL		DNV-GL	KR	
Nuclear Research Agency					KRISO	
Comments						

Ref. New Energies Coalition. “The Role of Nuclear in Shipping Decarbonization”. April 2025.

Associated shipbuilders for FNPPs

Akademik Lomonosov Floating Nuclear Plant

Chinese-made hulls for Russian floating nuclear plants

China Unveils Plans For ‘Largest Ever’ Container Ship, Powered By Thorium Reactor

HD Korea Shipbuilding Unveils Nuclear-powered Container Ship Design

ThorCon plans 4 GW of nuclear power by 2035 in Indonesia

CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

해양 원자력 관련 동향 분석 (Rule & Regulation)

IAEA ATLAS Project

- ✓ IAEA Atomic Technologies Licensed for Applications at Sea
- ✓ ‘26.8월, ATLAS Initiative 발족식
  - 초기 단계에 참여 필요 (연구계, 규제기관, 민간기업 등)
  - 현재 당장의 FNPP에 대응하기 위한 TNPP(Transportable)에 대한 Guideline 주요 내용 검토
  - 해양용 원전의 인허가와 관련한 논의 진행 예정 (기술, 규제 측면 모두 다룸)

ATLAS에서 Cyber Security란?

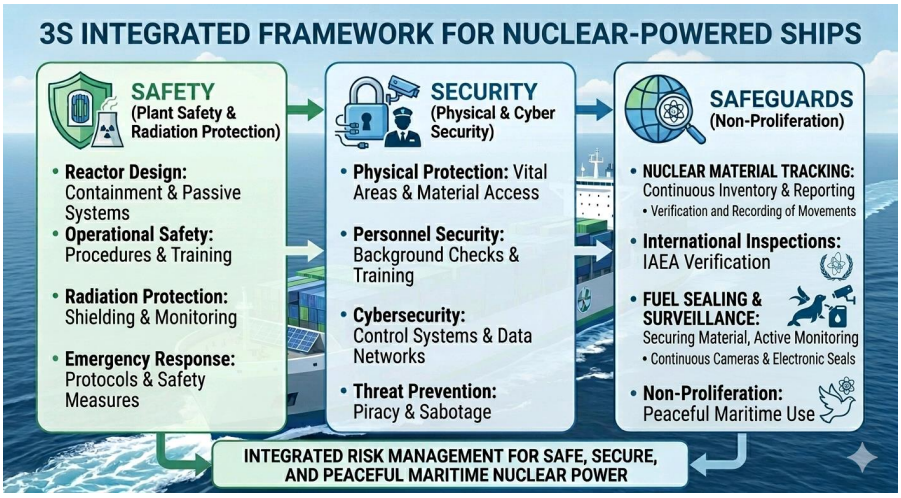
- ✓ 외부와 상시 무선 통신을 주고받아야 하는 해양 부유체/선박 환경에서 “원자로의 안전정지 제어권을 사이버 공격으로부터 어떻게 격리·보장할 것인가"에 대한 인허가 심사 기준과 기술 요건을 정립
- ✓ IMO의 Cyber Risk 관리 지침(MSC-FAL.1/Circ.3) 및 IACS의 UR E26(선박 시스템 복원력), UR E27(선박 탑재 기자재 사이버 보안)에 대한 통합 적용 필요

CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

해양 원자력 관련 동향 분석 (Rule & Regulation)

IAEA : 원자력추진선 3S Intergrated Framework

✓ Safety, Security and Safeguard



- 출처 : AI

CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

해양 SMR의 조건 (INL)

해양 적용에 유리한 원자로 노형

✓ 원자력추진선, 부유식(착저식) 원전 등의 비즈니스모델에 따른 분석

✓ FHR, MSR의 특징 반영

- 상압, 고온 조건 → 해양 조건에 유리

원자로 노형	세대 구분	TRL	특징
PWR (Pressurized Water Reactor)	GEN Ⅲ ~ GEN Ⅲ+	9 Stage (in operation)	• 대형 원전 상용화 및 경험 풍부 • 핵연료주기 : ~ 3년
MSR (Molten Salt Reactor)	GEN Ⅳ	4~6 Stage (under detailed design)	• 현재 개발 중 (2030년 이후 상용화) • 핵연료 주기 : 10년이상 가능

- 출처 : INL (2023.9), Configurations of Commercial Advanced Nuclear-Maritime Applications

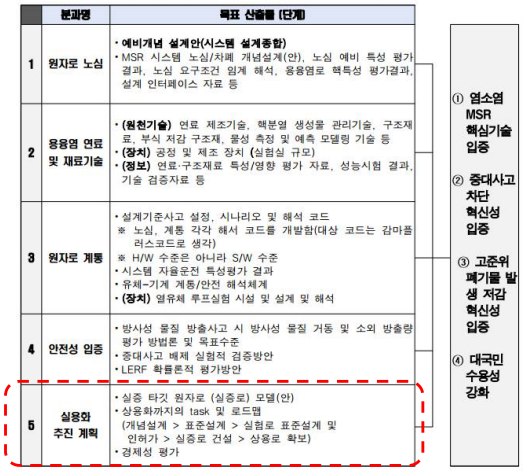
Reactor Type	Fixed land/ coast	Fixed offshore, independent only	Fixed offshore w/ onshore grid coupling	Self-propelled vessel, local	Self-propelled vessel, international
Light Water Reactor (LWR)	Already exists on land	Low temperature limits efficiencies for synthetic fuel production	Will need heat augmentation	Already exists for Naval/ Government applications	Already exists for Naval/Government applications
Sodium Fast Reactor (SFR)	Under development	Sodium-water interactions	Sodium-water interactions	Sodium-water interactions	Sodium-water interactions
Lead Fast Reactor (LFR)	Least mature technology in the West	High temperature, Lead (Pb) shielding	High temp, Lead (Pb) shielding	Least pursued technology	Least pursued technology
High-Temperature Gas Reactor (HTGR)	Under development	High temperature improves efficiencies for synthetic fuel production	High temperature improves efficiencies for synthetic fuel production	High efficiency but high pressure and low power density	High efficiency but high pressure and low power density
Fluoride High-Temperature Reactor (FHR)	Under development	High temperatures and thermal delivery	High temperatures and thermal delivery	High temperature and Low pressure	High temperature and Low pressure
Molten Salt Reactor (MSR)	Under development	High temperature and thermal delivery	High temperature and thermal delivery	High temperature and Low pressure	High temperature and Low pressure
Heat Pipe Reactor (HPR)	Under development	Limited output as single unit, potential to scale	Limited output as single unit, potential to scale	High temperature and Low pressure	High temperature and Low pressure

CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

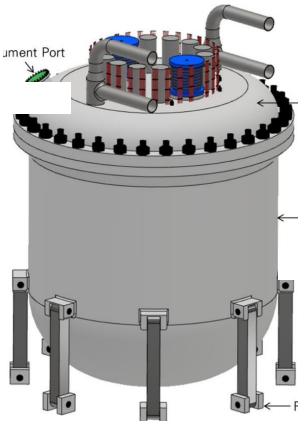
한국원자력연구원 용융염원자로 기술 개발 사업

▪ 한국원자력연구원 용융염원자로 기술 개발 사업 (혁신도전프로젝트) 추진

- ✓ "**중대사고와 고준위폐기물에서 자유로운 원자로** 기술"
- ✓ 해양용 용융염원자로 원천기술 개발 사업



원자로 노형	용융염원자로 MSR
핵연료	액체핵연료 (U + 용융염)
냉각재	용융염 (Chloride-based)
감속재	없음 (고속로)
전기출력	30 MWe ~ 40 MWe
설계 수명	25 years 이상
핵연료 주기	25 years (재장전 필요 없음)
운전 압력	0.1 ~ 0.2 MPa
운전 온도	600 ℃ 이상



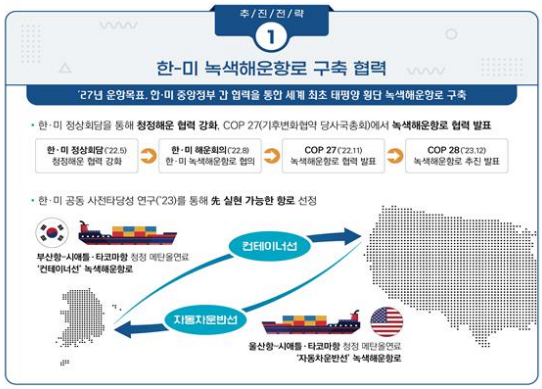
MARINA
Molten-salt Advanced Reactor for Integrated Nautical Applications

CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

원자력추진선 비즈니스 모델 : 15,000 TEU급 컨테이너선

▪ 비즈니스 모델 기준 항로 선정

- ✓ **현 시점에서의 주요 항로 경제성을 볼 때 15,000 TEU 컨테이너선이 최적 모델로 판단**
  - 미주 항로, 유럽 항로에 모두 적용 가능
  - 다수의 Port를 기항하는 것이 아닌 주요 Hub만 Shuttle Service 운영 (부산-South Hampton, 부산-LA 등)
  - 원자력에 우호적인 국가 대상 항로 가능성 및 녹색해운항로 (Green Shipping Corridor) 고려



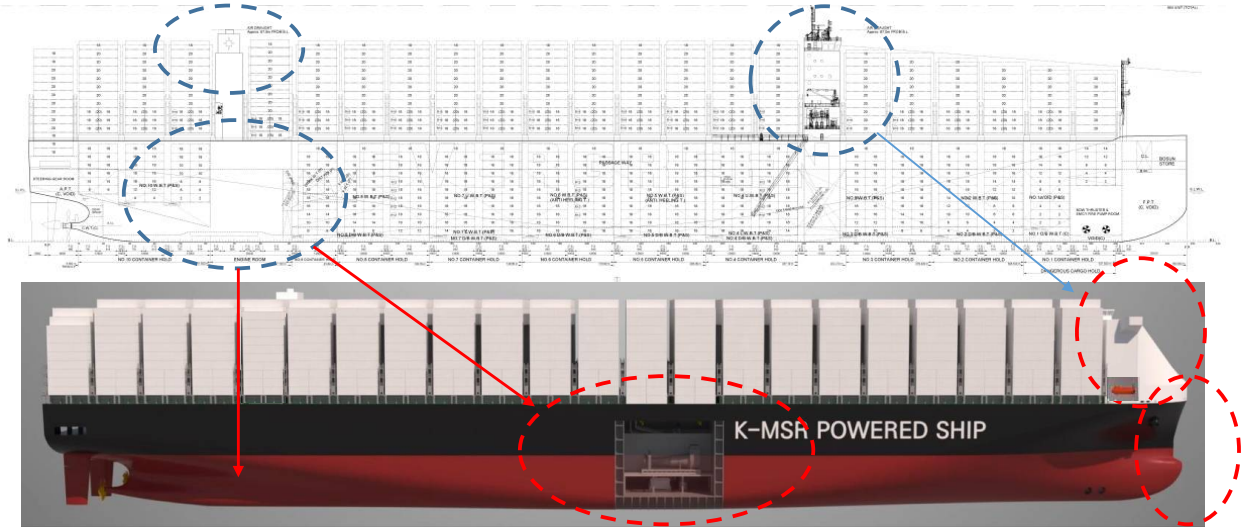
※ 무탄소 연료 또는 친환경 기술을 활용한 해상운송 전과정에서 탄소배출이 없는 항로

- 출처: DNV

CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

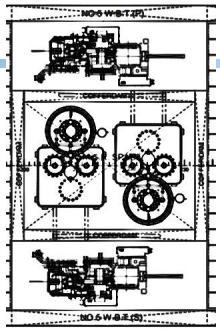
MARINA 비즈니스 모델 : 15,000 TEU급 컨테이너선

- 15,000 TEU급 컨테이너선 General Arrangement
  - ✓ KRISO "SMR 추진선 개념설계 연구" 프로젝트 연계

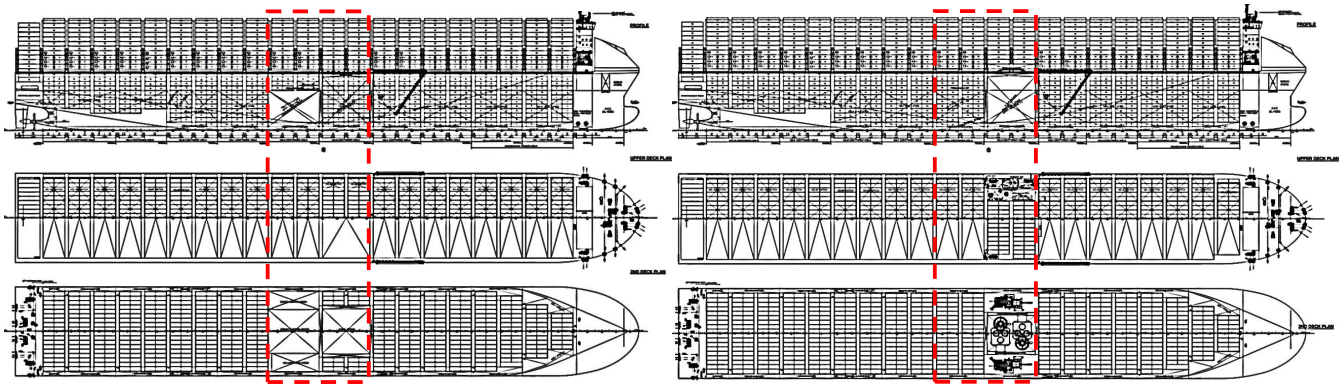


CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

MARINA 비즈니스 모델 : 15,000 TEU급 컨테이너선



- MSR 추진 15,000 TEU 컨테이너선 배치
  - ✓ Cargo hold 1개 내 배치 가능성 확인 이후 KRISO SMR 추진선 프로젝트 내 layout 반영 (MSR 계통 도움)
    - Neo-Panamax 최대 폭을 기준으로 MSR Space 내 MSR 2기 배치 가능
    - 적재성능 추가 확보 가능 (16,000 TEU 가능) 및 MSR Space 좌/우 Cargo에 대한 위험성 해소
      * 1 TEU당 기대 이익??



CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

MARINA 비즈니스 모델 : LNG 운반선

MSR 추진 LNG 운반선

✓ KAERI, ABS(미국선급), 라이베리아 기국 공동 프로젝트

Energy Storage System
- 출력 조정 및 항구 접안 시 보조 동력

선수거주구 + SAVER Wind (C)
- 가시성 확보
- 운전원 방사능 안전성 확보
- 공기 저항 감소

100 MWth MSR x 1ea
- 20년 이상 설계 수명

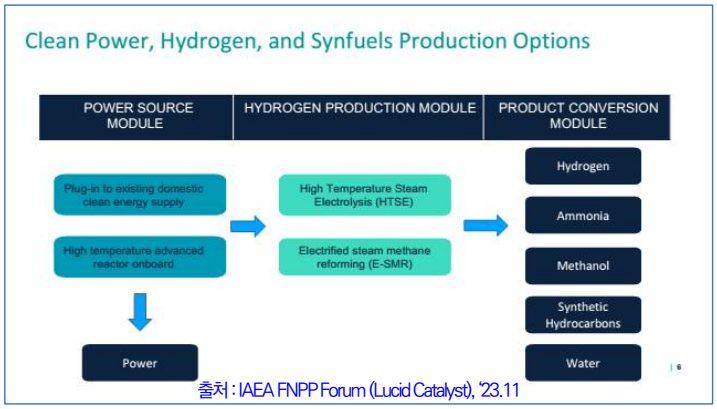
Full re-liquefaction System
- 완전재액화시스템 적용

CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

부유식 해양 원자력 발전 설비

부유식 해양 원전의 비즈니스 모델

✓ 단순 전기 생산이 아닌 “Carbon/**Emission Free** Energy” 생산
- Power to X에 적합
- 수소, 암모니아, 메탄올, 합성화석연료 및 담수 생산

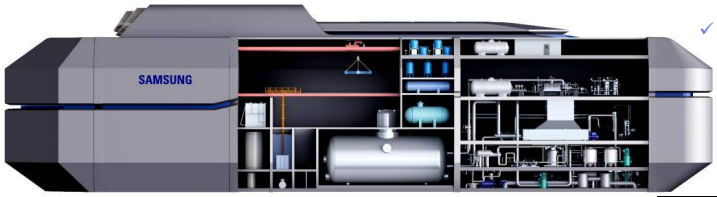


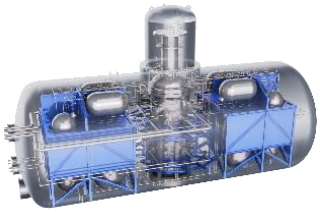
FPSO for Power, Hydrogen-Fuels, Desalination

CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

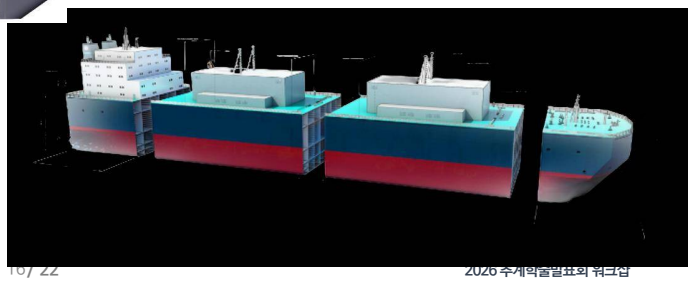
부유식 해양 원자력 발전 설비

- **SMART100 기반 FSMR**
  - ✓ 표준설계인가 획득 SMART100 2기 적용
  - ✓ Safe Containment Vessel 개념 도입





- **Saltfoss Energy(덴) seaMSR**
  - ✓ 100 MW CMSR 2기(총 200 MW)를 하나의 패키지로 공급
  - ✓ 액체핵연료 사용 : 노심용융방지, 피복재에 의한 수소 폭발 배제
  - ✓ 24년 핵연료주기 : 연료재장전 불필요
  - ✓ 감속재 NaOH 사용 → Graphite 사용



CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

선박/해양에서의 사이버 보안

- **삼성중공업 SHIFT-Auto**
  - ✓ 12 m급 자율운항 실증선박
    - 자동 접·이안, 음성 제어, 충돌 회피, 최적 항로 운항, 저궤도 위성통신 기반 원격 제어 등 다양한 자율운항 기술
    - IoT 기반 시스템 (삼성전자의 스마트싱스(SmartThings) IoT 플랫폼 탑재)
    - 데이터 무결성, 접근 제어, 암호화 통신 등 보안 기술

규제완화로 완전자율운항선박 시대 활짝…삼성중공업 'SHIFT-Auto' 출항

입력 2024-11-21 11:00

세종=노승길 기자 구독 +

정부 "내년 시행 자율운항선박법 통해 제도적으로 뒷받침"

CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

선박/해양에서의 사이버 보안

IMO MASS Code & 국내 자율운항선박법

- ✓ MASS: Maritime Autonomous Surface Ships (자율운항수상선박)
  - 자율운항선박의 정의, 원격운항센터(ROC)의 권한, 원격선장의 법적 책임, ConOps(운용개념서), 통신 두절 시 최소위험상태(MRC) 도달 등 "자율운항선박이 안전하게 바다를 항해하기 위한 종합 규칙"
  - 사이버 보안 측면에서 통신 패킷 제어나 칩셋 보안까지 다루지 않고 "외부 공격으로부터 선박 제어권을 방어해야 한다"는 목표 기반(Goal-based) 요건 제시

비교 항목	IMO MASS Code (국제 규범)	국내 자율운항선박법 (국내법)
법적 위상	SOLAS 기반 국제 강제화 추진	상용화 지원 목적 단독 특별법
규제 방식	운용개념서(ConOps) 및 기능 중심	기술 성숙도 및 실증 특례 중심
책임 주체	원격선장의 궁극적 지휘권 명시	안전운항관리책임자 지정 체계
사이버보안	IACS E26/E27 전주기 검증 의무	보안성 평가 및 통신 안정성 검토
적용 수역	국제 항해 종사 선박 대상	국내 관할 수역 및 실증 구역

CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

선박/해양에서의 사이버 보안

UR E26 “사이버 보안 아키텍처 요구사항 (Cyber resilience of ships)”

- ✓ 발표 기관과 시기 : IACS (International Association of Classification Societies) (‘22년 5월)
- ✓ 적용 대상: 2024년 1월 1일 이후 계약된 신조선
- ✓ 목적: 선박의 디지털 시스템에 대한 사이버 보안 설계 기준을 제시
  - 선박 설계 단계에서부터 사이버 보안이 내장되도록 요구
  - 자산 식별 및 분류: 선박 내 모든 디지털 시스템을 식별하고 중요도에 따라 분류
  - 네트워크 분리 및 접근 제어: IT/OT 시스템 간의 물리적 또는 논리적 분리, 사용자 접근 권한 설정
  - 보안 기능 내장: 방화벽, 침입 탐지 시스템(IDS), 암호화 통신 등 기본 보안 기능 탑재
  - 취약점 관리: 시스템 업데이트, 패치 관리, 보안 취약점 대응 절차 마련
  - 사고 대응 계획: 사이버 사고 발생 시 대응 및 복구 절차 포함
- ✓ 항해장비, 기관제어시스템, 통신장비 등 모든 디지털 자산에 대해 보안 설계 적용
- ✓ 선박 건조 시 선급기관이 보안 아키텍처를 검토하고 인증

CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

선박/해양에서의 사이버 보안

- **UR E27 “사이버 보안 테스트 및 검증 요구사항 (Testing of cyber resilience)”**
  - ✓ 발표 기관과 시기 : IACS (International Association of Classification Societies) (‘22년 5월)
  - ✓ 적용 대상: UR E26이 적용되는 선박의 디지털 시스템
  - ✓ 목적: UR E26에서 설계된 보안 아키텍처가 실제로 효과적으로 작동하는지 검증하는 기준 제시
    - 기능 테스트: 방화벽, 접근 제어, 암호화 통신 등 보안 기능이 정상 작동하는지 확인
    - 침투 테스트(Penetration Test): 모의 해킹을 통해 시스템의 취약점을 점검
    - 시나리오 기반 테스트: 실제 사이버 공격 시나리오를 기반으로 대응 능력 평가
    - 로그 및 모니터링 검증: 이상 징후 탐지 및 기록 기능의 유효성 확인
    - 복구 능력 테스트: 시스템 장애 발생 시 복구 절차의 실행 가능성 검증
  - ✓ 선박 인도 전, 선급기관이 UR E27 기준에 따라 보안 테스트 수행
  - ✓ 테스트 결과를 기반으로 보안 인증서 발급 여부 결정

CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

선박/해양에서의 사이버 보안

- **IMO MASS Code & IACS UR E26/E27 비교**
  - ✓ MASS Code : "자율운항선박은 고도의 사이버 복원력을 갖추어야 한다"고 규정

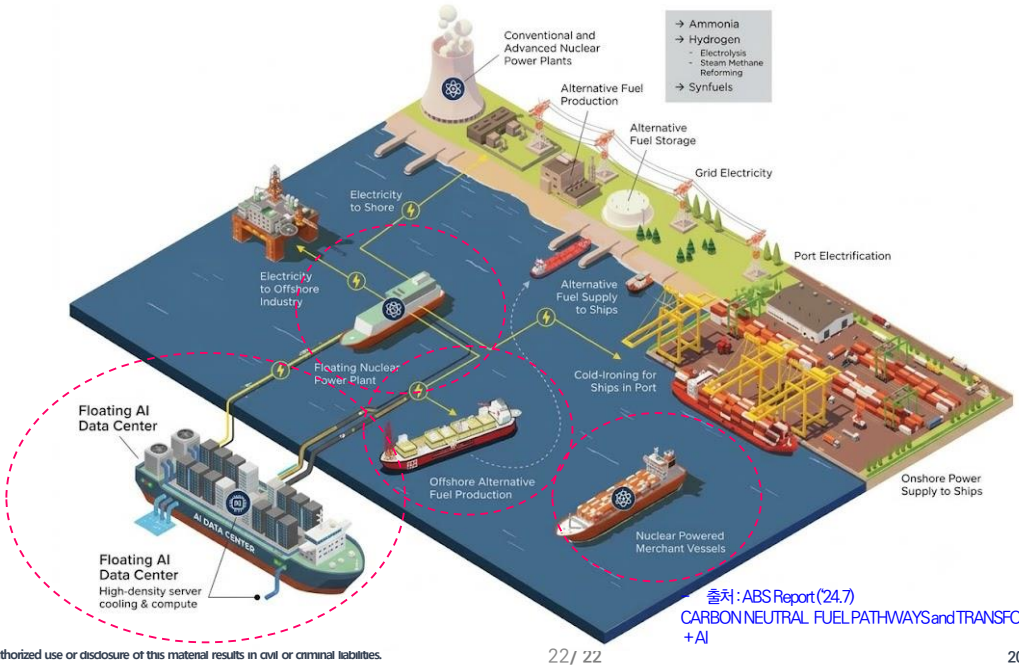
→ 실제 조선소와 선사는 이를 입증하기 위해 선급의 UR E26/E27 승인을 획득하는 방식으로 증명

  - ✓ 적용 시점의 차이
    - 현재 건조되는 자율운항 실증선박의 경우 사이버 보안에 관해서는 기본적으로 UR E26/E27 의무화

비교 항목	IMO MASS Code	IACS UR E26 (선박 시스템)	IACS UR E27 (탑재 기자재)
제정 주체 및 위상	IMO (국제 해사 안전 협약 / 기국 통제)	IACS (선급 통일 건조 규칙)	IACS (선급 기자재 승인 규칙)
적용 대상 선박	자율운항수상선박(MASS) 한정	모든 신조선 (일반 상선 포함)	선박 내 모든 OT/IT 제어 장비
규제 및 다루는 범위	운항·원격제어·인적책임 종합	선내 네트워크 구획 및 사이버 복원력	기자재 보안 부팅·무결성 시험
시행 및 강제 시기	2026년 비강제 → 2032년 강제화	2024년 7월 1일 계약 선박 의무화	2024년 7월 1일 계약 선박 의무화
상호 관계 및 역할	최상위 목표기반 안전 요건 제시	MASS 선박 사이버 안전 구현 표준	MASS 시스템 구성 하드웨어 인증

CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

맺음말 : 해양 원자력 Value Chain



출처 : ABS Report ('24.7)
CARBON NEUTRAL FUEL PATHWAYS and TRANSFORMATIONAL TECHNOLOGIES + AI

CONFIDENTIAL Unauthorized use or disclosure of this material results in civil or criminal liabilities.

06

PRESENTATION

16:30–16:55

2026. 10. 28.(수)

2026 한국원자력학회 추계학술발표회 · 원자력 사이버보안 워크숍
원자력시설 사이버보안 규제 변화, 이행 현황과 과제 — 디지털 I&C 시대, 대형원전에서 SMR·AR까지

국가 핵심 인프라 보안 모니터링 시스템 강화 및 이행 현황

김진철

한전KDN

국가 핵심 인프라 보안 모니터링 시스템 강화 및 이행 현황

한전KDN|주|

CONTENTS

국가 핵심 인프라 보안 모니터링 시스템 강화 및 이행 현황

CHAPTER Ⅰ 사업 개요

CHAPTER Ⅱ 추진 방향

CHAPTER Ⅲ 향후 계획

한전KDN|주|

CHAPTER Ⅰ CHAPTER Ⅱ CHAPTER Ⅲ

Ⅰ 사업 개요

국가 핵심 인프라 보안 모니터링 시스템 강화

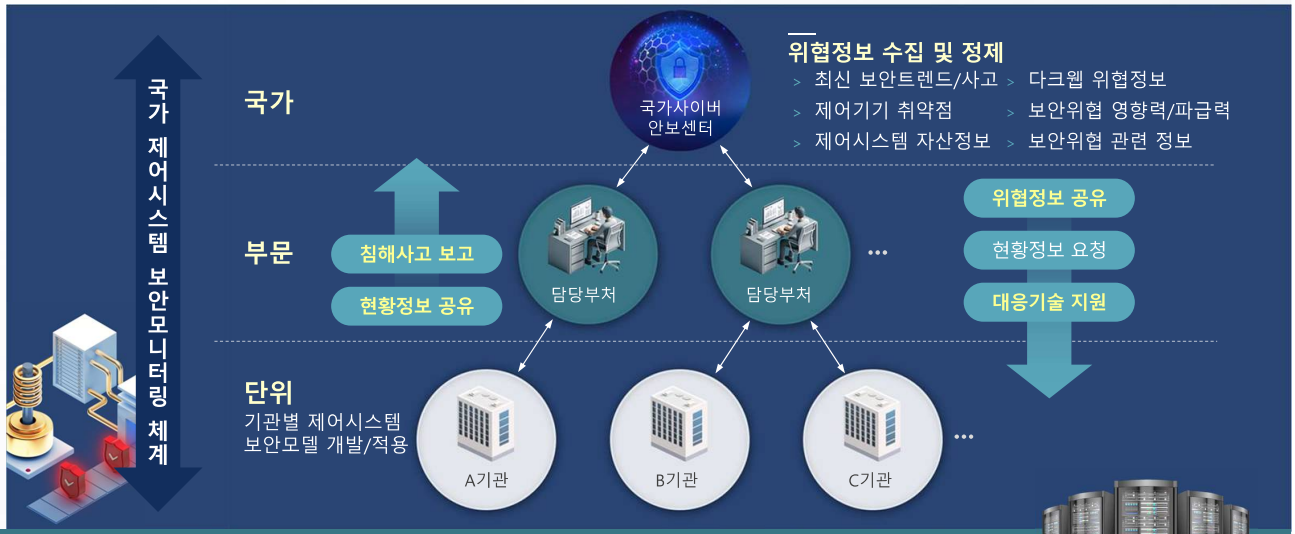
1 | 사업 추진 목표
2 | 제어시스템 개요
3 | 추진배경 및 현황

한전KDN|주|

국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

01 국가 제어시스템 보안 모니터링 체계

기술개발 및 실증 사업을 통해 국가 핵심 인프라 보안 모니터링 강화



"제어 보안 기술 핵심"

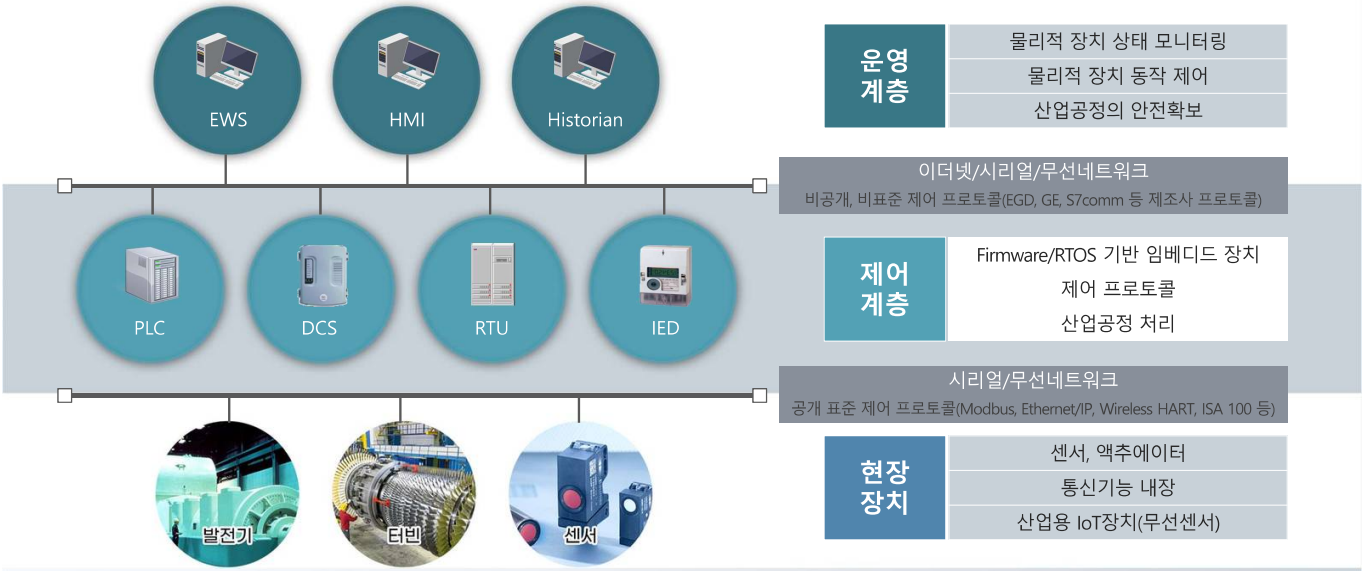
- **제어 전용 통신 프로토콜 모니터링**, 트래픽 분석 및 위협 이벤트 식별
- 제어시스템의 세부 자산 정보 및 **보안취약점 식별, 대응체계 확보**

한전KDN|주|

국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

02 제어시스템 개요

- 어떤 대상(제어대상, 플랜트 등) **시스템의 동작을 감시, 제어 모니터링**
- **설비 상태나 출력을 제어하고 조절하는** 기계적, 전자적 또는 소프트웨어적 장치/구조



| 제어시스템 구성도 |

한전KDN㈜

국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

03 추진 배경 및 현황

제어시스템에 대한 사이버 위협 증가, **보안 모니터링 구축 가이드라인** 제정

배경 및 필요성

- 정부기관, 기반시설, 제조기업 등 사이버 위협 증가
  (유럽 공항 마비, 미국 송유관 /상수도 공격 등)
- 전세계 산업제어시스템 중 33%이상 악성코드 탐지
  (이중 약 10% 지속적으로 감염 반복)
- 제어시스템 취약점 CVE 건수 지속적 증가
  (2023년 : 1,340건 2020년 대비 약 2.4배)

국내 · 외 대응 현황

- (국내) '제어시스템 보안 모니터링 구축 가이드라인' ('25.5)
  정보통신기반보호법(제9조) 및 시행령(제17조) 기준
  제어시스템 취약점 분석 평가 항목 확대
- (해외) 전력, 석유·가스 분야 시범 실증으로 제어시스템 보안 모델 개발 및 적용 중

한전KDN㈜

CHAPTER Ⅰ CHAPTER Ⅱ CHAPTER Ⅲ

Ⅱ

국가 핵심 인프라 보안 모니터링 시스템 강화

추진 방향

1 | 구축사업 추진 단계
2 | 보안 모니터링 구축모델 설계 단계
3 | 보안 모니터링 구축 단계

한전KDN|주|

01 구축사업 추진 단계

보안 모니터링 구축 가이드라인에 따른 **단계적**으로 실증 및 **구축** 활동 **추진**

1단계 기획 및 사전 준비

1.1 추진 기획 수립
- 중장기 추진 기획 수립
- 실증 추진

1.2 자산식별
- 목적
- 정보 수집 방법, 식별 정보 항목
- 식별 대상 자산
- 식별 수행 단계
- 자산유형

1.3 보안 모니터링 영역 정의
- 보안 모니터링 영역 식별
- 보안 모니터링 정보 분류
- 수집 시 고려사항
- 네트워크 구조 파악
- 주요자산 식별 및 선정
- 보안 모니터링 범위 정의

2단계 사업 구축

본 사업 적용단계

2.1 보안 모니터링 구축모델 설계
- 구축모델 요구조건
- 활용 가능 기술 솔루션
- 수집 기술 검토
- 수집데이터 흐름도 작성
- 데이터 수집 지점 선정
- 시스템 구성 및 아키텍처 설계
- 보안 모니터링 지표 설정

2.2 보안 모니터링 구축
- 제어시스템 보안운영센터 구축 목표, 기능, 역할
- 제어시스템 보안운영센터 구성요소
- 수집 지점 선정
- 주요 기술 아키텍처
- 기술솔루션 배포 설치 및 검증
- 위협시나리오 작성
- 시각화 (대시보드)
- 잔여 위협 및 수명주기 관리 평가

3단계 확대 구축

3.1 기관 전체 확대
- 구축모델 개선, 적용 방향성 결정
- 실증 구축 결과 검토
- 개선항목 반영한 표준안 도출
- 자산식별 확대 및 고도화 진행
- 자산관리 시스템 구축, 변화관리

3.2 확대 자원 계획
- 본사 정책 개선
- 본사 업무 정의 및 인력구성
- 보안 교육 및 인식 재고
- 제어시스템 보안 모니터링 제도화
- 프로세스 재개정

3.3 추가 고려사항
- 설계수명과 운영수명 고려
- 네트워크 운영정보 기준모델

한전KDN|주|

국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

01 보안 모니터링 추진 기획 수립 (1단계)

수도관리제어망에 대한 자산 식별, 데이터 수집, 위협 모니터링 기능 실증

실증 범위 및 시행 ('24년 완료)

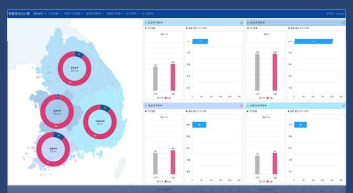
- **제어망 내부 자산 식별**
  - 신규 노드 자동탐지 및 맵핑, 모니터링 대상 자산 파악
- **데이터 수집 및 분석 (보안위협 탐지)**
  - 로그, 패킷, 운전정보 데이터 연동, 위협 이벤트 탐지
- **통합 모니터링 체계 구현**
  - 보안설비 통합 모니터링 구현, 외부 접점 구간 가시성 확보

수처리시설 위협 실증 시나리오 시행

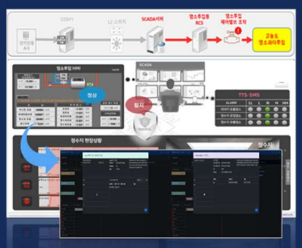
- **실증 시나리오 #1 (정수장 염소 과다 투입 공격)**
  - 감염USB 사용 악성코드 전파
  - 공격 은닉으로 인해 염소투입 HMI와 TTS·SMS 알람을 통한 이상 확인 불가
  - 보안위협 은닉 공격 실시간 탐지 ☞ NADIA+
- **실증 시나리오 #2 (배수지 수위 범람 공격)**
  - 원격지 대상, 공격자 VPN 접속 후 악성코드 전파
  - 신규 프로토콜 패킷 코드 탐지 ☞ 위협관리시스템
  - 보안위협 은닉공격 실시간 탐지 ☞ NADIA+

주요 실증 결과 Verification

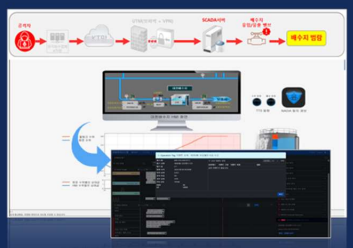
| 데이터 분석·위협탐지 기능 구현 |



| 통합 모니터링 체계 |



| 실증 시나리오 #1 은닉공격 탐지 |



| 실증 시나리오 #2 원격지 공격 탐지 |

한전KDN㈜

국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

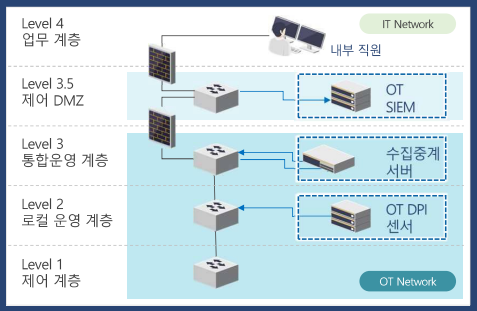
02 보안 모니터링 구축 모델 설계 단계

협약 체결 통한 대상 기관 지정 후 데이터 수집 및 적용 기술 선정

2단계 보안 모니터링 구축 모델 설계 Guide

구축 모델 요구조건	이벤트 모니터링, 위협 시각화, 모니터링 역량, 대응 역량 부분에 대한 기능별 요구조건 확인
활용 가능 기술 솔루션	OT센서, OT 방화벽/IDS/IPS, OT SIEM 등 기관 제어시스템 내 적용 가능한 솔루션 분석
수집 기술 검토	제어영역의 자산 유형에 따른 적합한 모니터링 방안 선정(자산 구성, 중요도 등 고려)
수집데이터 흐름도 작성	제어시스템 자산 간의 데이터 흐름 상태 통신 방식(전용 프로토콜, 연계 대상 등) 확인
데이터 수집 지점 선정	활용 가능 솔루션 및 수집 기술 검토 내역과, 제어시스템 가용성 고려, 데이터 수집 지점 선정
시스템 구성 및 아키텍쳐 설계	자산 목록화 및 자산 유형 식별 → 네트워크 구조 파악 → 모니터링 영역 정의 → 데이터 흐름도 파악 → 데이터 수집지점 결정 → 모니터링 시스템 설계
보안 모니터링 지표 선정	보안 모니터링 수행 시 비정상 상황 인지 기준 (실제 운전 환경, 이상 상황 인지 기준 등 반영)

데이터 수집 및 적용 기술 Architecture



물리적, 논리적 네트워크 분리 분할	▪ 보안 모니터링 구축 모델 기반 네트워크 구조 개선 ▪ 물리적 일방향 전송 ▪ OT 방화벽 구축
방화벽을 통한 접근제어	▪ OT 방화벽 구축
비정상 통신 / 이상행위 탐지 모니터링	▪ OT DPI Sensor ▪ OT SIEM
원격 접속제어	▪ 원격접근 점프 서버 ▪ 원격접속 서비스
업데이트 관리	▪ 산업제어시스템 전용 패치관리 서버

본 사업 선정 솔루션

한전KDN㈜

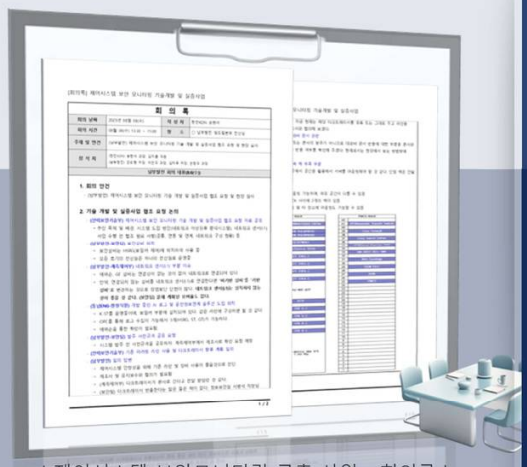
국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

02 보안 모니터링 구축 모델 설계 단계

발전 제어시스템 시설 확인, 보안 모니터링 대상 자산 및 트래픽 수집 방안 협의

남부 발전

발전 제어시스템 도입기관 담당부서 실무협의 시행



| 제어시스템 보안모니터링 구축 사업 - 회의록 | (남부발전)

주요 협의 내용 Verification

주제 및 안건

- 제어시스템 보안 모니터링 구축 사업 협조 요청 및 제반 환경 논의

회의 시행

- 장소 및 일시 : 남부발전 빛드림본부 / 2025. 08. 06
- 주요 참석자 : 한전KDN, 남부발전, 동남ENG

실무 협의 사항

- 제어시스템 보안 모니터링 구축 사업을 위한 협조요청 및 현장실사
- 제어 트래픽 및 자산 정보 수집 방안 협의
  - OPC를 통한 HRSG, ST, GT 로그 수집 가능 여부 확인
  - 기운영 ICS(Darktrace) 설비 라인을 통한 트래픽 수집 방안 확인
- 도입 설비 세부 기능 규격 등에 대한 공유 요청 확인
- 보안 모니터링을 위한 도입 설비 내역 확정
- 데이터 수집 지점 및 연계 방안 확정

한전KDN 주

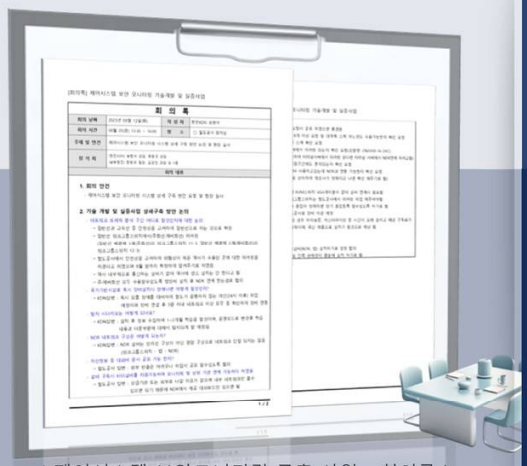
국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

02 보안 모니터링 구축 모델 설계 단계

철도 제어시스템 시설 확인, 보안 모니터링 대상 자산 및 트래픽 수집 방안 협의

철도 공사

철도 제어시스템 도입기관 담당부서 실무협의 시행



| 제어시스템 보안모니터링 구축 사업 - 회의록 | (철도 공사)

주요 협의 내용 Verification

주제 및 안건

- 제어시스템 보안 모니터링 상세 구축 방안 논의 및 현장 실사

회의 시행

- 장소 및 일시 : 철도공사 회의실 / 2025. 08. 12
- 주요 참석자 : 한전KDN, 철도공사

실무 협의 사항

- 제어시스템 보안 모니터링 구축 사업을 위한 협조요청 및 제반환경 논의
  제어 트래픽 및 자산 정보 수집 방안 협의 (일반선 대상 확인)
- 기운영 SIEM과 보안 모니터링 시스템 연동 요청 확인
- 위협 탐지 시나리오 적용 방안, 시스템 네트워크 구성 방안 확인
  (네트워크 단절 없이 구성을 위한 네트워크 TAP 장비 검토)
- 보안 모니터링을 위한 도입 설비 내역
- 데이터 수집 지점 및 연계 방안 확정

한전KDN 주

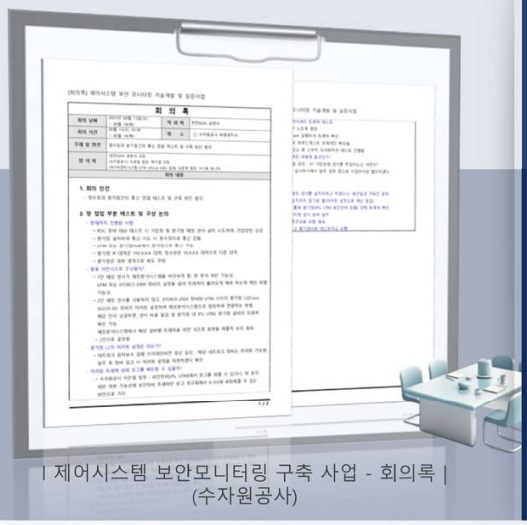
국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

02 보안 모니터링 구축 모델 설계 단계

수처리시설 보안 모니터링 실증 결과 활용, 데이터 연계 및 구성 방안 협의

수자원공사

수처리 제어시스템 도입기관 담당부서 실무협의 시행



| 제어시스템 보안모니터링 구축 사업 - 회의록 |
(수자원공사)

주요 협의 내용 Verification

주제 및 안건

- 정수장과 분기점 간의 통신 연결 테스트 및 구축 방안 협의

회의 시행

- 장소 및 일시 : 수자원공사 보령권지사 / 2025. 08. 13 ~ 08. 14
- 주요 참석자 : 한전KDN, 수자원공사, 설비유지보수사

실무 협의 사항

- 기존 실증 내용 확인, 분기점/정수장 네트워크 구성 정보 확인
- 네트워크 센서(L1) 활용한 자산 정보 수집 방안 협의
  제어 트래픽 전송 방안 및 보안설비 등의 로그 수집 방안 협의
  (분기점 미러링을 통해 접점 구간 보안 설비 등 전체 트래픽 포함)
- 보안 모니터링을 위한 도입 설비 내역 확정
- 데이터 수집 지점 및 연계 방안 확정

한전KDN 주

국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

03 보안 모니터링 구축 단계

보안 모니터링 가이드라인에 따른 본 사업 시스템 구축 방안 확보

2단계 보안 모니터링 구축 Guide

OT SOC 구축 목표, 기능, 역할	보안 모니터링 실증 목표의 구체적 설정 제어시스템 보안운영 목표, 역할, 기능 정의
OT SOC 구성요소	제어DMZ, 네트워크 세그먼테이션, 데이터 수집, 분석 및 탐지 계층 등 주요 구성요소 분석 · 설계
수집 지점 선정	OT환경의 로그, 트래픽, 데이터, 이벤트 등 실시간 수집을 위한 수집 지점 선정
주요 기술 아키텍처	네트워크 분리, 접근제어, 비정상/이상행위 모니터링, 원격접속 제어 등 기술적 요소 활용
기술솔루션 배포 설치 및 검증	제어시스템 환경에 적합한 모니터링 솔루션 선정 및 배치, 기능/성능/운영 테스트
위협 시나리오 작성	보안 위협 시나리오(일반적 위협, IT-OT연계 위협 등) 작성, 테스트 및 검증
시각화(대시보드)	실시간 데이터, 경고 및 알림, 통계 및 분석 보고서, 사용자 인터페이스 등 시각화 구현
잔여 위협 및 수명주기 관리 평가	실증 구축 이후 잔여 위협 평가 및 최소화 유지관리를 통해 시스템의 지속적 운영 환경 확보

주요 추진 사항 Action

- 수집 대상 및 기 운영 보안 설비 정보 확인
  - 표준/비표준 제어 프로토콜 (CTC, Modbus 등)
- 도입 기관 특수성, 제어 트래픽 제약사항 반영
  - 남부발전 : HRSG, ST, GT
  - 철도공사 : 일반선 구간
  - 수자원공사 : 분기점, 취·가압장
- 일정 계획, 시스템 설치, 시험 · 검수 및 운영
- 보안 위협 시나리오 작성, 절차에 따른 검증 수행
- 제어 및 보안 담당자 맞춤형 관제 확보
- 전국 단위 유지보수 체계 및 지속적인 기술지원

시스템 구축 이후 단계별 활동을 통해
"보안 모니터링 운영체계 실효성 확보"

한전KDN 주

국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

03 보안 모니터링 구축

시스템 구축 **작업 계획 수립** 및 **제어시스템 모니터링 구축** (남부발전)

남부 발전

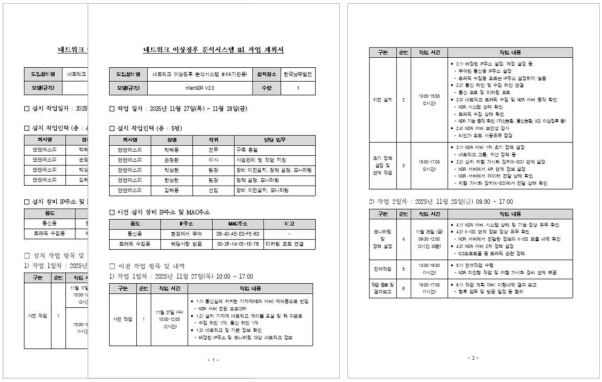
시스템 구축 작업 계획 수립

- 주요 기술 아키텍쳐 적용
- 세부 작업 절차 확보
- 소요 시간 및 자원 반영

- 실무협의 내용 반영
- 사전 보고 후 구축 작업 시행
- 작업계획서 등 산출물 제출

주요 작업 일정 및 내용

- 1차 작업 : HW설치, 장비 설정
- 2차 작업 : TAP 이전설치, 정책 모니터링



| 남부발전 작업계획서 및 설치계획서 |

작업 세부 내역

호환성 검증	**기자재 반입 전 에머슨코리아 장비간 제조사 호환성 검증** (에머슨코리아 Test-Bed 입고 로그수집시스템 검증 협의 진행)
사전 작업	기자재 반입 및 보안성 검사 물리적 설치 환경 구성 (네트워크 케이블 포설 및 랙 마운트)
시스템 설치	**네트워크 트래픽 수집 및 NDR 동작 확인** (시스템 및 트래픽 수집 상태) NDR 서버 초기 정책 설정
연계 및 연동 작업	**위협 가시화 장치(K-ISS)연동 API 개발** (API 연계, 데이터 전달 등) K-ISS 및 NDR 연동 정보 1차 확인
모니터링 및 잔여 작업	NDR, K-ISS 상태/기능 정상 확인 (K-ISS 연계 정보 정상 유무 확인) 잔여 작업 수행 및 주변 환경 정리
작업종료 및 결과보고	종합성능시험 **결과 보고** 향후 업무 및 방문 일정 등 협의

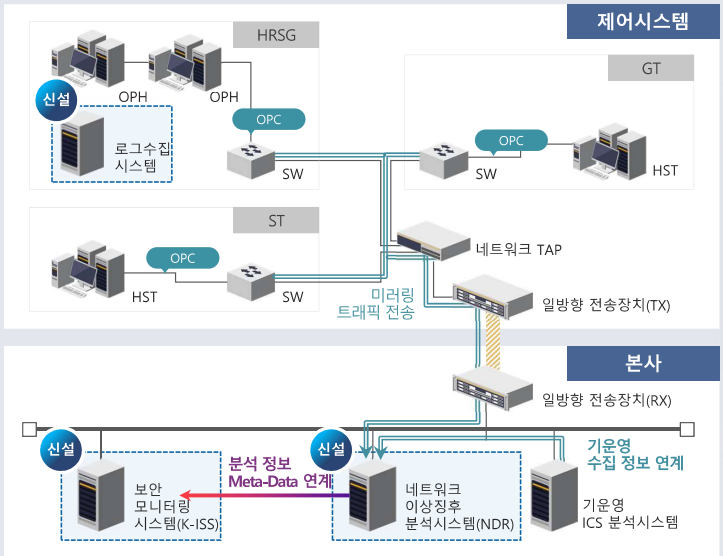
한전KDN|주|

국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

03 보안 모니터링 구축

발전제어설비(HRSG, GT, ST) 시스템 구성 방안

남부 발전 (참조 모델 #2)



세부 구축 결과

설비 내역 및 현장 사진

구 분	설비명	제조사	수량	단위
네트워크 이상징후 분석시스템	nNet NDR	앤앤에스피	1	대
보안모니터링 시스템	K-ISS	한전KDN	1	식
로그수집시스템	SH7-2104E(사H/W)	이슬림코리아	1	식

시스템 구축 주요 내역

- 네트워크 이상징후 분석시스템 (NDR)
- 보안 모니터링 시스템(K-ISS)
- 로그수집시스템 구축

한전KDN|주|

국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

03 보안 모니터링 구축 단계

시스템 구축 작업 계획 수립 및 제어시스템 모니터링 구축 (철도 공사)

철도 공사

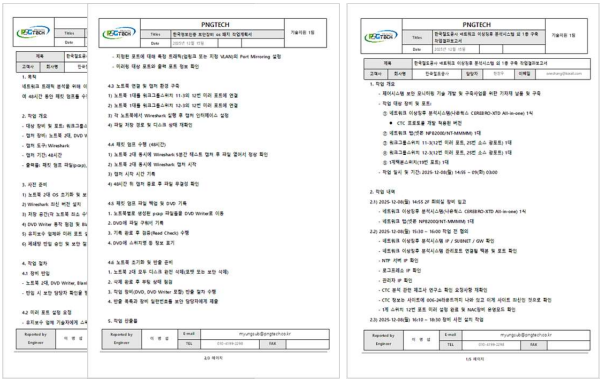
시스템 구축 작업 계획 수립

- 주요 기술 아키텍쳐 적용
- 세부 작업 절차 확보
- 소요 시간 및 자원 반영

- 실무협의 내용 반영
- 사전 보고 후 구축 작업 시행
- 작업계획서 등 산출물 제출

주요 작업 일정 및 내용

- 1차 작업 : 1차 CTC 패킷 수집
- 2차 작업 : 2차 CTC 패킷 수집
- 3차 작업 : 장비설치, 정책설정, 모니터링



| 철도공사 작업계획서 및 변경작업계획서 |

작업 세부 내역

패킷 사전 수집	**패킷 덤프 사전 수집 및 분석** 미러링 트래픽 수집 및 **동작 구조 확인**
사전 작업	CTC 제어 및 COM 통신 프로토콜 검증 전자재 반입 및 보안성 검사 물리적 설치 환경 구성 (네트워크 케이블 포설 및 랙 마운트)
시스템 설치	통신 라인 및 수집 라인 연결 **트래픽 수집 및 NDR 서버, TAP 확인** (시스템 및 트래픽 수집 상태)
초기정책 구성	NDR 서버 1차 초기 정책 설정 네트워크 그룹, 자산 정책 등
모니터링 및 잔여작업	NDR 서버 시스템 상태 정상 확인 **CTC 제어 프로토콜 인식 및 자산 정보 분류 확인 등** 시각동기화 및 Syslog 연계
작업종료 및 결과보고	종합성능시험 **결과 보고** 향후 업무 및 방문 일정 등 협의 (기운영 OT-SIEM 연동 지표 등)

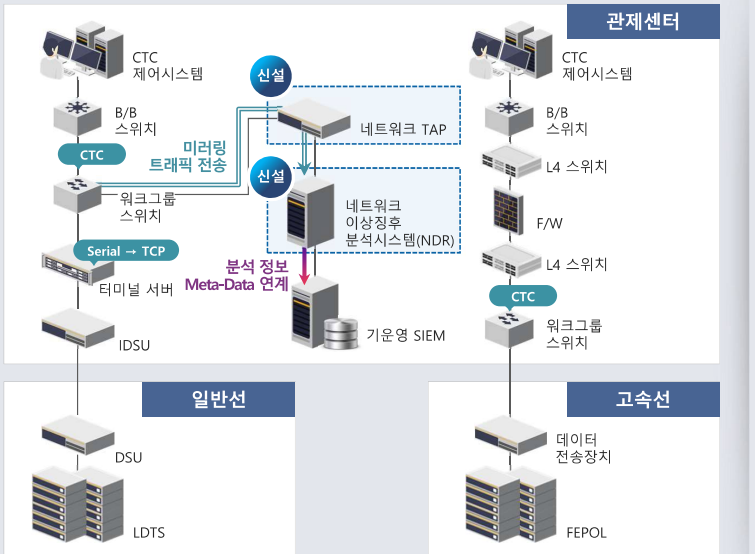
한전KDN|주|

국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

03 보안 모니터링 구축

CTC 제어 프로토콜 시스템 구성 방안

철도 공사 (참조 모델 #1)



세부 구축 결과

설비 내역 및 현장 사진

구 분	설비명	제조사	수량	단위
네트워크 이상징후 분석시스템	CEREBRO-XTD	나온웍스	1	대
네트워크 TAP	NPB2000-NPB	넷몬	1	대

시스템 구축 주요 내역

- 네트워크 이상징후 분석시스템(NDR)
- 네트워크 TAP 구축
- **제어트래픽(CTC) 및 자산 수집/분석 정상 확인**

한전KDN|주|

국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

03 보안 모니터링 구축

시스템 구축 **작업 계획 수립** 및 **제어시스템 모니터링 구축**

수자원공사

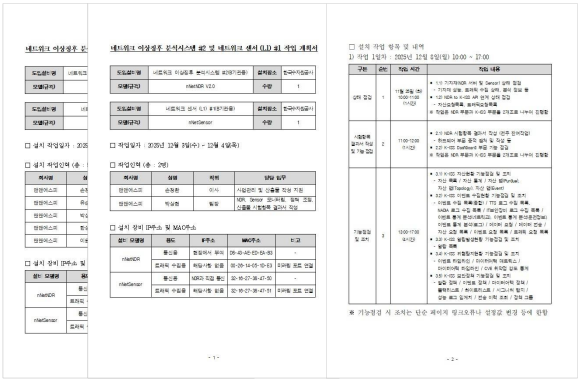
시스템 구축 작업 계획 수립

- 주요 기술 아키텍쳐 적용
- 세부 작업 절차 확보
- 소요 시간 및 자원 반영

- 실무협의 내용 반영
- 사전 보고 후 구축 작업 시행
- 작업계획서 등 산출물 제출

주요 작업 일정 및 내용

- 1차 작업 : 장비 설치, 기본설정
- 2차 작업 : 정책설정, K-ISS API 연동작업
- 3차 작업 : 기 구축 설비 정책 조정, 기능점검



| 수자원공사 작업계획서 및 설치계획서 |

작업 세부 내역

사전 작업	기자재 반입 및 보안성 검사 물리적 설치 환경 구성
시스템 설치	**트래픽 수집 및 NDR, Sensor 동작 확인** 시스템 및 트래픽 수집 상태
초기정책 구성	NDR 서버 초기 정책 설정 Sensor 초기 정책 설정 **네트워크 그룹, 자산 정책 등**
연계 및 연동 작업	위협 가시화 장치(K-ISS) 연계 설정 **API 연계, 데이터 전달** 등 K-ISS 기능 점검 및 조치, 정책 조정 MITRE Attack 정책, AI 모델 기능 등
모니터링 및 잔여 작업	**NDR, K-ISS 상태/기능 정상 확인** (K-ISS 연계 정보 정상 유무 확인) 잔여 작업 수행 및 주변 환경 정리
작업종료 및 결과보고	종합성능시험 **결과 보고** 향후 업무 및 방문 일정 등 협의

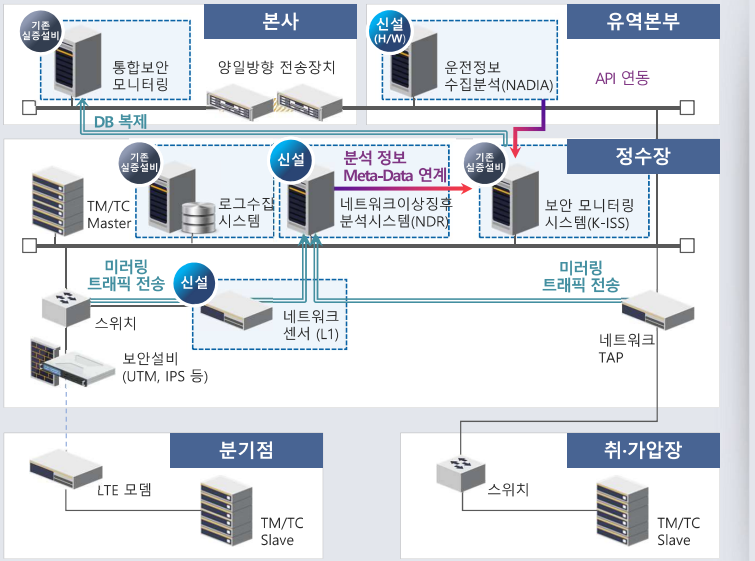
한전KDN|주|

국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

03 보안 모니터링 구축

정수장 제어시스템 세부 구성 방안

수자원공사 (참조 모델 #2)



세부 구축 결과

설비 내역 및 현장 사진

구 분	설비명	제조사	수량	단위
네트워크 이상징후 분석시스템	nNet NDR	앤앤에스피	1	식
네트워크 센서(L1)	nNet Sensor	앤앤에스피	1	식
운전정보 수집분석 시스템	SH7-2104E (서버 H/W)	이슬림코리아	1	대

시스템 구축 주요 내역

- 네트워크 이상징후 분석시스템(NDR)
- 네트워크 센서 L1
- 운전정보수집분석 시스템 구축
- **NDR ~ K-ISS 기능 점검·조치 및 정책 조정**

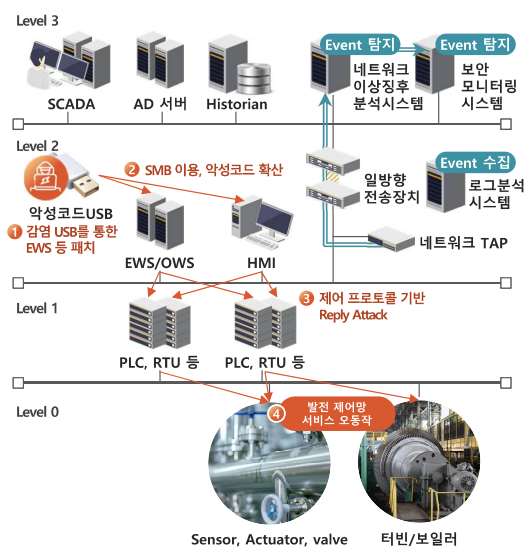
한전KDN|주|

국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

04 보안 모니터링 구축 (기관별 위협 시나리오 - 남부발전)

발전 제어시스템 보안 위협 실증 시나리오 #1

보안위협 시나리오 (공격 흐름도)



발전 제어 시스템 서비스 변조 공격

공격 시나리오

> 악의적 내부 직원 및 작업 편의성을 위한 **악성코드 감염된 USB사용**

보안위협

> EWS, OWS, HMI 등 시스템 운영체제, 소프트웨어 업데이트 미적용
> **악성코드가 포함된 저장매체(USB)를 통한 제어/운전 프로세스 무단 변경**

공격 절차

시나리오 순서		세부 내용
❶		• 유지보수 관계사 직원이 **악성코드가 포함된 이동형 저장매체(USB)** 반입
❷	2-1	• 악성코드가 포함된 이동형 저장매체(USB)를 EWS에 연결
	2-2	• EWS 악성코드 감염 후 **OWS/HMI 등 제어 관리 시스템의 취약점 수집 및 전파**
	2-3	• 취약점을 통한 원격 접속 시도 및 SYSTEM **권한 획득(상승)을 통해 제어권 확보**
	2-4	• 보안장비에 대한 **우회 경로 확보(Reverse Proxy TCP 설정)**
	2-5	• 악성코드 업로드 및 원격 실행
	2-6	• 제어 설비에 대한 네트워크 정보 수집(설비 벤더, 제어 프로토콜)
	2-7	• **제어 프로토콜에 대한 분석을 통해 공격 대상 설정**
❸		• Emerson LLC(Hart Protocol 구문취약점)을 통한 Reply Attack
❹		• **발전 제어 시스템**(설비 센서, 액추에이터, 터빈, 보일러 등) **오동작으로 인한 피해 발생**

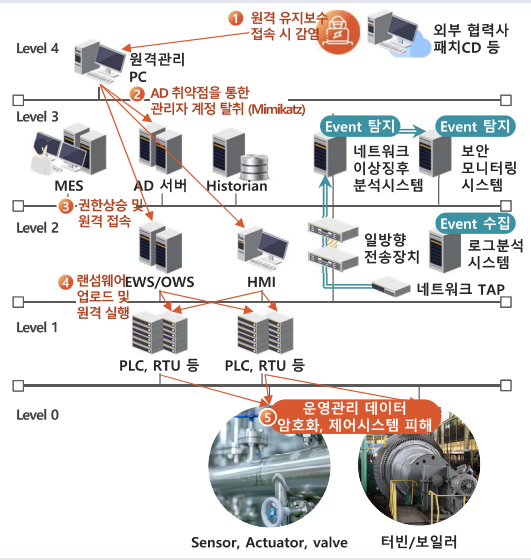
한전KDN|주|

국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

04 보안 모니터링 구축 (기관별 위협 시나리오 - 남부발전)

발전 제어시스템 보안 위협 실증 시나리오 #2

보안위협 시나리오 (공격 흐름도)



랜섬웨어, 제어 설비 암호화로 시스템 서비스 정지

공격 시나리오

> **펌웨어 위해 감염된 CD 사용시** 제어망내 관리PC 통한 전파로 피해 발생

보안위협

> EWS, OWS, HMI 등의 운영체제, 소프트웨어 업데이트 미적용
> 악성코드가 감염된 패치 및 파일 등 원격관리 PC에서 랜섬웨어 발생

공격 절차

시나리오 순서		세부 내용
❶		• **감염된 패치나 CD 사용시 원격관리 PC를 통해 제어망 내부까지 랜섬웨어 전파**
❷	2-1	• 악성코드가 공격 대상에 대한 정보 수집
	2-2	• **Active Directory 데이터베이스 덤프**를 통한 **계정 및 패스워드 탈취(Mimikatz)**
❸	3-1	• 취약점을 통한 원격 접속 시도 및 SYSTEM **권한 획득(상승)을 통해 제어권 확보**
	3-2	• 보안장비에 대한 **우회 경로 확보(Reverse Proxy TCP 설정)**
❹	4-1	• 악성코드 업로드 및 원격 실행
	4-2	• 제어 설비에 대한 네트워크 정보 수집(설비 벤더, 제어 프로토콜)
	4-3	• **EWS, OWS, HMI 등의 제어 설비 관리 시스템의 랜섬웨어를 통한 데이터베이스 암호화**
❺		• 데이터 암호화를 통해 **제어 설비 시스템에 대한 운영 관리 불가, 피해 발생**

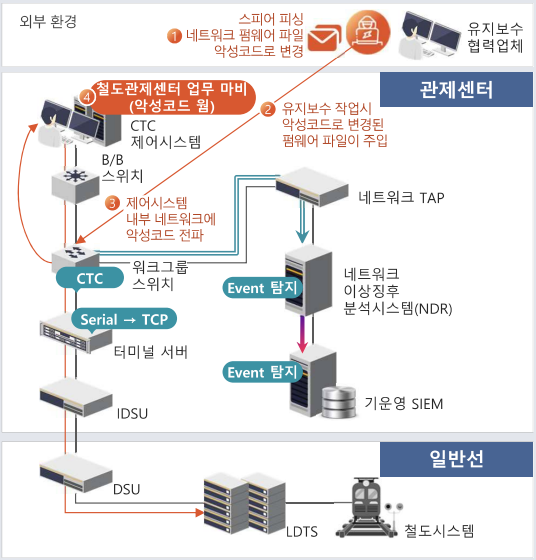
한전KDN|주|

국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

04 보안 모니터링 구축 (기관별 위협 시나리오 - 철도공사)

철도 제어시스템 보안 위협 실증 시나리오 #1

보안위협 시나리오 (공격 흐름도)



유지보수 경로를 악용한 철도관제 내부망 마비

공격 시나리오

> **협력업체 메일(펌웨어)을 수신하여 내부 PC 웜 감염으로** 악성코드 전파

보안위협

> 제어 네트워크 내부망 접속을 통한 정보 수집 및 공격대상 설정
> 스피어 피싱으로 인해 감염된 매체 사용, 제어/운전 프로세스 변경

공격 절차

시나리오 순서		세부 내용
1		• **유지보수사 직원이 스피어 피싱 메일 확인, 첨부 파일 오픈** – 스피어 피싱 기법 : Thread Hijacking / 공격유형 : Reply-Chain Attack • 네트워크 장비 **펌웨어 파일이 악성코드 파일로 대체** – Wannacry 같은 사용자 개입 없이 스스로 전파하는 웜(Worm)의 특성 보유
2	2-1	• 감염된 펌웨어 파일이 네트워크 작업을 위해 한국철도공사 직원용 메일로 전달됨 **(사회공학적 공격 : 피해자는 이미 신뢰관계가 형성된 내용으로 의심없이 파일을 다운로드함)**
	2-2	• 한국철도공사 직원이 네트워크 장비 펌웨어 파일을 정상파일로 인식하고, 내부 작업용 노트북에 옮김
3		• 유지보수사 직원이 네트워크 장비 펌웨어 업그레이드를 위해 **유지보수 노트북을 CTC네트워크에 연결 후 네트워크에 악성코드가 전파** – 제어시스템 망 특성상 오래된 버전의 운영체제 / 애플리케이션을 사용하는 경우 존재 – 중요 파일이 랜섬웨어에 암호화되거나 통신 지연이 발생하는 복합 재난 상황 발생
4		• **철도관제센터 네트워크 망 마비** • 네트워크의 가용성 붕괴

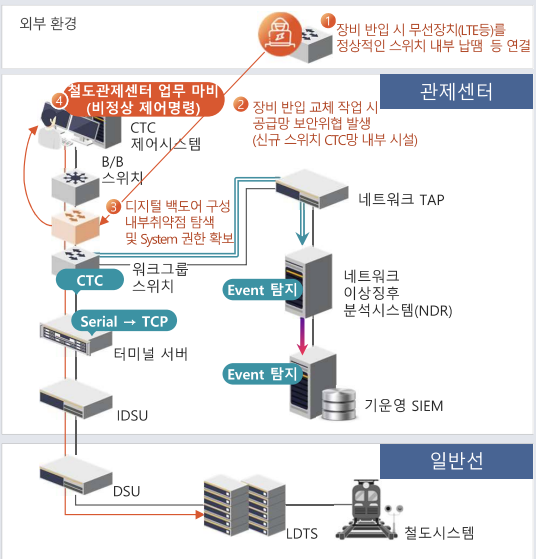
한전KDN㈜

국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

04 보안 모니터링 구축 (기관별 위협 시나리오 - 철도공사)

철도 제어시스템 보안 위협 실증 시나리오 #2

보안위협 시나리오 (공격 흐름도)



네트워크 장치 공급망 공격 (장비 반입 시)

공격 시나리오

> SW 공급망 보안으로 스위치 내부 원격 접속(LTE 등)을 위한 백도어 공격

보안위협

> OT장비·소프트웨어 공급망 공격을 통한 악성코드 사전 삽입
> 감염된 기기 또는 매체 사용, 제어/운전 프로세스 변경

공격 절차

시나리오 순서		세부 내용
1		• **신규 네트워크 스위치 내부에 네트워크 임플란트 침투** (네트워크 장비 반입 시, 기판을 열어보지 않는 관행 악용)
2		• **네트워크 스위치가 CTC제어실 네트워크 내부망(=폐쇄망)에 설치됨** * 현장의 WIPS(무선침입탐지시스템) 탐지 우회
3	3-1	• 공격자가 디지털 뒷문을 이용하여 내부 취약점 탐색 (트래픽을 분석하여 주요 자산(서버) 탐색, 취약 서비스에 대한 정보 수집)
	3-2	• **취약점을 이용한 주요 자산 시스템 권한 획득 및 백도어 설치** * ETERNALBLUE, 디지털 뒷문(백도어) 설치방법 – DOUBLEPULSAR – 스크립트 파일은 장비 재부팅 시에도 자동으로 실행되어 영속성을 유지하도록 조치
4		• 원격지에서 취약점 공격을 통해 제어실 내부 공격 개시 • **악성코드 파일을 서버에 업로드 및 실행** **(악성코드 파일 예시: stuxnet / industroyer 등** OT 시스템을 타겠으로 이상동작을 수행하도록 하는 스크립트 파일) • **철도관제센터 업무 마비 (비정상적 제어명령 발생, HMI화면 오류, 기능상실)**

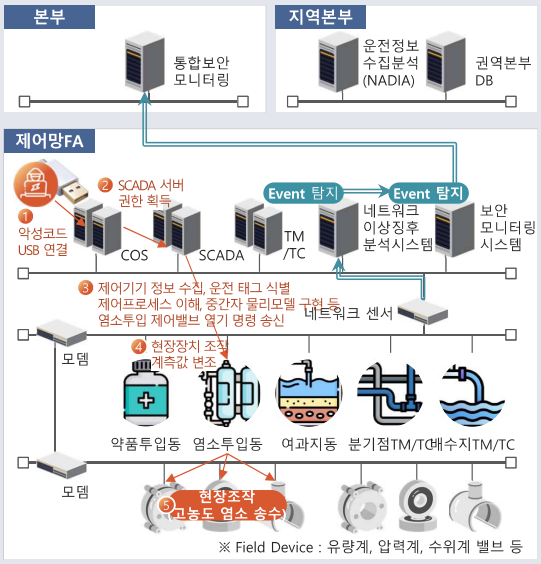
한전KDN㈜

국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

04 보안 모니터링 구축 (기관별 위협 시나리오 - 수자원공사)

수처리 제어시스템 보안 위협 실증 시나리오 #1

보안위협 시나리오 (공격 흐름도)



정수장 염소 과다투입

- 공격 시나리오
  - 악의적 내부 직원 및 작업 편의성을 위한 악성코드 감염된 USB사용
- 보안위협
  - COS, SCADA의 운영체제, 소프트웨어 업데이트 미적용
  - 악성코드가 포함된 저장매체(USB)를 통한 제어/운전 프로세스 무단 변경
- 공격 절차

시나리오 순서		세부 내용
1	1-1	• 관계사 직원이 악성코드가 포함된 이동형 저장매체(USB) 반입
	1-2	• 악성코드가 포함된 이동형 저장매체(USB)를 COS에 연결
2	2-1	• COS 악성코드 감염 후 SCADA 서버로 전파
	2-2	• 악성코드 SCADA 서버 권한 획득(상승)을 통해 제어권 확보
3	3-1	• 제어기기 정보 수집
	3-2	• 염소투입 관련 운전데이터 태그 식별
	3-3	• 운전데이터 기반 염소 제어프로세스 이해
	3-4	• 중간자 물리 모델 구현
4	4-1	• 염소투입 제어밸브 열기 명령 송신
	4-2	• 현장장치(염소투입 제어밸브) 조작에 따른 염소 과다투입/염소 계측값 변조를 통한 공격 은닉
5		• 고농도 염소 송수

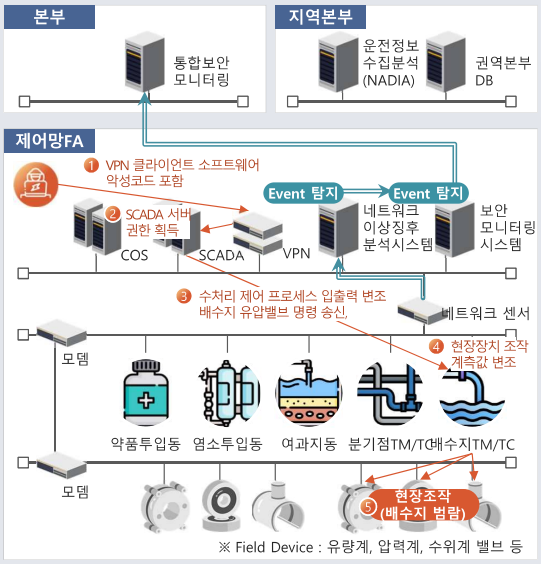
한전KDN|주

국가 핵심 인프라 보안 모니터링 강화 및 이행 현황

04 보안 모니터링 구축 (기관별 위협 시나리오 - 수자원공사)

수처리 제어시스템 보안 위협 실증 시나리오 #2

보안위협 시나리오 (공격 흐름도)



배수지 수위 범람 공격

- 공격 목표
  - VPN 무결성 검증 미적용으로 악성코드 감염되고 제어망 서버 권한 획득
- 보안위협
  - 유무선, 전용회선 등 통신장비 보안설정 오류/미비 (VPN 클라이언트)
  - 감염된 시스템/소프트웨어 설치 및 사용, 제어/운전 프로세스 변경
- 공격 절차

시나리오 순서		세부 내용
1	1-1	• 관계사 직원이 악성코드가 포함된 VPN 클라이언트 소프트웨어를 노트북에 설치 (VPN 클라이언트 프로그램 무결성 검증 미적용) • 유무선, 전용회선 등 통신장비 보안설정 오류/미비
	1-2	정수장 수도제어망(FA) VPN 연결 수행
2	2-1	• 수도제어망(FA) ARP 스캔을 통한 자산 탐색
	2-2	• 식별된 자산(SCADA) 서버를 대상으로 권한획득을 위한 무차별 대입 공격
3		• 권한 획득(상승)을 통해 제어프로세스 변조, 배수지 유입밸브 열기(유출밸브 닫기) 명령 송신
4		• 배수지 현장장치(유량 제어밸브) 조작에 따른 원수 유입 • 배수지 수위 계측값 변조를 통한 공격 은닉
5		• 현장장치(유입/유출 밸브) 조작에 따른 배수지 범람 발생

한전KDN|주

CHAPTER Ⅰ CHAPTER Ⅱ CHAPTER Ⅲ

Ⅲ

국가 핵심 인프라 보안 모니터링 시스템 강화

향후 계획

1 | 기관 확대 적용 방안

한전KDN㈜

01 기관 확대 적용 방안

지역단위의 제어시스템 보안 모니터링 구축 완료 후 기관/조직 전체로 확대

3단계 기관 확대 적용 방안

K water 한국수자원공사

보안 관제대상 확대
- 유역본부 4개, 정수장 12개소

통합 모니터링체계
- 정수장(현장) → 유역본부 → 본사 관제센터 통합 모니터링 체계 구현

KORAIL

보안 관제대상 확대
- 1차 : 일반선 일부 → 일반선 전체
- 2차 : 고속선 일부 → 고속선 전체

통합 모니터링체계
- 철도통합관제센터(구로)에서 CTC 제어시스템에 대한 통합모니터링 체계 구현

한국남부발전㈜

보안 관제대상 확대
- 빛드림본부 → 하동발전소 → 남부발전 사업소 점진적 확대

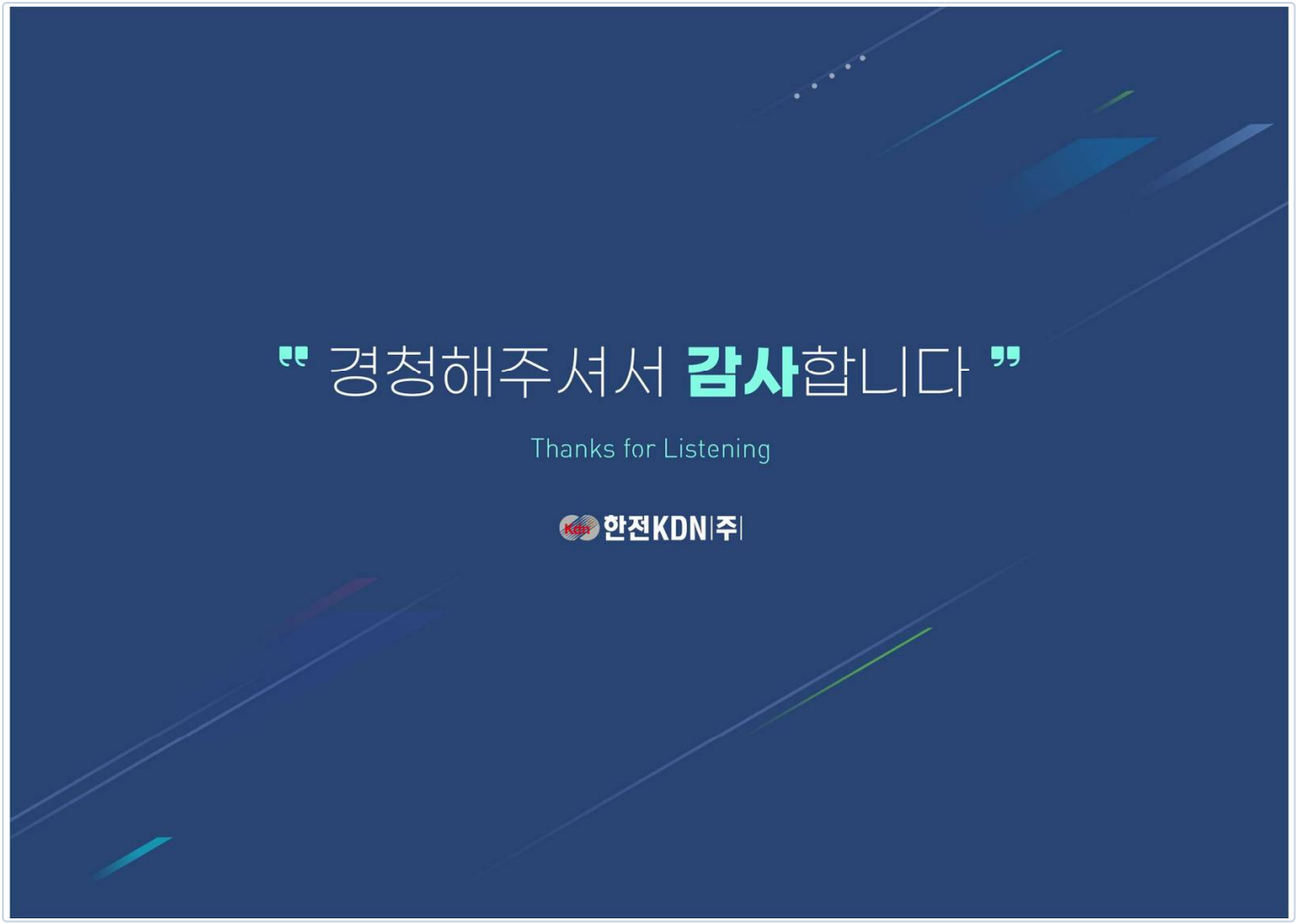
통합 모니터링체계
- 남부발전 빛드림본부에서 사업소 제어시스템에 대한 통합모니터링 체계 구현

자산 관리체계 고도화
- 자산의 추가 변동사항 실시간 반영체계 확보
- 네트워크 및 물리적 자산의 상호 의존 관계 분석

데이터 수집·분석 확대
- 비-에이전트, 네트워크 미러링, 운전정보(Tag) API 연동 방식 적용
- DPI 탐지 및 분석 기능 개선

보안 모니터링 체계 확보
- 제어시스템 데이터 분석, 위협 이벤트 정보체계 구현
- 권역별 탐지 결과 보안 모니터링 체계 확보

통합 모니터링 기술 적용
- 보안 표준 프레임워크 적용
- 데이터 상관분석을 통한 정교한 위협탐지체계 구현


" 경청해주셔서 감사합니다 "
Thanks for Listening
한전KDN|주|

07

PRESENTATION

16:55–17:20

2026. 10. 28.(수)

2026 한국원자력학회 추계학술발표회 · 원자력 사이버보안 워크숍

원자력시설 사이버보안 규제 변화, 이행 현황과 과제 — 디지털 I&C 시대, 대형원전에서 SMR·AR까지

원전 사이버보안 관제를 위한 제어기 수준의 보안 모니터링 기술 연구 현황

손광섭

한국원자력연구원 (KAERI)

KOREA ATOMIC ENERGY RESEARCH INSTITUTE

원자력시설 사이버보안 규제 변화, 이행 현황과 과제

- 디지털 I&C 시대, 대형원전에서 SMR/AR까지 -

원전 사이버보안 관제를 위한 제어기 수준의 보안 모니터링 기술 연구 현황

손광섭 (보안기술연구실, KAERI)

Korea Atomic Energy Research Institute

A nuclear research institute
reshaping the future based on
peoples trust

KAERI
Korea Atomic Energy Research Institute

CONTENTS

01 보안관제 기술 및 규제 현황
02 APR1400 대상 NIDS
03 APR1400 대상 HIDS-MTP
04 보안조치기반 사이버리스크 정적 평가 모델
05 결론

2026 추계 워크숍 · 원자력시설 사이버보안 규제 변화, 이행 현황과 과제

01 보안관제 기술 및 규제 현황

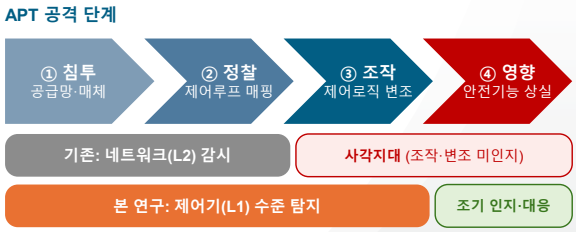
□ 국내·외 원전 포함 주요기반시설 대상 사이버위협 증대

- 시설에 대한 직접적인 사이버공격 뿐 아니라 공급망을 통한 공격도 확대되고 있음.

□ 사이버위협 기술의 발전으로 인한 새로운 위협 유형 증대

- ICS(Industrial Control System) 대상 사이버위협은 수년에 걸쳐 준비되고 지속적으로 시도되는 등 매우 정교하고 지능적으로 발전(APT, Advanced Persistent Threat)
- 제어 시스템 대상의 센서신호/제어로직 조작과 HMI(Human Machine Interface) 정보 변조 등 지능적이고 복합적인 사이버공격 시도
- IT 보안 기술의 도입만으로는 ICS 대상의 지능적인 사이버공격 탐지에 한계 → 원전 운영환경 및 계측제어시스템에 특화된 탐지기술 필요

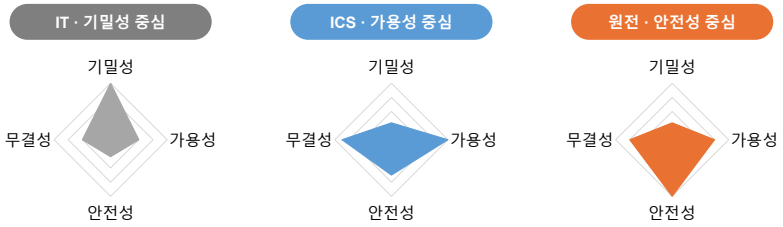
반시설 사이버 위협 사건>



<APT 공격 단계별 탐지 가시성>

01 보안관제 기술 및 규제 현황

원전 운영환경 특성과 보안관제 요건



구분	IT	ICS	원전
수명	3~5년	20년 이상	60년 이상
패치 적용	정기·계획적	느리고 드묾	불가한 경우 존재
실시간성	지연 허용	매우 중요	매우 중요 + 인허가
보안시험·변경	정기·의무	비정기	오버홀 시, 인허가 연계

<IT / ICS / 원전 운영환경 비교 (보안 우선순위는 개념도)>

∴ 원전 보안관제 설계 원칙

1. **기존 계통 무변경**
   제어기 SW·설계 변경 없이 → 인허가 부담 최소
2. **단방향·수동형 수집**
   미러링·탭·데이터다이오드 → 안전기능 간섭 배제
3. **패치 대신 상시 탐지**
   패치 불가 자산의 보상 통제로서 지속 모니터링
4. **안전 영향 중심 판단**
   경보를 CDA 상태·플랜트 리스크로 환산

01 보안관제 기술 및 규제 현황

ICS 위협 동향과 보안관제 기술 동향

☐ OT/ICS 위협 동향 (Dragos, 2026 OT Year in Review)

26 — **OT 위협그룹 추적**
2025년 활동 11개, 신규 3개 그룹 식별

119 — **산업분야 대상 랜섬웨어 그룹**
2024년 80개 → 2025년 119개 (49%↑)

42일 — **OT 랜섬웨어 평균 체류시간**
OT 가시성 확보 조직은 평균 5일 내 봉쇄

25% — **ICS 취약점 CVSS 점수 오류**
권고의 26%는 패치·완화책 없음

공격자는 HMI·인버터·계측모듈을 스캔해 제어루프 전체를 매핑 → 정찰에서 물리적 영향 단계로 이동

☐ ICS 보안관제(모니터링) 기술 동향

자산 가시성·형상관리 CISA 등 공동「OT 자산 인벤토리 가이드」(2025.8)	L2–L3
수동형 산업 프로토콜 DPI Modbus·DNP3·IEC 61850·S7 등 해석, 미러링/탭 수집	L2
화이트리스트·이상행위 탐지 정형화된 OT 통신 특성 학습, 시그니처 병행	L2
공정 인지형(Process-aware) 탐지 제어로직·플랜트 모델 기반 L0/L1 감시 – 연구단계	L0–L1
위협 분석·대응 연계 MITRE ATT&CK for ICS, SIEM/SOAR 상관분석	전 계층

상용 OT 관제 = 네트워크(L2~L3) 중심
원전 안전계통 전용 프로토콜(HR-SDL/SDN)과 제어기(L1) 내부 상태는 사각지대
→ **제어기 수준 모니터링 필요**

출처: Dragos 2026 OT Cybersecurity Year in Review(2026.2), CISA 외「Foundations for OT Cybersecurity: Asset Inventory Guidance」(2025.8)

5

바른기술

01 보안관제 기술 및 규제 현황

국외 원자력 사이버보안 규제·표준 동향

구분	주요 문서	보안관제 관련 핵심 요구
미국 NRC	10 CFR 73.54, RG 5.71 Rev.1 (2023)	지속적 모니터링·평가, 취약점 관리, 감사기록 검토, 사건 대응 및 사이버리스크 평가 강화
미국 산업계	NEI 08-09, NEI 13-10 Rev.7	결과 기반(Consequence-based) CDA 분류, 취약점 조치 기준(CVSS) 등 이행 지침
미국 SMR/AR	10 CFR Part 53 최종규칙 (2026.3), §73.110	기술 중립·리스크 정보 활용, 사이버보안 등급화(graded approach), 결과 기반 성능요건, 원격 운영·소수 인력 고려
IAEA	NSS 17-T Rev.1 (2021), NSS 33-T (2021)	생애주기 컴퓨터보안, 보안등급(Security Level)별 통제, I&C 시스템 지속 감시
IEC	IEC 62645 (2019), IEC 63096 (2020), IEC 62859	원전 I&C 보안 프로그램·보안통제 요건, 안전-보안 조화
범산업 ICS	NIST SP 800-82 Rev.3 (2023), IEC 62443	OT 보안 아키텍처, 존·컨듀잇, 모니터링·탐지 및 대응

공통 키워드: 지속적 모니터링 | 등급화·결과 기반 | 리스크 정보 활용 | 생애주기 보안 내재화 | 자동화

SMR/AR 시사점 디지털 I&C 전면화 + 소수 인력·원격 운영 → 사람이 아닌 **시스템이 상시 감시**해야 하며, 탐지 결과를 **안전 영향(결과)으로 해석**하는 능력 필요

6

바른기술

01 보안관제 기술 및 규제 현황

□ **미국 NRC의 RG 5.71 개정(2023)**

- Rev.1은 지속적인 모니터링, 사이버리스크 평가 강화 및 주기적인 사이버보안 프로그램 검토 및 변경 관리 강조

□ **IAEA 문서 및 IEC 표준 등**

- 생애주기 동안 보안 내재화를 강조하고 지속적인 사이버위협 모니터링 및 평가를 통해 사이버위협으로 인한 리스크 수준을 허용 가능한 한도 내로 유지해야 함을 강조

□ **국내 규제 요건(KINAC/RS-015) 및 국정원 지침(국가원자력시설 생애주기별 보안 내재화 지침:2025년부터 적용 중)**

- 원자력 시설의 계획, 설계, 구현, 시험, 운영, 해체 등 생애주기별로 사이버위협을 분석하고 보안 모니터링 체계를 확립하며 공급망 보안 등 사이버보안 관련 사항을 제시

국정원 지침(제어시스템 보안 모니터링 구축 가이드라인)

니너지, 상하수도 시설 등)으로 사이버위협이 빠르게

상시적인 모니터링 및 신속한 대응체계 구축에 대한 가이드라인 제시

링 체계 구축 계획서 제출 필요

국가기반시설 사이버공격 심화
각기관에 '보안 모니터링' 지침

정부가 교통·에너지·상하수도 시설 등 주요
이 심화되고 있다며 이에 대한 경계령을 내렸
회적 혼란이 불가피한 만큼 보안 지침 준수를
량 강화를 촉구했다.

23일 정보기술(IT) 업계에 따르면 국가정보원
생, 지역난방, 스마트도시 등 제어 시스템 관
템을 구축할 수 있도록 신규 가이드라인을 제
축 계획을 제출할 것으로 알려졌다.

국정원, 핵심 인프라 공공기관에 '보안 모니터링 시스템 강화' 요청했다.

[시사월드=by 박효숙]=국가정보원은 고도화하는 사이버 위협에 대응하고자 발전, 교통 등 사회 핵심 인프라를 관리하는 공공기관에 보안 모니터링 시스템 강화를 요청했다.

6월 23일 정보통신기술(ICT) 업계에 따르면, 국정원은 지난달 이들 기관이 자체 보안 모니터링 체계를 구축할 수 있도록 돕는 가이드라인을 배포했다.

국정원은 가이드라인 마련 배경에 대해 "고도화·지능화된 사이버 위협 세력이 발전·교통 등 주요 기반 시설을 노리고 있다"며 "선제 대응을 위해 제어 시스템 보안 강화가 필요하다"고 설명했다. 이어서 인프라 제어를 담당하는 기관들이 인터넷과 분리된 자체 보안 모니터링 체계를 안전하게 구축하고 운영할 수 있도록 가이드라인을 제작했다고 덧붙였다.

이 가이드라인에 따라 해당 기관들은 연내 자체 보안 모니터링 체계 구축 계획을 제출할 것으로 알려졌다.

<국정원 "제어시스템 보안 모니터링 구축 가이드라인" 배포 관련 언론 기사(2025.06.24)>

01 보안관제 기술 및 규제 현황

미국 원전 사이버보안 모범 사례와 시사점 (KINAC, 2025)

- NEI 사이버보안 이행 워크숍(2025.3, 인디애나폴리스) 및 NRC 사이버보안 검사 참관(2025.6, Seabrook 원전)을 통해 수집한 이행 사례

위협·취약점 관리 자동화	휴대용 저장매체 관리 자동화	로그 관리 자동화(SIEM)
• CDA 형상정보 자동 수집 → 자산·형상관리 시스템 등록 • 외부 업체 취약점 스캔, CVE 대조 후 설비 담당자 통보(60일 내 조치) • NEI 08-09 Addendum 5 기준 조치: 일반 CDA CVSS ≥ 7.0, 경계 디바이스 CVSS ≥ 4.0	• 휴대용 매체·유지보수 노트북은 별도 캐비닛 보관, 사전 승인 출입카드로만 접근 • 키오스크(20종 백신) 검사로 데이터 이동 통제 • 무결성 유지를 위해 업데이트 기간에만 제한적 인터넷 연결	• 주기적(분기 1회) 로그 분석을 위해 로그를 중앙 수집·상관분석 • 방화벽·IDS/IPS·서버 로그 통합, 경보·시각화 • 특이 로그 발생 시 사건 대응을 위한 사내 연락체계 자동화(문자 발송 등)

시사점

- 핵심은 인적 오류 최소화와 업무 자동화 — 규제 요건(RG 5.71 Rev.1, KINAC/RS-015 Rev.02)을 도구로 상시 이행
- 그러나 자동화의 대상은 **IT·네트워크 장비의 로그** 중심 — 로그 생성 기능이 제한된 **제어기(PLC/DCS)·안전계통**은 사각지대
- 기존 계통 변경 없이 단방향 수동형 수집으로 제어기 수준 상태·행위를 감시하는 보안관제 기술 필요 → 본 연구

출처: 박포일, 「미국 사이버보안 모범 사례」, 2025 원자력안전규제정보회의, KINAC

01 보안관제 기술 및 규제 현황

□ 국내외 Level 1~2 대상 사이버위협 탐지 기술은 개발 중이거나 전무

02 APR1400 대상 NIDS

APR1400 대상 보안관제 시스템의 위협 탐지 범위 및 개념

□ **NIDS (Network-based Intrusion Detection System)**

- **Network Protocol-based**
  - 비안전통신망: Ethernet 기반의 IPS (Information Process System) Network Packet의 위협 탐지
    - 지식 기반: 기존에 알려진 악성코드 등의 Signature 기반 위협 탐지
    - 행위 기반: IPS Network Flow 기반 위협 탐지 (DoS 공격, Brute Force 공격 등)
  - 안전통신망: Fieldbus 기반의 HR-SDL, HR-SDN Packet의 비정상 행위 탐지
    - Block, Format, Station No., Index No., Timeout 등에 발생하는 비정상 행위 탐지
- **Process-Based**
  - Logic-based

SF-CCS의 트립 및 개시로직 활용 위협 탐지

S, PPCS, SBCS, RPCS, P-CCS의 공정로직 활용 위협 탐지

  - Plant model-based

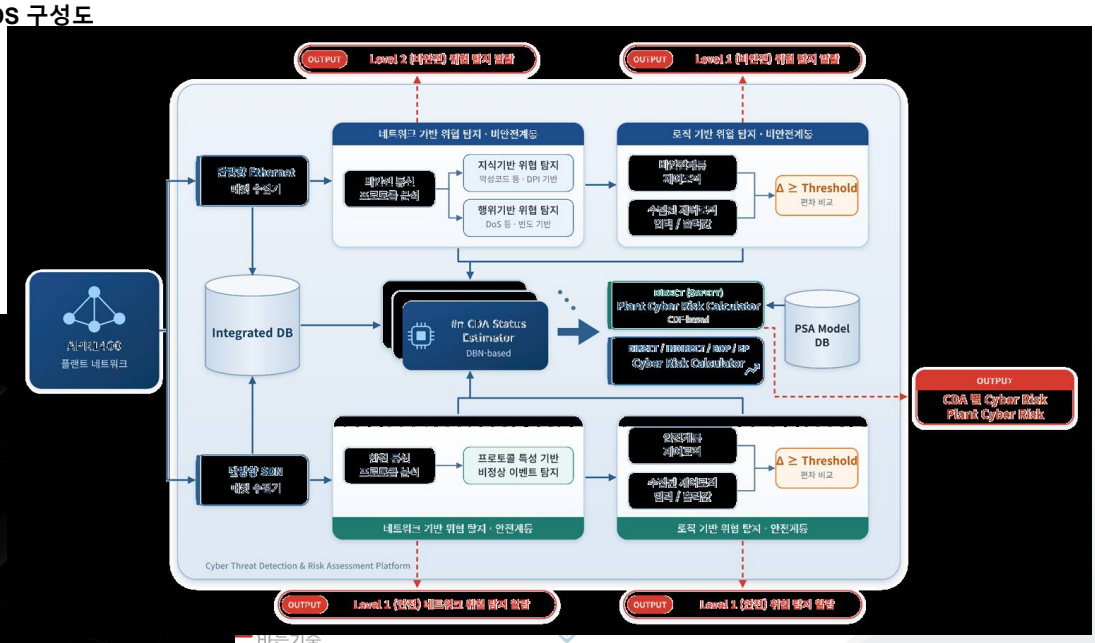
활용 센서 신호 위협 탐지

HIDS (Host-based Intrusion Detection System)

재되는 ****에 대한 프로세스, 파일 변경, 시스템 파일 등 감시

02 APR1400 대상 NIDS

□ **NIDS 구성도**

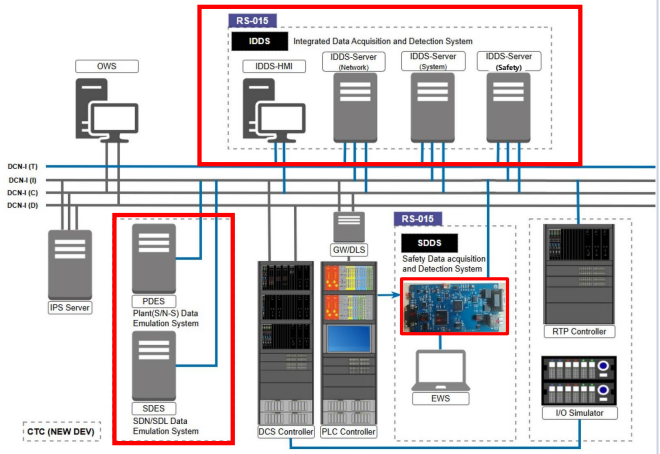


02 APR1400 대상 NIDS

□ **APR1400 기반 사이버보안 테스트베드 구축**

- 기존 장비 활용(PPS/ESF-CCS/DCS/IPS 등)
- APR1400과 유사한 환경을 모사하기 위해
  - PDES(Plant Data Emulation System): DCN 모사
  - SDES(SDN Data Emulation System): 안전망 모사

E: KAERI(보안기술연구실)>

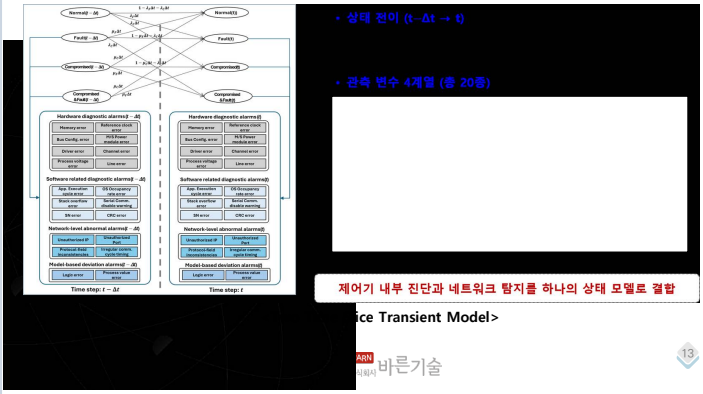


<사이버보안 테스트베드 구축>

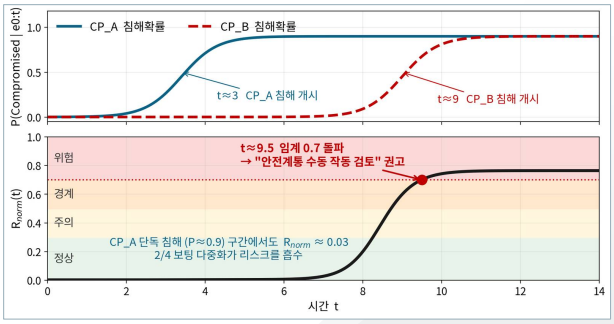
02 APR1400 대상 NIDS

□ 공정기반 탐지 엔진(안전계통 + 비안전계통)

- 안전계통: **단방향 데이터 취득 장치 개발**: SDN-to-Ethernet Converter(단방향,SDOQ-E)
- HR-SDN **프로토콜**(안전계통 네트워크) **특성 기반 위협 탐지**
- 안전계통(RPS/ESF-CCS)과 비안전계통(PLCS/PPCS/SBCS/FWCS/CVCS) **로직 기반 위협 탐지**
- PLC(안전계통)와 DCS(비안전계통)의 상태, 진단 데이터 및 위협 이벤트를 활용하여 **DBN을 통해 실시간 제어기 상태**(Normal/Fault/Compromised) 추정(**CDA 리스크**)
- 제어기의 위협확률이 PSA 모델의 해당 모듈의 조건부확률값으로 입력되어 CDF 재계산하여 **CDF 증가량을 리스크**로 표현(**Plant 리스크**)



ice Transient Model>

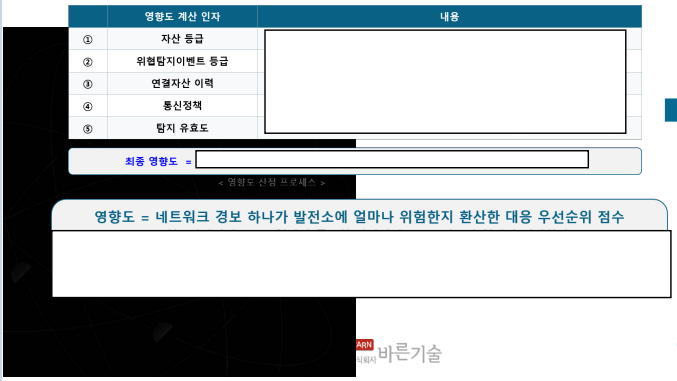


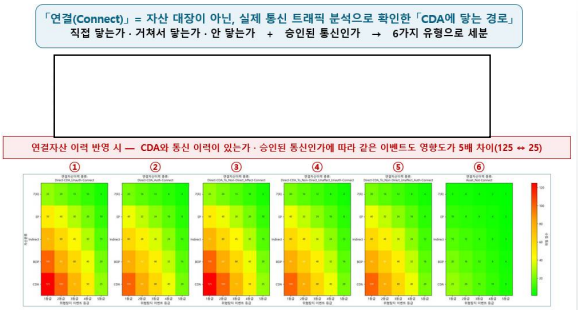
<CDA Risk와 Plant Risk>

02 APR1400 대상 NIDS

□ 네트워크 기반 탐지엔진

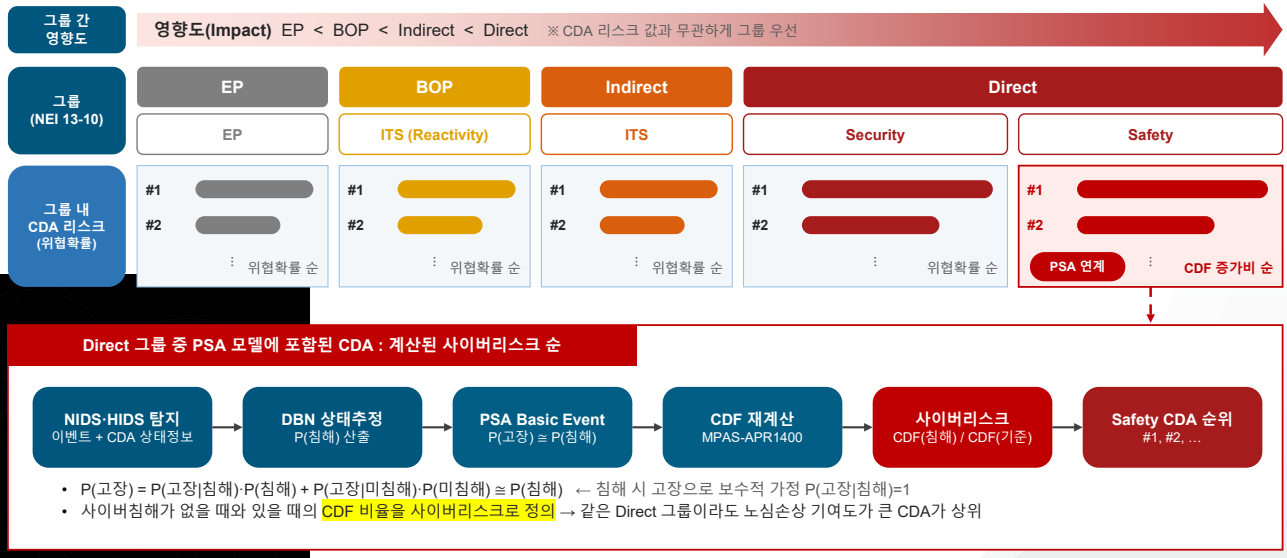
- APR1400 통신 트래픽 분석결과를 토대로 탐지 규칙 개발 및 지식 기반/행위 기반으로 유효한 위협 분류
- **최근 인프라사이버공격 관련 탐지규칙** 반영 (OS-VXworks, BlackEnergy, EternalBlue, etc)
- 표준 프로토콜을 사용하지 않는 통신 형태에 따른 탐지규칙 개발 및 튜닝
- 기존 레거시 네트워크 기반 위협탐지 엔진에서 탐지하지 못하는 **ARP 프로토콜 사용 위협 탐지**
- Purdue 모델 기준 **DCS 로직 전송 등의 IP 통신**에 대한 모니터링과 탐지
- 엔터프라이즈 정보보안 솔루션에서 사용 중인 탐지 규칙 호환, 위협 탐지를 가능하도록 하는 **OpenSource 탐지규칙 약1.5만개 반영**





02 APR1400 대상 NIDS

□ 탐지 결과 기반 **전체 CDA 리스크 순위화** : 그룹 간 영향도 → 그룹 내 CDA 리스크 → PSA 연계 사이버리스크



02 APR1400 대상 NIDS

적용 대상 및 시작품

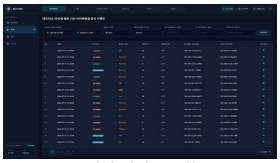
□ **적용대상: 보안관제 시스템**

- 기존 원전 시스템에 영향 없이 단방향 데이터 통신장치(미러링, 탭 등)를 활용
- 실시간 사이버위협 탐지 및 사이버리스크를 정량적으로 평가하는 시스템
- 기존 국내 원전에는 없는 시스템으로 신한울 3&4호기부터 한수원 건설처와 두산에너빌리티를 중심으로 보안관제 시스템 설계 중
- 두산에너빌리티는 Level 2 (네트워크: IPS 통신망) 중심으로 보안관제를 [redacted]침(제어시스템 보안 모니터링 구축 가이드 Level 1(제어기)의 보안관제까지 고려해야 함.
- [redacted] 건설처 및 두산에너빌리티에 소개·시연한 [redacted]너빌리티는 Level 1(제어기) 및 일부 Level 신한울 3&4호기에 반영하는 방안을 추진 중임.

<사이버위협 탐지 및 대응 시스템 시작품>

<통합관제 대시보드>

<MITRE ATT&CK ICS 기반 위협 분석>


<탐지 이벤트 조회>

<공정기반 대시보드>

<스위치 상태>

<공정기반 이벤트 조회 및 CDA 상태>

02 APR1400 대상 NIDS

국내외 기존기술 대비

구분	기존 기술(국내/국외)	본 과제
탐지 계층	Level 2(네트워크) 단일 계층	Level 1(제어기) + Level 2(네트워크) + MTP 호스트(HIDS) 다계층
탐지 원리	시그니처·트래픽 이상행위	설계기반 공정지식(RPS/ESF-CCS 트립·개시로직, DCS 제어로직) 및 플랜트 모델(State Estimator) 기반 탐지 추가
안전계통 대상	전용 프로토콜 미지원, 안전계통 제외	HR-SDL/SDN 프로토콜 해석 및 POSAFE-Q 기반 안전계통 탐지, 단방향 수집으로 안전영향 배제
[redacted]	경보 발생에 한정	DBN 기반 CDA 상태추정(정상/고장/침해/고장&침해) → PSA 연계 실시간 플랜트 리스크(CDF 증가율) 산출
[redacted]	[redacted]터 또는 일반 ICS	APR1400 실장비(POSAFE-Q·MTP·DCS) 테스트베드, 통합 탐지율 94.2%(목표 90%), TTA V&V 2회
[redacted]	외산 솔루션 의존	설계사·운영사·기기제작사 협조 기반 국산 독자기술, 기술이전(HIDS) 및 신한울 3·4호기 Level 1 및 일부 Level 2 반영 추진

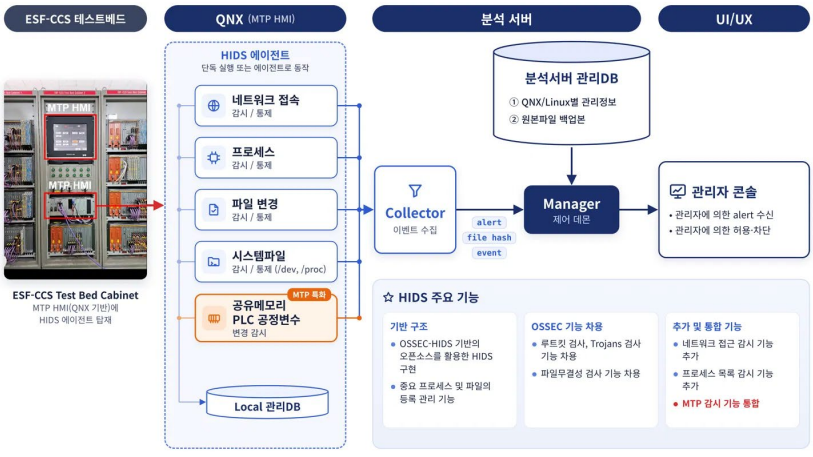
[redacted]

17

03 APR1400 대상 HIDS-MTP

☐ HIDS 개발

- 안전계통 MTP 운영체제인 QNX에 탑재되는 실시간 탐지엔진 개발
  - 네트워크 접속·프로세스·파일변경·시스템파일 감시/통제 및 공유메모리 PLC 공정변수 변경 실시간 감시
  - 기존 MTP 응용 프로그램 Task에 영향을 주지 않고 시스템 부하율 60% 이내로 최적화



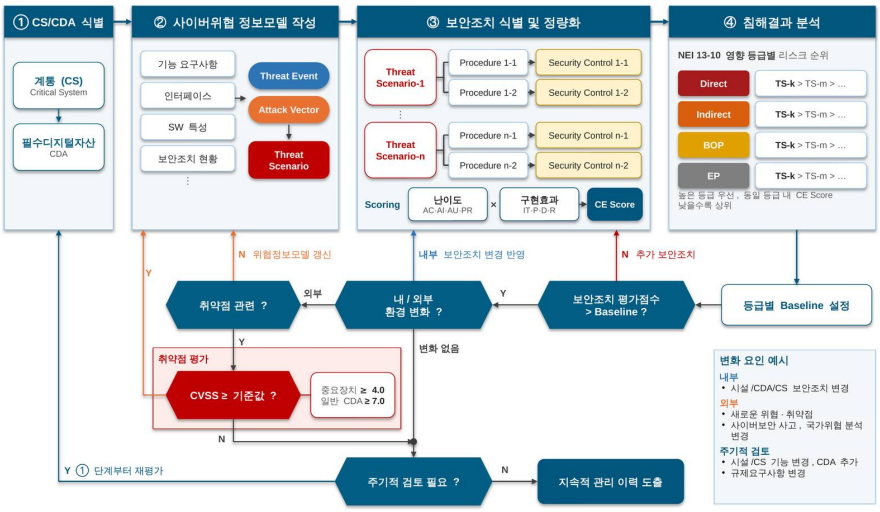
[redacted]

18

04 보안조치 기반 정적 사이버리스크 평가 모델

□ 보안조치 기반 정적 사이버리스크 평가 모델 프레임

- Cyber Risk = F(CDA에 보안조치 평가, 침해영향 정도, CDF 영향 정도)

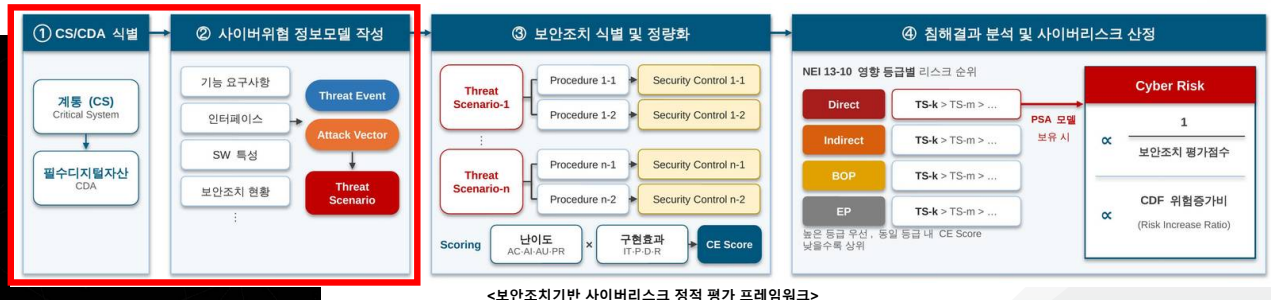


<보안조치기반 사이버리스크 정적 평가 프레임워크>

04 CDA 보안조치 기반 정적 사이버리스크 평가

□ 보안조치 기반 정적 사이버리스크 평가 방법 순서

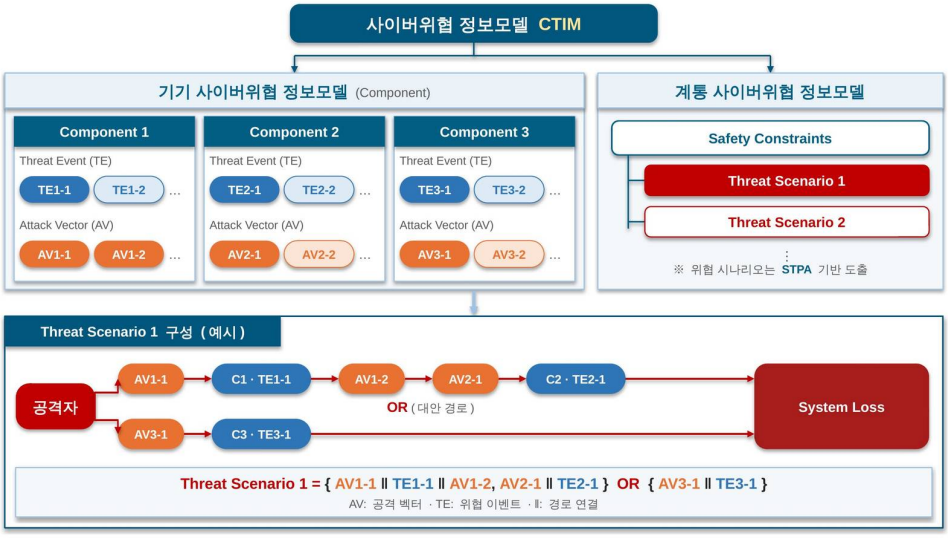
1) CS/CDA 식별
2) 사이버위협 정보모델 작성
   - ○ CDA 사이버위협 정보모델: CDA의 운영환경, 사용되는 SW, 인터페이스, 보안기능 및 공격벡터 등을 분석하여 CDA(기기) 수준의 위협 이벤트 식별
   - ○ CS 사이버위협 정보모델: CDA 사이버위협 정보모델을 활용하여 CDA가 포함되는 CS의 기능, 인터페이스 및 보안기능 등을 분석하여 CS(계통)수준의 위협 시나리오 식별
   - ○ CS 위협 시나리오: STPA 방법론 활용하여 체계적인 위협 시나리오 도출



<보안조치기반 사이버리스크 정적 평가 프레임워크>

04 CDA 보안조치 기반 정적 사이버리스크 평가

- 계통/기기 사이버위협 정보모델 구조



04 CDA 보안조치 기반 정적 사이버리스크 평가

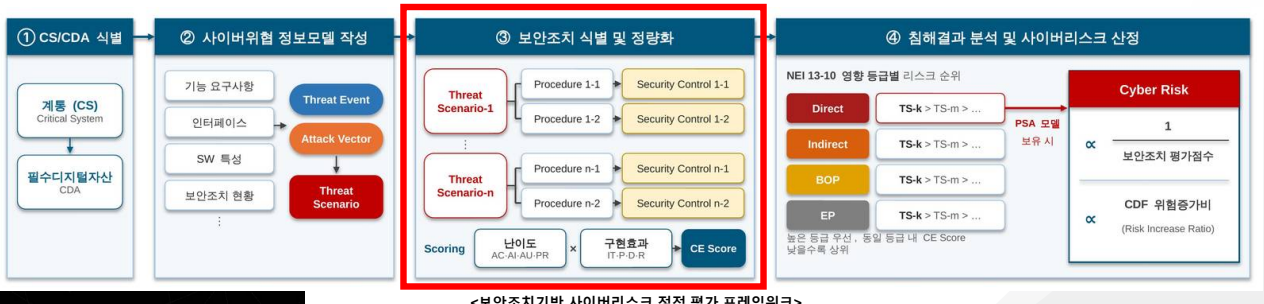
3) 보안조치 식별 및 정량화

○ 2)의 절차에서 식별된 위협 시나리오를 대응할 수 있는 해당 CS/CDA의 기술적, 관리적 및 운영적 보안조치 식별

○ 식별된 보안조치에 대해 정성적인 평가(High, Medium, Low)를 통해 정량화 (보안조치 평가 점수)

- 보안조치의 난이도: Configuration(AC), Information(AI), Authentication(AU), Persistence(PR)
- 보안조치의 구현효과: Implementation Type(IT), Protect, Detect, Response & Recover

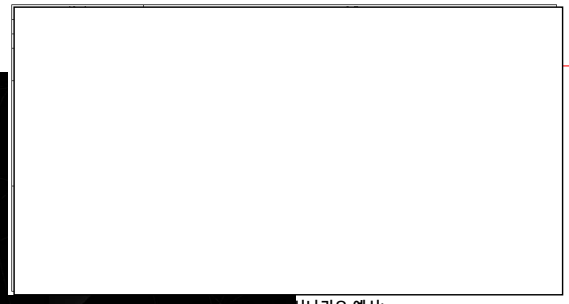
○ 보안조치 평가 점수(CSE, Combined Security Effectiveness score)가 높을수록 위협 시나리오의 실현 가능성은 낮아짐.



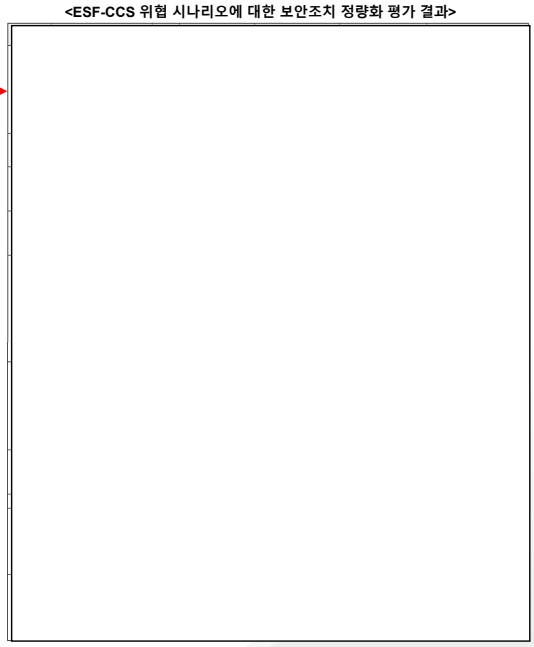
<보안조치기반 사이버리스크 정적 평가 프레임워크>

04 CDA 보안조치 기반 정적 사이버리스크 평가

- **ESF-CCS 보안조치 식별 및 정량화**
  - ESF-CCS에 대한 계통 및 기기 사이버위협 정보모델 작성
  - 작성된 사이버위협정보모델로부터 위협 시나리오 식별
  - 위협 시나리오에 대한 보안조치 식별 및 정량화



시나리오 예시>

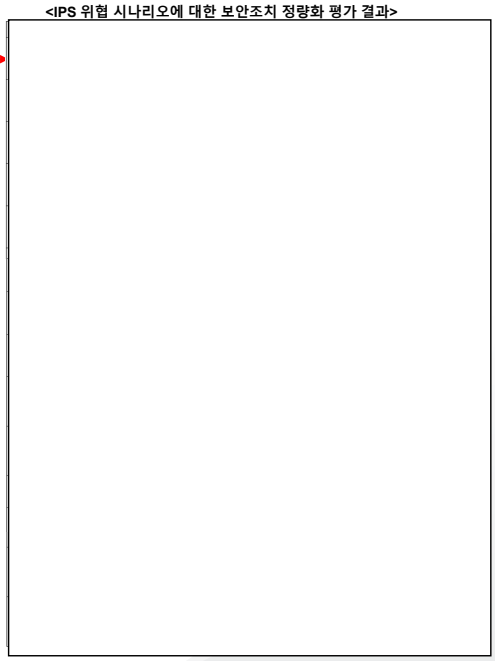


바른기술

23

04 CDA 보안조치 기반 정적 사이버리스크 평가

- **정보처리계통(IPS) 보안조치 식별 및 정량**
  - IPS에 대한 계통 및 기기 사이버위협 정보모델 작성
  - 작성된 사이버위협정보모델로부터 위협 시나리오 식별
  - 위협 시나리오에 대한 보안조치 식별 및 정량화



바른기술

24

04 CDA 보안조치 기반 정적 사이버리스크 평가

4) 침해 결과 정량화

○ NEI 13-10 활용하여 사이버위협에 따른 원자력시설 발전소 침해 영향 정도를 4가지 등급으로 분류

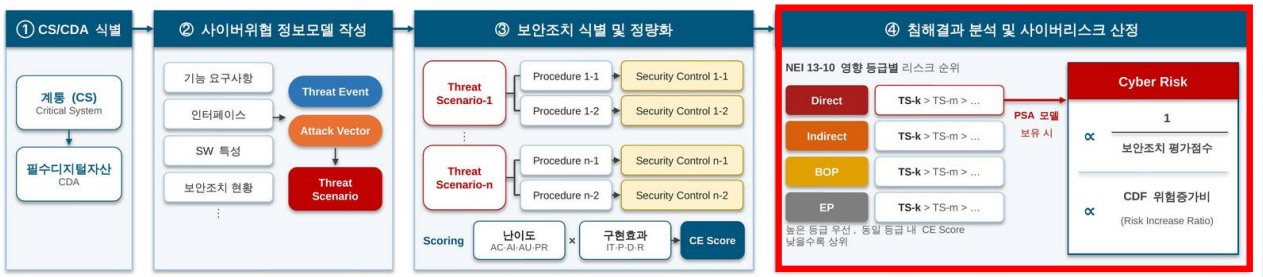
- Direct > Indirect, BOP > EP

○ 보안조치 평가 점수에 상관없이 위 등급에 따라 사이버리스크 순위가 결정되며, 같은 등급의 경우 보안조치 평가 점수가 낮을수록 사이버리스크 순위는 높음.

○ Direct 그룹 중 안전기능과 관련된 CDA/CS는 PSA 모델을 활용하여 사이버위협으로 인한 CDF(Core Damage Frequency)의 상대적인 증가량(RIR, Risk Increase Ratio)을 산출가능 → 원자력시설의 영향 정도를 정량화

$$Cyber\ Risk = F(Likelihood, Degree\ of\ Impact)$$

- Likelihood: 보안조치 평가 점수를 활용하여 간접적으로 산출
- Degree of Impact: CDF의 상대적 증가량인 RIR을 계산하여 산출



<보안조치기반 사이버리스크 정적 평가 프레임워크>

04 CDA 보안조치 기반 정적 사이버리스크 평가

4) 침해 결과 정량화

#	Threat Scenarios	Condition	CE Score

#	Components	RAW	Possible Scenario	#	Components	RAW	Possible Scenario	#	Components	RAW	Possible Scenario
1											
2											
3											
4											
5											
6											
7											
8											
9											
10											
11											
12											
13											
14											
15											
16											
17											
18											
19											
20											
21											
22											
23											
24											
25											
26											
27											

<해당 CDA 위협에 따른 CDF 증가량>

2 CES>

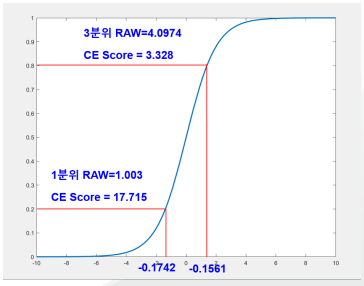
ation using Logistic Sigmoid Function with Z-score

$$\text{ean}}, CES_z(i) = \frac{CES(i) - CES_{mean}}{CES_{std}}$$

$$\frac{Z_MAX}{W_{Z_MIN}}(0\sim1)$$

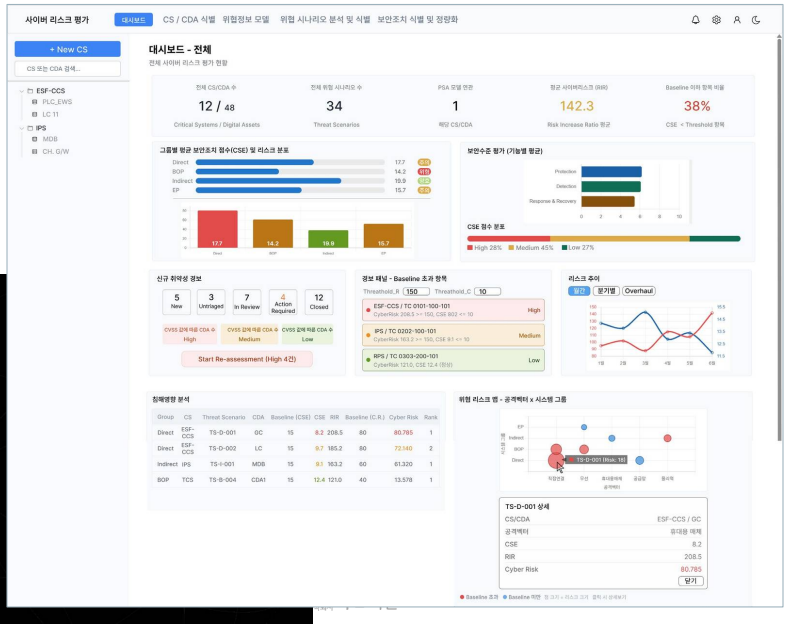
$$\frac{MIN}{Z_MIN}(0\sim1)$$

$$S_N(j))(0\sim1)$$



04 CDA 보안조치 기반 정적 사이버리스크 평가

□ 보안조치 기반 정적 사이버리스크 평가 툴 (웹기반)



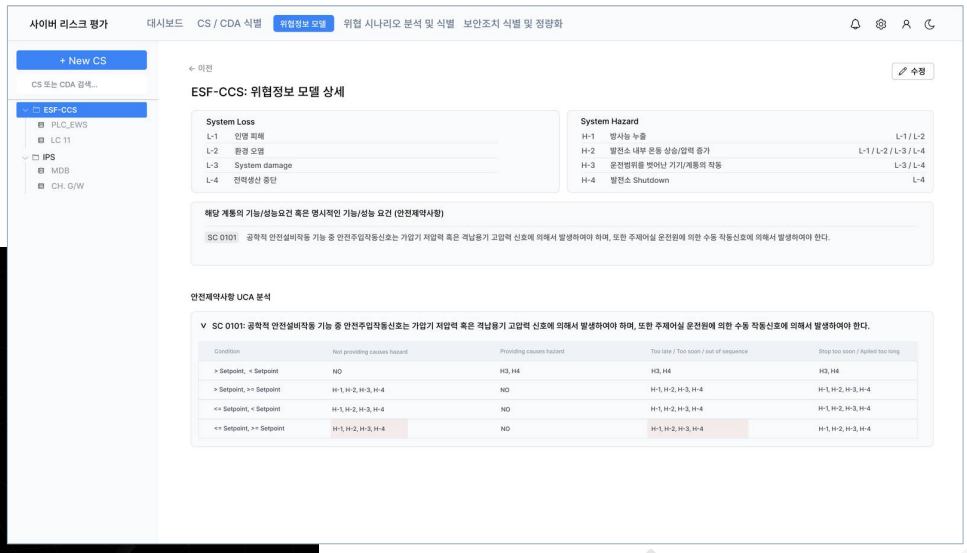
- **대시보드 핵심 지표**
  - 전체 CS/CDA 수 · 위협 시나리오 수
  - PSA 모델 연관 건수 · 평균 RIR
  - Baseline 이하 항목 비율
- **그룹별 CSE 및 리스크 분포**
  - Direct · Indirect · BOP · EP 그룹별 평균 CSE
- **Baseline 초과 경보 패널**
  - Threshold_R / Threshold_C 설정값 대비 초과 항목
- **위협 리스크 맵 (공격벡터 × 시스템 그룹)**
  - 점 클릭 시 CSE · RIR · Cyber Risk 상세 팝업

페이지 구성
CS/CDA 식별 · 위협정보 모델 · 위협 시나리오 분석 · 보안조치 식별 및 정량화

04 CDA 보안조치 기반 정적 사이버리스크 평가

□ 보안조치 기반 정적 사이버리스크 평가 툴 (웹기반)

- 화면 ① — 사이버위협 정보모델(CTIM) 작성 : STPA System Loss · Hazard · UCA

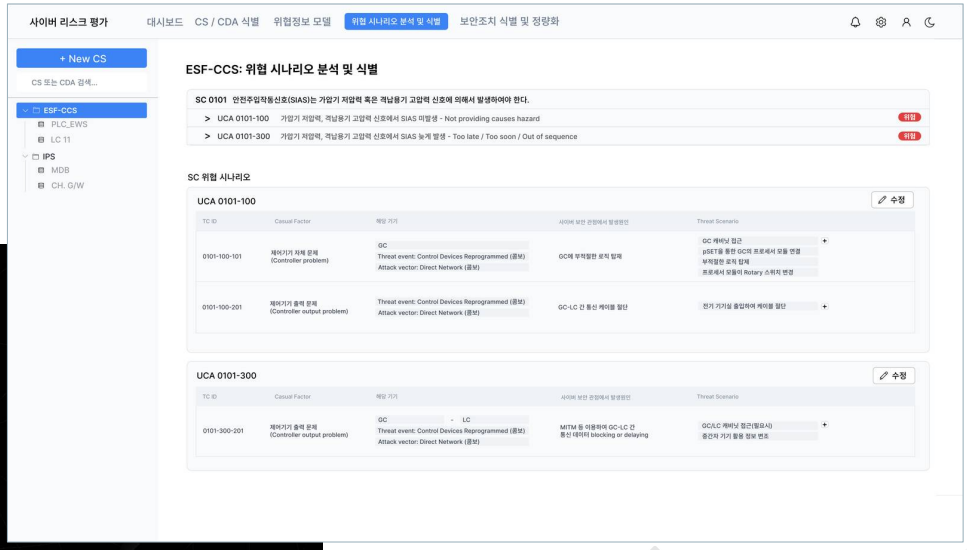


- **System Loss L-1 ~ L-4**
  - 인명 피해 · 환경 오염 · System damage · 전력생산 중단
- **System Hazard H-1 ~ H-4**
  - 각 Hazard가 어느 Loss로 이어지는지 매핑
- **안전제약사항 (SC)**
  - 계통 기능·성능 요건을 SC 문장으로 기술
- **안전제약사항 UCA 분석**
  - 4개 조건 × 4개 UCA 유형 → 해당 Hazard 체크

04 CDA 보안조치 기반 정적 사이버리스크 평가

□ 보안조치 기반 정적 사이버리스크 평가 툴 (웹기반)

- 화면 ② — 위협 시나리오 분석 및 식별 : UCA → Causal Factor → 위협 시나리오

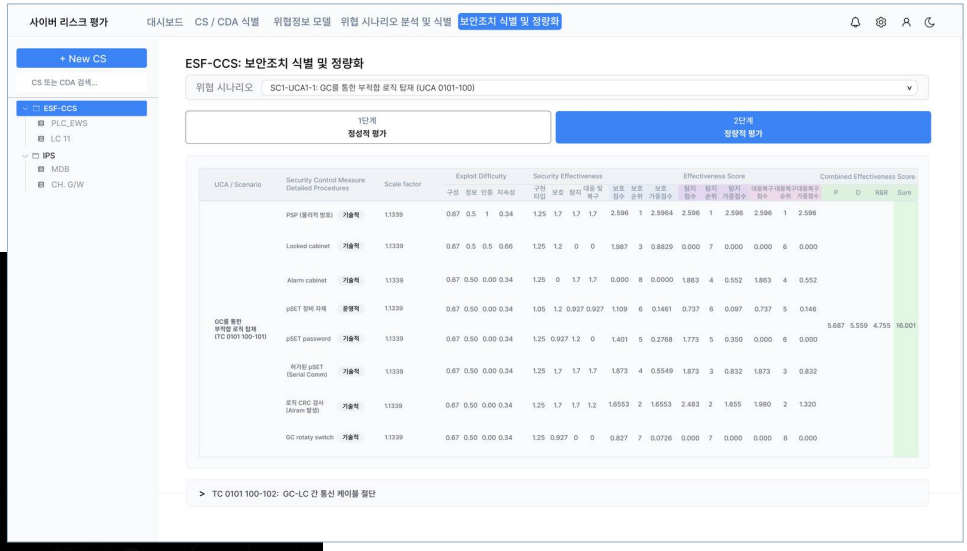


- SC → UCA 트리
  - UCA별 위험 등급을 상단에 표시
- Casual Factor
  - 제어기기 자체 문제 · 출력 문제 등 드롭다운
- Threat event · Attack vector
  - NIST SP 800-82 / NEI 10-09 항목을 콤보로 선택
- Threat Scenario
  - UCA 하나당 복수 시나리오 등록 (TC ID 부여)

04 CDA 보안조치 기반 정적 사이버리스크 평가

□ 보안조치 기반 정적 사이버리스크 평가 툴 (웹기반)

- 화면 ③ — 보안조치 식별 및 정량화 : 정성 평가 → CSE 산출



- 1단계 정성적 평가
  - 보안조치별 High / Medium / Low 선택
- 2단계 정량적 평가
  - 정성 값이 자동으로 수치로 변환
- Exploit Difficulty
  - 구성(AC) · 정보(AI) · 인증(AU) · 지속성(PR)
- Security Effectiveness
  - 구현타입 · 보호 · 탐지 · 대응 및 복구
- Combined Effectiveness
  - P · D · R&R 기능별 가중합 → Sum

05 결론

규제 요구	NIDS	HIDS	리스크 평가
지속적 모니터링 · 리스크 기반 관리	L1(제어기) + L2(네트워크) 다계층 탐지	안전계통 MTP 호스트 감시	탐지 → 안전영향 정량화
• RG 5.71 Rev.1, IAEA·IEC, KINAC/RS-015, 국정원 가이드라인 • 국정원 지침은 Level 1(제어기)까지 관제 범위 확대 • SMR/AR(Part 53): 등급화·결과 기반·원격 운영	• APR1400 실장비 테스트베드, 단방향 수집 • HR-SDL/SDN·제어로직·플랜트 모델 기반 탐지 • 통합 탐지율 **94.2%** (2단계 목표 ≥ 97%)	• 프로세스·파일·시스템파일·네트워크·공유메모리 감시 • 기존 MTP 응용에 영향 없이 부하율 60% 이내	• 정적: 보안조치 CE Score + PSA RAW + NEI 13-10 • 동적: DBN 기반 CDA 상태추정 (정상/고장/침해) • MPAS-APR1400 연계 **실시간 플랜트 리스크**

☐ **현장 적용**

- 신한울 3·4호기 CSOC에 L1 + 일부 L2 탐지 반영 추진중
- 기존 계통 설계변경 없는 비안전등급 추가설비(단방향 수집 + 탐지/관제 서버)
- 외산 비의존 독자 기술 → 수출 시 기술·데이터 주권 확보

☐ **향후 과제**

- 실원전 **시운전 단계 실증** 및 오탐(False Positive) 관리 체계
- 호기별 탐지규칙·공정모델 재엔지니어링 자동화
- 보안–운전 조직 R&R, 사이버 대응 절차서 정립
- SMR/AR: 설계 단계부터 제어기 수준 관제 내재화(Security-by-Design)

네트워크 중심 관제 → 제어기(L1) 수준 가시성 확장 + 사이버리스크 정량화 : "탐지"에서 "안전영향 판단"으로

Acknowledgements
This work was supported by the Nuclear Safety Research Program through the Korea Foundation Of Nuclear Safety (KoFONS) using the financial resource granted by the Nuclear Safety and Security Commission (NSSC) of the Republic of Korea. (No. RS-2021-KN059410), and the National Research Foundation (NRF) using the financial resource granted by the Ministry of Science and ICT of the Republic of Korea. (No. RS-2022-00144287).

A nuclear research institute
reshaping the future based
on **people's trust**

THANK YOU

Korea Atomic Energy Research Institute

KNS 2026 AUTUMN MEETING · WORKSHOP

2026 한국원자력학회 추계학술발표회
원자력 사이버보안 워크숍 발표자료집

원자력시설 사이버보안 규제 변화, 이행 현황과 과제 — 디지털 I&C 시대, 대형원전에서 SMR·AR까지

2026. 10. 28.(수) 14:00–18:00 · 경주화백컨벤션센터(HICO) 2층 204호

한국원자력학회
KOREAN NUCLEAR SOCIETY

주소	(34166) 대전광역시 유성구 유성대로 794, 4층(장대동, 뉴토피아빌딩)
홈페이지	www.kns.org
주관	원자력계측제어, 인간공학 및 자동원격 연구회
워크숍 홈페이지	https://2026-kns-nuclear-cyber.github.io/

KNS(P)-004-2026